

# Einführung und Methodik

## Über ISACA

ISACA® ([isaca.org](http://isaca.org)) ist ein seit nahezu 50 Jahren bestehender globaler Verband, der Einzelpersonen und Unternehmen dabei unterstützt, Technologiepotenziale auszuschöpfen. Technologie treibt die Welt von heute an, und ISACA stattet Experten mit Know-how und Qualifikationen aus, führt Fortbildungen durch und erweitert konsequent das Kontaktnetzwerk, um die Karriere dieser Experten voranzubringen und ihre Organisationen bei der Transformation zu unterstützen. ISACA nutzt die Expertise von einer halben Million engagierter Fachleute in den Bereichen Informations- und Cybersicherheit, Governance, Assurance, Risiko und Innovation sowie die Erfahrung ihrer Tochtergesellschaft CMMI® Institute, um Innovation mittels Technologie voranzutreiben. ISACA ist in mehr als 188 Ländern vertreten, darunter mehr als 217 Chapter und Büros in den Vereinigten Staaten und China.

## Haftungsausschluss

ISACA hat das *COBIT® 2019-Rahmenwerk: Einführung und Methodik* (das „Werk“) in erster Linie als Weiterbildungsressource für EGIT- (Enterprise Governance of Information and Technology), Prüfungs-, Risiko- und Sicherheitsexperten konzipiert und erstellt. ISACA übernimmt keinerlei Gewähr, dass die Verwendung des Werks zu den gewünschten Ergebnissen führen wird. Das Werk sollte weder dahingehend ausgelegt werden, dass alle erforderlichen Informationen, Verfahren und Tests darin enthalten sind, noch dahingehend, dass alle nicht enthaltenen Informationen, Verfahren und Tests, mit denen dieselben Ergebnisse erzielt werden können, ausgeschlossen sind. Bei der Überlegung, wie angemessen bestimmte Informationen, Verfahren oder Tests sind, sollte sich der Anwender auf sein fachliches Urteilsvermögen stützen und die spezifischen Umstände berücksichtigen, die sich aus dem jeweiligen System oder der IT-Umgebung ergeben.

## Disclaimer

ISACA has designed and created *COBIT® Framework: Introduction and Methodology* (the „Work“) primarily as an educational resource for enterprise governance of information and technology (EGIT), assurance, risk and security professionals. ISACA makes no claim that use of any of the Work will assure a successful outcome. The Work should not be considered inclusive of all proper information, procedures and tests or exclusive of other information, procedures and tests that are reasonably directed to obtaining the same results. In determining the propriety of any specific information, procedure or test, enterprise governance of information and technology (EGIT), assurance, risk and security professionals should apply their own professional judgment to the specific circumstances presented by the particular systems or information technology environment.

## Verantwortlichkeit für die Übersetzung

Das vorliegende Werk ist die *deutsche* Übersetzung der englischen Version *COBIT® Framework: Introduction and Methodology*. ISACA Germany Chapter hat die Übersetzung mit der Genehmigung der ISACA® ausgeführt. ISACA Germany Chapter übernimmt die alleinige Verantwortung für die Richtigkeit und Originaltreue der Übersetzung.

## Quality Statement

This Work is translated into *German* from the English language version of *COBIT® Framework: Introduction and Methodology* by the ISACA Germany Chapter with the permission of ISACA®. The ISACA Germany Chapter assumes sole responsibility for the accuracy and faithfulness of the translation.

## Copyright

© 2020 ISACA. Alle Rechte vorbehalten. Handbücher zur Verwendung sind unter [www.isaca.org/COBITuse](http://www.isaca.org/COBITuse) verfügbar.  
© 2020 ISACA. All rights reserved. For usage guidelines, see [www.isaca.org/COBITuse](http://www.isaca.org/COBITuse).

*COBIT® 2019-Rahmenwerk: Einführung und Methodik*  
ISBN 978-1-60420-857-3

---

**ISACA**

1700 E. Golf Road, Suite 400

Schaumburg, IL 60173, USA

Telefon: +1.847.660.5505

Fax: +1.847.253.1755

Kontaktieren Sie uns unter: <https://support.isaca.org>

Website: [www.isaca.org](http://www.isaca.org)

**Besuchen Sie die ISACA Online-Foren:** <https://engage.isaca.org/onlineforums>

**Twitter:** <http://twitter.com/ISACANews>

**LinkedIn:** <http://linkd.in/ISACAOOfficial>

**Facebook:** [www.facebook.com/ISACAHQ](http://www.facebook.com/ISACAHQ)

**Instagram:** [www.instagram.com/isacanews/](http://www.instagram.com/isacanews/)

## **IN MEMORIAM: JOHN LAINHART (1946–2018)**

---

### **In memoriam: John Lainhart (1946–2018)**

Gewidmet John Lainhart, dem ISACA-Vorsitzenden von 1984–1985. John war maßgeblich an der Erstellung des COBIT®-Rahmenwerks beteiligt und hatte zuletzt den Vorsitz der COBIT® 2019-Arbeitsgruppe inne, die mit diesem Werk ein erfolgreiches Ergebnis präsentiert. Während seiner vier Jahrzehnte bei ISACA nahm John zahlreiche Aufgaben innerhalb des Verbandes wahr und verfügte über die ISACA-Zertifizierungen CISA, CRISC, CISM und CGEIT. John hinterlässt ein bemerkenswertes persönliches und fachliches Vermächtnis. Sein Einsatz hatte wesentlichen Einfluss auf die Entwicklung von ISACA.

# Danksagungen

Die ISACA dankt den folgenden Unterstützern:

## **COBIT-Arbeitsgruppe (2017–2018)**

John Lainhart, Vorsitzender, CISA, CRISC, CISM, CGEIT, CIPP/G, CIPP/US, Grant Thornton, USA

Matt Conboy, Cigna, USA

Ron Saull, CGEIT, CSP, Great-West Lifeco & IGM Financial (im Ruhestand), Kanada

## **Entwicklungsteam**

Steven De Haes, Ph.D., Management School der Universität Antwerpen, Belgien

Matthias Goorden, PwC, Belgien

Stefanie Grijp, PwC, Belgien

Bart Peeters, PwC, Belgien

Geert Poels, Ph.D., Universität Gent, Belgien

Dirk Steuperaert, CISA, CRISC, CGEIT, IT In Balance, Belgien

## **Review-Experten**

Sarah Ahmad Abedin, CISA, CRISC, CGEIT, Grant Thornton LLP, USA

Floris Ampe, CISA, CRISC, CGEIT, CIA, ISO27000, PRINCE2, TOGAF, PwC, Belgien

Elisabeth Antonssen, Nordea Bank, Schweden

Krzysztof Baczkiewicz, CHAMP, CITAM, CSAM, Transpectit, Polen

Christopher M. Ballister, CRISC, CISM, CGEIT, Grant Thornton, USA

Gary Bannister, CGEIT, CGMA, FCMA, Österreich

Graciela Braga, CGEIT, Prüferin und Beraterin, Argentinien

Ricardo Bria, CISA, CRISC, CGEIT, COTO CICSa, Argentinien

Sushil Chatterji, CGEIT, Edutech Enterprises, Singapur

Peter T. Davis, CISA, CISM, CGEIT, COBIT 5-Assessor, CISSP, CMA, CPA, PMI-RMP, PMP, Peter

Davis+Mitarbeiter, Kanada

James Doss, CISM, CGEIT, EMCCA, PMP, SSGB, TOGAF 9, ITvalueQuickStart.com, USA

Yalcin Gerek, CISA, CRISC, CGEIT, ITIL-Experte, Prince2, ISO 20000LI, ISO27001LA, TAC AS., Türkei

James L. Golden, Golden Consulting Associates, USA

J. Winston Hayden, CISA, CISM, CRISC, CGEIT, Südafrika

Jimmy Heschl, CISA, CISM, CGEIT, Red Bull, Österreich

Jorge Hidalgo, CISA, CISM, CGEIT, Chile

John Jasinski, CISA, CRISC, CISM, CGEIT, COBIT 5-Assessor, CSM, CSPO, IT4IT-F, ITIL-Experte, Lean IT-F, MOF, SSBB, TOGAF-F, USA

Joanna Karczewska, CISA, Polen

Glenn Keaveny, CEH, CISSP, Grant Thornton, USA

Eddy Khoo S. K., CGEIT, Kuala Lumpur, Malaysia

Joao Souza Neto, CRISC, CGEIT, Universidade Católica de Brasília, Brasilien

Tracey O'Brien, CISA, CISM, CGEIT, IBM Corp (im Ruhestand), USA

Zachy Olorunjojon, CISA, CGEIT, PMP, BC Ministry of Health, Victoria, BC, Kanada

Opeyemi Onifade, CISA, CISM, CGEIT, BRMP, CISSP, ISO 27001LA, M.IoD, Afenoid Enterprise Limited, Nigeria

Andre Pitkowski, CRISC, CGEIT, CRMA-IIA, OCTAVE, SM, APIT Consultoria de Informatica Ltd., Brasilien

Dirk Reimers, Entco Deutschland GmbH, A Micro Focus Company

Steve Reznik, CISA, CRISC, ADP, LLC., USA

Bruno Horta Soares, CISA, CRISC, CGEIT, PMP, GOVaaS – Governance Advisors, as-a-Service, Portugal

Dr. Katalin Szenes, Ph.D., CISA, CISM, CGEIT, CISSP, John von Neumann Fakultät für Informatik,

Óbuda- Universität, Ungarn

## Danksagungen (Forts.)

### Review-Experten

Peter Tessin, CISA, CRISC, CISM, CGEIT, Discover, USA  
Mark Thomas, CRISC, CGEIT, Escoute, USA  
John Thorp, CMC, ISP, ITCP, The Thorp Network, Kanada  
Greet Volders, CGEIT, COBIT-Beurteilender, Voqualis N.V., Belgien  
Markus Walter, CISA, CISM, CISSP, ITIL, PMP, TOGAF, PwC Singapur/Schweiz  
David M. Williams, CISA, CAMS, Westpac, Neuseeland  
Greg Witte, CISM, G2 Inc., USA

### Vorstand der ISACA

Rob Clyde, CISM, Clyde Consulting LLC, USA, Vorsitzender  
Brennan Baybeck, CISA, CRISC, CISM, CISSP, Oracle Corporation, USA, stellv. Vorsitzender  
Tracey Dedrick, ehemaliger Chief Risk Officer von Hudson City Bancorp, USA  
Leonard Ong, CISA, CRISC, CISM, CGEIT, COBIT 5-Implementierer und Assessor, CFE, CIPM, CIPT, CISSP, CITBCM, CPP, CSSLP, GCFA, GCIA, GCIH, GSNA, ISSMP-ISSAP, PMP, Merck & Co., Inc., Singapur  
R.V. Raghu, CISA, CRISC, Versatilist Consulting India Pvt. Ltd, Indien  
Gabriela Reynaga, CISA, CRISC, COBIT 5 Foundation, GRCP, Holistics GRC, Mexiko  
Gregory Touhill, CISM, CISSP, Cyxtera Federal Group, USA  
Ted Wolff, CISA, Vanguard, Inc., USA  
Tichaona Zororo, CISA, CRISC, CISM, CGEIT, COBIT 5-Assessor, CIA, CRMA, EGIT | Enterprise Governance of IT, Südafrika  
Theresa Grafenstine, CISA, CRISC, CGEIT, CGAP, CGMA, CIA, CISSP, CPA, Deloitte & Touche LLP, USA, ISACA-Vorsitzende von 2017–2018  
Chris K. Dimitriadis, Ph.D., CISA, CRISC, CISM, INTRALOT, Griechenland, ISACA-Vorsitzender von 2015–2017  
Matt Loeb, CGEIT, CAE, FASAE, Chief Executive Officer, ISACA, USA  
Robert E. Stroud (1965–2018), CRISC, CGEIT, Xebialabs, Inc., USA, ISACA-Vorsitzender, von 2014–2015  
*ISACA ist zutiefst betrübt über das Ableben von Robert E. Stroud im September 2018.*

### Übersetzungsteam

Frank Schütz, Sprachenreich GmbH, Deutschland

### Review durch:

Markus Gaulke, CISA, CISM, CGEIT, CRISC, KPMG AG Wirtschaftsprüfungsgesellschaft,  
Vorstand ISACA Germany Chapter e.V., Fachbuchautor Praxiswissen COBIT, Deutschland

Prof. Dr. Michael Klotz, Professor für Informationsmanagement und Unternehmensorganisation,  
Hochschule Stralsund, Mitherausgeber der Zeitschrift „IT-Governance“, Deutschland

# INHALTSVERZEICHNIS

|                                                                                   |           |
|-----------------------------------------------------------------------------------|-----------|
| <b>Abbildungsverzeichnis .....</b>                                                | <b>9</b>  |
| <b>Kapitel 1 Einführung.....</b>                                                  | <b>11</b> |
| 1.1 Governance der unternehmensweiten I&T.....                                    | 11        |
| 1.2 Vorteile der I&T-Governance .....                                             | 11        |
| 1.3 COBIT als I&T-Governance-Rahmenwerk.....                                      | 13        |
| 1.3.1 Was ist COBIT und was nicht? .....                                          | 13        |
| 1.4 Aufbau dieser Publikation .....                                               | 14        |
| <b>Kapitel 2 Zielgruppen.....</b>                                                 | <b>15</b> |
| 2.1 Governance-Anspruchsgruppen .....                                             | 15        |
| <b>Kapitel 3 COBIT-Prinzipien.....</b>                                            | <b>17</b> |
| 3.1 Einleitung .....                                                              | 17        |
| 3.2 Sechs Prinzipien für ein Governance-System .....                              | 17        |
| 3.3 Drei Prinzipien für ein Governance-Rahmenwerk.....                            | 18        |
| 3.4 COBIT® 2019 .....                                                             | 19        |
| <b>Kapitel 4 Grundlegende Konzepte: Governance-System und -Komponenten ...</b>    | <b>21</b> |
| 4.1 COBIT-Übersicht .....                                                         | 21        |
| 4.2 Governance- und Managementziele.....                                          | 22        |
| 4.3 Komponenten des Governance-Systems .....                                      | 23        |
| 4.4.3 Schwerpunktbereiche .....                                                   | 24        |
| 4.5 Designfaktoren .....                                                          | 25        |
| 4.6 Zielkaskade.....                                                              | 30        |
| 4.6.1 Unternehmensziele.....                                                      | 31        |
| 4.6.2 IT-bezogene Ziele.....                                                      | 32        |
| <b>Kapitel 5 COBIT Governance- und Managementziele.....</b>                       | <b>35</b> |
| 5.1 Zweck .....                                                                   | 35        |
| <b>Kapitel 6 Leistungssteuerung in COBIT .....</b>                                | <b>39</b> |
| 6.1 Definition.....                                                               | 39        |
| 6.2 Prinzipien der COBIT-Leistungssteuerung .....                                 | 39        |
| 6.3 Übersicht der COBIT-Leistungssteuerung.....                                   | 39        |
| 6.4 Managen der Prozessleistung .....                                             | 40        |
| 6.4.1 Prozessfähigkeitsstufen .....                                               | 40        |
| 6.4.2 Rating der Prozessaktivitäten .....                                         | 41        |
| 6.4.3 Reifegradstufen für Schwerpunktbereiche .....                               | 41        |
| 6.5 Leistungssteuerung anderer Komponenten des Governance-Systems.....            | 42        |
| 6.5.1 Leistungssteuerung von Organisationsstrukturen .....                        | 42        |
| 6.5.2 Leistungssteuerung von Informationselementen .....                          | 43        |
| 6.5.3 Leistungssteuerung von Kultur und Verhalten.....                            | 45        |
| <b>Kapitel 7 Konzeption eines zugeschnittenen Governance-Systems.....</b>         | <b>47</b> |
| 7.1 Auswirkungen von Designfaktoren.....                                          | 47        |
| 7.2 Phasen und Schritte im Gestaltungsprozess .....                               | 49        |
| <b>Kapitel 8 Implementierung der Governance der unternehmensweiten I&amp;T ..</b> | <b>51</b> |
| 8.1 Zweck des COBIT-Implementierungsleitfadens .....                              | 51        |
| 8.2 COBIT-Implementierungsansatz.....                                             | 51        |
| 8.2.1 Phase 1 – Welche Treiber gibt es?.....                                      | 52        |
| 8.2.2 Phase 2 – Wo befinden wir uns heute? .....                                  | 52        |
| 8.2.3 Phase 3 – Wo möchten wir stehen? .....                                      | 53        |

|                                                                                                                          |    |
|--------------------------------------------------------------------------------------------------------------------------|----|
| 8.2.4 Phase 4 – Was muss getan werden? .....                                                                             | 53 |
| 8.2.5 Phase 5 – Wie kommen wir dorthin? .....                                                                            | 53 |
| 8.2.6 Phase 6 – Sind wir angekommen? .....                                                                               | 53 |
| 8.2.7 Phase 7 – Wie können wir die Dynamik beibehalten? .....                                                            | 53 |
| 8.3 Beziehung zwischen dem <i>COBIT® 2019-Designleitfaden</i> und dem <i>COBIT® 2019-Implementierungsleitfaden</i> ..... | 54 |

## **Kapitel 9 Erste Schritte mit COBIT: Erstellen des Business Case ..... 55**

|                                                   |    |
|---------------------------------------------------|----|
| 9.1 Business Case .....                           | 55 |
| 9.2 Kurzfassung .....                             | 55 |
| 9.3 Hintergrund .....                             | 56 |
| 9.4 Geschäftliche Herausforderungen .....         | 57 |
| 9.4.1 GAP-Analyse und Ziel .....                  | 58 |
| 9.4.2 Betrachtete Alternativen .....              | 58 |
| 9.5 Lösungsvorschlag .....                        | 58 |
| 9.5.1 Phase 1: Vorplanung .....                   | 58 |
| 9.5.2 Phase 2: Programm-Implementierung .....     | 59 |
| 9.5.3 Programmumfang .....                        | 59 |
| 9.5.4 Programm-Methodik und Ausrichtung .....     | 60 |
| 9.5.5 Programmergebnisse .....                    | 60 |
| 9.5.6 Programmrisiko .....                        | 61 |
| 9.5.7 Anspruchsgruppen .....                      | 61 |
| 9.5.8 Kosten-Nutzen-Analyse .....                 | 61 |
| 9.5.9 Herausforderungen und Erfolgsfaktoren ..... | 62 |

## **Kapitel 10 COBIT und andere Standards ..... 65**

|                                                            |    |
|------------------------------------------------------------|----|
| 10.1 Leitprinzipien .....                                  | 65 |
| 10.2 Liste der Standards auf die Bezug genommen wird ..... | 65 |



# ABBILDUNGSVERZEICHNIS

## Kapitel 1 Einführung

|                                                                                                   |    |
|---------------------------------------------------------------------------------------------------|----|
| Abbildung 1.1 – Kontext der Governance der unternehmensweiten Informationen und Technologie ..... | 11 |
|---------------------------------------------------------------------------------------------------|----|

## Kapitel 2 Zielgruppen

|                                            |    |
|--------------------------------------------|----|
| Abbildung 2.1 COBIT-Anspruchsgruppen ..... | 15 |
|--------------------------------------------|----|

## Kapitel 3 COBIT-Prinzipien

|                                                               |    |
|---------------------------------------------------------------|----|
| Abbildung 3.1 – Prinzipien eines Governance-Systems .....     | 17 |
| Abbildung 3.2 – Prinzipien eines Governance-Rahmenwerks ..... | 18 |

## Kapitel 4 Grundlegende Konzepte: Governance-System und -Komponenten

|                                                                              |    |
|------------------------------------------------------------------------------|----|
| Abbildung 4.1 – COBIT-Übersicht .....                                        | 21 |
| Abbildung 4.2 – COBIT-Kernmodell .....                                       | 23 |
| Abbildung 4.3 – COBIT-Komponenten eines Governance-Systems .....             | 24 |
| Abbildung 4.4 – COBIT-Designfaktoren .....                                   | 25 |
| Abbildung 4.5 – Designfaktor Unternehmensstrategie .....                     | 25 |
| Abbildung 4.6 – Designfaktor Unternehmensziele .....                         | 26 |
| Abbildung 4.7 – Designfaktor Risikoprofil (IT-Risikokategorien) .....        | 26 |
| Abbildung 4.8 – Designfaktor I&T-bezogene Probleme .....                     | 27 |
| Abbildung 4.9 – Designfaktor Bedrohungslandschaft .....                      | 27 |
| Abbildung 4.10 – Designfaktor Compliance-Anforderungen .....                 | 28 |
| Abbildung 4.11 – Designfaktor Rolle der IT .....                             | 28 |
| Abbildung 4.12 – Designfaktor Sourcing-Modell für die IT .....               | 28 |
| Abbildung 4.13 – Designfaktor IT-Implementierungsmethoden .....              | 29 |
| Abbildung 4.14 – Designfaktor Strategie zur Übernahme von Technologien ..... | 29 |
| Abbildung 4.15 – Designfaktor Unternehmensgröße .....                        | 29 |
| Abbildung 4.16 – COBIT-Zielkaskade .....                                     | 30 |
| Abbildung 4.17 – Zielkaskade: Unternehmensziele und -metriken .....          | 31 |
| Abbildung 4.18 – Zielkaskade: IT-bezogene Ziele und Metriken .....           | 32 |

## Kapitel 5 COBIT Governance- und Managementziele

|                                                                                              |    |
|----------------------------------------------------------------------------------------------|----|
| Abbildung 5.1 – COBIT-Kernmodell: Governance- und Managementziele und jeweiliger Zweck ..... | 35 |
|----------------------------------------------------------------------------------------------|----|

## Kapitel 6 Leistungssteuerung in COBIT

|                                                                                              |    |
|----------------------------------------------------------------------------------------------|----|
| Abbildung 6.1 – Fähigkeitsstufen .....                                                       | 40 |
| Abbildung 6.2 – Prozessfähigkeitsstufen .....                                                | 41 |
| Abbildung 6.3 – Reifegradstufen für Schwerpunktbereiche .....                                | 42 |
| Abbildung 6.4 – COBIT-Informationsreferenzmodell: Qualitätskriterien für Informationen ..... | 44 |

## Kapitel 7 Konzeption eines zugeschnittenen Governance-Systems

|                                                                                            |    |
|--------------------------------------------------------------------------------------------|----|
| Abbildung 7.1 – Einfluss von Designfaktoren auf ein Governance- und Managementsystem ..... | 47 |
| Abbildung 7.2 – Gestaltungsprozess des Governance-Systems .....                            | 49 |

## Kapitel 8 Implementierung der Governance der unternehmensweiten I&T

|                                                                                                                                  |    |
|----------------------------------------------------------------------------------------------------------------------------------|----|
| Abbildung 8.1 – COBIT-Implementierungs-Roadmap .....                                                                             | 52 |
| Abbildung 8.2 – Verbindungspunkte zwischen dem <i>COBIT-Designleitfaden</i> und dem <i>COBIT-Implementierungsleitfaden</i> ..... | 54 |

## Kapitel 9 Erste Schritte mit COBIT: Erstellen des Business Case

|                                                                                 |    |
|---------------------------------------------------------------------------------|----|
| Abbildung 9.1 – Herausforderungen und geplante Aktionen für die Muster AG ..... | 62 |
|---------------------------------------------------------------------------------|----|

Diese Seite wurde absichtlich freigelassen.

## Kapitel 1 Einführung

### 1.1 Governance der unternehmensweiten I&T

Im Zuge der digitalen Transformation sind Informationen und Technologie<sup>1</sup> (I&T) zu entscheidenden Faktoren geworden, wenn es darum geht Unternehmen zu unterstützen und Nachhaltigkeit und Wachstum sicherzustellen. Bislang war es bei den verantwortlichen Führungsebenen an der Tagesordnung, I&T-bezogene Entscheidungen zu delegieren, zu ignorieren oder zu vermeiden. In den meisten Branchen und Industrien ist eine solche Haltung allerdings heute schädlich. Die Schaffung von Mehrwert für die Anspruchsgruppen (d. h. das Realisieren von Vorteilen mit niedrigen Ressourcenkosten bei gleichzeitiger Optimierung des Risikos) basiert häufig auf einem hohen Digitalisierungsgrad neuer Geschäftsmodelle, effizienten Prozessen, erfolgreichen Innovationen usw. Das Überleben und Wachstum digitalisierter Unternehmen hängt daher zunehmend von I&T ab.

Angesichts der zentralen Bedeutung der I&T für das Risikomanagement und die Wertschöpfung in Unternehmen hat sich in den letzten drei Jahrzehnten ein besonderer Schwerpunkt auf die Governance der unternehmensweiten I&T (EGIT) herausgebildet. EGIT ist ein wesentlicher Bestandteil der Governance. Die Verantwortung dafür liegt bei der Geschäftsleitung, die die Definition und Implementierung von Prozessen, Strukturen und Beziehungsmechanismen in der Organisation überwacht, die es sowohl den Fachbereichsmitarbeitern als auch den IT-Experten ermöglichen, ihre Aufgaben im Hinblick auf die Anpassung von Geschäft und IT und die Schaffung von Geschäftswert aus durch I&T ermöglichten geschäftlichen Investitionen wahrzunehmen (**Abbildung 1.1**).

**Abbildung 1.1 – Kontext der Governance der unternehmensweiten Informationen und Technologie**



Quelle: De Haes, S.; Van Grembergen, W.; *Enterprise Governance of Information Technology: Achieving Alignment and Value, Featuring COBIT 5*, Springer International Publishing, Schweiz, 2. Aufl. 2015, <https://www.springer.com/us/book/9783319145464>

Die Governance der unternehmensweiten I&T ist komplex und vielschichtig. Es gibt keinen idealtypischen Weg, um eine effektive EGIT innerhalb einer Organisation zu konzipieren, zu implementieren und aufrechtzuerhalten. Daher müssen die Verantwortlichen die EGIT-Maßnahmen und deren Umsetzung in der Regel auf den jeweiligen Unternehmenskontext und die Erfordernisse zuschneiden. Sie müssen auch bereit sein, mehr Verantwortung für I&T zu übernehmen und eine andere Denkweise und Kultur zu fördern, um einen Mehrwert aus I&T zu generieren.

### 1.2 Vorteile der I&T-Governance

Grundsätzlich befasst sich die EGIT mit der Wertschöpfung aus der digitalen Transformation und der Minderung von Geschäftsrisiken, die sich aus dieser Transformation ergeben. Genauer gesagt, resultieren aus der erfolgreichen Umsetzung der EGIT drei Hauptergebnisse:

<sup>1</sup> Im gesamten Text wird IT als Bezeichnung für die Abteilung einer Organisation verwendet, die die Hauptverantwortung für die Technologie trägt. I&T, wie in diesem Text verwendet, bezieht sich auf alle Informationen, die das Unternehmen erzeugt, verarbeitet und nutzt, um seine Ziele zu erreichen, sowie auf die Technologie, die dies im gesamten Unternehmen unterstützt.

- **Nutzenrealisierung** – Bezieht sich auf die Schaffung von Mehrwert für das Unternehmen durch I&T sowie die Erhaltung und Steigerung des aus der bestehenden I&T abgeleiteten Wertes, Investitionen und die Eliminierung von IT-Initiativen und Betriebsmitteln, die keinen ausreichenden Wert liefern. Das Grundprinzip des I&T-Mehrwertes ist die Bereitstellung zweckoptimaler Dienstleistungen und Lösungen, die innerhalb des festgelegten Zeit- und Kostenrahmens die beabsichtigten finanziellen und nichtfinanziellen Vorteile bringen. Der Mehrwert, den I&T liefert, sollte direkt an der Wertschöpfung ausgerichtet sein, auf die sich das Unternehmen konzentriert. Der Mehrwert von IT sollte auch auf eine Weise gemessen werden, die die Auswirkungen und Beiträge von durch IT ermöglichten Investitionen in den Wertschöpfungsprozess des Unternehmens aufzeigt.
- **Risiko-Optimierung** – Bezieht sich auf das Geschäftsrisiko, das mit der Nutzung, dem Besitz, dem Betrieb, der Einbindung, dem Einfluss und der Einführung von I&T in einem Unternehmen verbunden ist. I&T-bezogene Geschäftsrisiken resultieren aus I&T-bezogenen Ereignissen, die sich potenziell auf das Geschäft auswirken könnten. Während sich die Wertschöpfung auf die *Schaffung* von Wert konzentriert, steht beim Risikomanagement die *Werterhaltung* im Vordergrund. Das Management von I&T-bezogenen Risiken sollte in den unternehmensweiten Risikomanagementansatz integriert werden, um sicherzustellen, dass sich das Unternehmen auch auf IT konzentriert. Es sollte in einer Weise gemessen werden, die die Auswirkungen und Beiträge der Optimierung des I&T-bezogenen Geschäftsrisikos zur Werterhaltung aufzeigt.
- **Ressourcenoptimierung** – Hierdurch wird sichergestellt, dass die geeigneten Fähigkeiten zur Umsetzung des Strategieplans vorhanden sind und ausreichende, angemessene und effektive Ressourcen bereitgestellt werden. Durch die Ressourcenoptimierung wird sichergestellt, dass eine integrierte, wirtschaftliche IT-Infrastruktur zur Verfügung steht, neue Technologien entsprechend den Anforderungen des Unternehmens eingeführt und veraltete Systeme modernisiert oder ersetzt werden. Da neben der Hard- und Software auch die Bedeutung der Mitarbeiter miteinbezogen wird, stehen auch die Bereitstellung von Schulungen, die Mitarbeiterbindung und die Gewährleistung der Kompetenz von wichtigem IT-Fachpersonal im Mittelpunkt. Daten und Informationen sind wichtige Ressourcen und deren Nutzung zur Realisierung eines optimalen Wertbezuges ist ein weiteres Schlüsselement der Ressourcenoptimierung.

Strategische Ausrichtung und Leistungsmessung sind von größter Bedeutung und für alle Aktivitäten relevant, um sicherzustellen, dass die I&T-bezogenen Ziele mit den Unternehmenszielen konform gehen.

In einer großen Fallstudie einer internationalen Fluggesellschaft konnten folgende Vorteile der EGIT aufgezeigt werden: niedrigere IT-bezogene Kontinuitätskosten, erhöhtes IT-gestütztes Innovationsvermögen, verbesserte Abstimmung von digitalen Investitionen und Geschäftszielen und -strategie, erhöhtes Vertrauen zwischen Geschäftsbereichen und IT sowie eine veränderte Denkhaltung hin zu einer „Wertschätzung“ der digitalen Assets.<sup>2</sup>

Untersuchungen haben gezeigt, dass Unternehmen mit mangelhaft konzipierten oder umgesetzten EGIT-Ansätzen hinsichtlich der Abstimmung von Geschäfts- und I&T-Strategie und -Prozessen schlechter abschneiden. Infolgedessen ist die Wahrscheinlichkeit, dass solche Unternehmen ihre beabsichtigten Geschäftsstrategien umsetzen und den Geschäftswert realisieren, den sie sich von der digitalen Transformation erhoffen, wesentlich geringer.<sup>3</sup>

Daraus wird deutlich, dass Governance weit über die oft anzutreffende (d. h. enge) Interpretation hinaus verstanden und umgesetzt werden muss, die das Akronym „Governance, Risk and Compliance“ (GRC) nahe legt. GRC suggeriert, dass Compliance und die damit verbundenen Risiken das gesamte Spektrum der Governance darstellen.

---

<sup>2</sup> De Haes, S.; W. Van Grembergen, W.; Enterprise Governance of Information Technology: Achieving Alignment and Value, Featuring COBIT 5, Springer International Publishing, Schweiz, 2. Aufl. 2015, <https://www.springer.com/us/book/9783319145464>

<sup>3</sup> De Haes, S.; Joshi, A.; Van Grembergen, W.; State and Impact of Governance of Enterprise IT in Organizations: Key Findings of an International Study, ISACA® Journal, Bd. 4, 2015, <https://www.isaca.org/Journal/archives/2015/Volume-4/Pages/state-and-impact-of-governance-of-enterprise-it-in-organizations.aspx>. Siehe auch De Haes und van Grembergen, a. a. O.

### 1.3 COBIT als I&T-Governance-Rahmenwerk

Im Laufe der Jahre wurden Rahmenwerke auf der Basis von bewährten Praktiken mit dem Ziel entwickelt und vorangetrieben, den Prozess des Verstehens, Konzipierens und Implementierens der EGIT zu unterstützen. COBIT® 2019 baut auf mehr als 25 Jahren Entwicklungserfahrung in diesem Bereich auf, wobei nicht nur neue Erkenntnisse aus der Wissenschaft einfließen, sondern diese Erkenntnisse auch Anwendung in der Praxis finden.

Seit der Gründung hat sich COBIT® zu einem immer weiteren und umfassenderen I&T-Governance- und Management-Rahmenwerk entwickelt und etabliert sich zunehmend als allgemein anerkanntes Rahmenwerk für die I&T-Governance.

#### 1.3.1 Was ist COBIT und was nicht?

Bevor nachfolgend das aktualisierte COBIT-Rahmenwerk beschrieben wird, ist es wichtig darzulegen, was COBIT ist und was nicht:

COBIT ist ein Rahmenwerk für Governance und Management der unternehmensweiten Informationen und Technologie,<sup>4</sup> das das gesamte Unternehmen einbezieht. In diesem Kontext versteht man unter unternehmensweiter I&T die gesamte Technologie und Informationsverarbeitung, die das Unternehmen einsetzt, um seine Ziele zu erreichen, unabhängig davon, wo im Unternehmen dies stattfindet. Mit anderen Worten: unternehmensweite I&T ist nicht auf die IT-Abteilung einer Organisation beschränkt, schließt diese aber ein.

Das COBIT-Rahmenwerk unterscheidet klar zwischen Governance und Management. Diese beiden Disziplinen umfassen unterschiedliche Aktivitäten, erfordern unterschiedliche Organisationsstrukturen und dienen unterschiedlichen Zwecken.

• **Governance** gewährleistet, dass:

- die Bedürfnisse, Voraussetzungen und Optionen der Anspruchsgruppen evaluiert werden, um ausgewogene, vereinbarte Unternehmensziele festzulegen.
- die Ausrichtung durch Priorisierung und Entscheidungsfindung vorgegeben wird.
- die Leistung und Compliance anhand der vereinbarten Ausrichtung und den Zielen beurteilt werden.

In den meisten Unternehmen liegt die Gesamtverantwortung für die Governance in den Händen der Geschäftsleitung unter der Führung des Vorsitzenden. Einzelne Verantwortlichkeiten hinsichtlich Governance können auch an andere geeignete Ebenen in der Organisationsstruktur delegiert werden, insbesondere in größeren, komplexen Unternehmen.

• **Management** umfasst die Planung, Begründung und Überwachung von Aktivitäten in Übereinstimmung mit der vom Governance-Organ vorgegebenen Richtung, um die Unternehmensziele zu erreichen.

In den meisten Unternehmen obliegt das Management den obersten Führungskräften unter der Leitung des Chief Executive Officer (CEO).

COBIT definiert folgende Komponenten zum Aufbau und zur Aufrechterhaltung eines Governance-Systems: Prozesse, Organisationsstrukturen, Richtlinien und Verfahren, Informationsflüsse, Kultur und Verhalten, Fähigkeiten und Infrastruktur.<sup>5</sup>

<sup>4</sup> In der gesamten Publikation implizieren Verweise auf das „Rahmenwerk für IT-Governance“ den vollen Umfang dieser Beschreibung.

<sup>5</sup> Diese Komponenten wurden in COBIT® 5 als Enabler bezeichnet.

COBIT definiert ebenfalls Designfaktoren, die vom Unternehmen berücksichtigt werden sollten, um das am besten geeignete Governance-System aufzubauen.

COBIT setzt bei Governance-Fragestellungen an, indem relevante Governance-Komponenten zu Governance- und Managementzielen gruppiert werden, die im Hinblick auf die erforderlichen Fähigkeitsstufen gemanagt werden können.

Mehrere Missverständnisse zu COBIT sollen aber auch ausgeräumt werden:

- COBIT ist keine vollständige Beschreibung der gesamten IT-Umgebung eines Unternehmens.
- COBIT ist kein Rahmenwerk zur Organisation von Geschäftsprozessen.
- COBIT ist kein (IT-)technisches Rahmenwerk zum Management der gesamten Technologie.
- COBIT trifft keine oder gibt keine IT-bezogenen Entscheidungen vor. COBIT liefert keine Entscheidung dahingehend, welche die beste IT-Strategie oder Architektur ist oder welche Kosten IT verursachen könnte oder sollte. Vielmehr definiert COBIT alle Komponenten, die beschreiben, welche Entscheidungen wie und von wem getroffen werden sollten.

## 1.4 Aufbau dieser Publikation

Der nachfolgende Teil dieser Publikation enthält die folgenden Kapitel:

- In Kapitel 2 werden die Zielgruppen von COBIT beschrieben.
- In Kapitel 3 werden die Prinzipien für I&T-Governance-Systeme sowie für bewährte Governance-Rahmenwerke dargestellt.
- In Kapitel 4 werden die grundlegenden Konzepte und die Terminologie von COBIT® 2019 erläutert, einschließlich des aktualisierten COBIT-Kernmodells mit den 40 Governance- und Managementzielen.
- In Kapitel 5 werden die 40 Governance- und Managementziele dargestellt.
- In Kapitel 6 wird das Konzept der Leistungssteuerung in COBIT® 2019 erläutert und wie Fähigkeitsstufen auf der Basis von Capability Maturity Model Integration (CMMI®) eingeführt werden.
- Kapitel 7 enthält eine kurze Einführung und einen Überblick über den *COBIT® 2019 Designleitfaden*.
- Kapitel 8 enthält eine kurze Einführung und einen Überblick über den *COBIT® 2019 Implementierungsleitfaden*.
- Kapitel 9 beschreibt ein detailliertes Beispiel, um Argumente für die Auswahl und Umsetzung von COBIT in einem Unternehmen zu veranschaulichen.
- Kapitel 10 listet die Standards, Rahmenwerke und Bestimmungen auf, die der Entwicklung von COBIT® 2019 zugrunde lagen.

## Kapitel 2

### Zielgruppen

#### 2.1 Governance-Anspruchsgruppen

Die Zielgruppen für COBIT sind die EGIT-Anspruchsgruppen und, im weiteren Sinne, die Corporate Governance-Anspruchsgruppen. Diese Anspruchsgruppen und den Nutzen, den sie aus COBIT ziehen können, sind in **Abbildung 2.1** dargestellt.

| <b>Abbildung 2.1 – COBIT-Anspruchsgruppen</b> |                                                                                                                                                                                                                                                           |
|-----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Anspruchsgruppe</b>                        | <b>Nutzen von COBIT</b>                                                                                                                                                                                                                                   |
| <b>Interne Anspruchsgruppen</b>               |                                                                                                                                                                                                                                                           |
| <b>Geschäftsleitung</b>                       | Bietet Einblicke, wie man Wert durch die Nutzung von I&T generieren kann und zeigt entsprechende Aufgaben der Geschäftsleitung auf.                                                                                                                       |
| <b>Oberste Führungskräfte</b>                 | Bietet Anleitungen zur Organisation und Überwachung der Leistung von I&T im gesamten Unternehmen.                                                                                                                                                         |
| <b>Business Manager</b>                       | Bietet Informationen, wie man die I&T-Lösungen umsetzt, die Unternehmen benötigen und wie neue Technologien am besten zur Schaffung neuer strategischer Möglichkeiten genutzt werden können.                                                              |
| <b>IT-Manager</b>                             | Bietet Anleitungen, wie man die IT-Abteilung optimal aufbaut und strukturiert, die Leistung der IT managt, einen effizienten und effektiven IT-Betrieb gewährleistet, die IT-Kosten steuert, die IT-Strategie an den Geschäftsprioritäten ausrichtet usw. |
| <b>Externe Prüfer</b>                         | Hilft, die Abhängigkeit von externen Dienstleistungsanbietern zu managen, Sicherheit über die IT zu erhalten und ein effektives und effizientes internes Kontrollsystem zu gewährleisten.                                                                 |
| <b>Risikomanagement</b>                       | Unterstützt dabei, alle IT-bezogenen Risiken zu identifizieren und zu managen.                                                                                                                                                                            |
| <b>Externe Anspruchsgruppen</b>               |                                                                                                                                                                                                                                                           |
| <b>Regulierungsbehörden</b>                   | Hilft sicherzustellen, dass das Unternehmen die relevanten Regeln und Bestimmungen befolgt und über das passende Governance-System verfügt, um Compliance-Anforderungen zu managen und zu erfüllen.                                                       |
| <b>Geschäftspartner</b>                       | Hilft sicherzustellen, dass der Geschäftsbetrieb eines Geschäftspartners sicher und zuverlässig ist und die anwendbaren Regeln und Bestimmungen erfüllt.                                                                                                  |
| <b>IT-Lieferanten</b>                         | Hilft sicherzustellen, dass der Geschäftsbetrieb eines IT-Lieferanten sicher und zuverlässig ist und die anwendbaren Regeln und Bestimmungen erfüllt.                                                                                                     |

Um vom COBIT-Rahmenwerk profitieren zu können sind ein gewisses Maß an Erfahrung und ein tiefgehendes Verständnis des Unternehmens erforderlich. Diese Voraussetzungen ermöglichen es den Anwendern, die zentralen COBIT-Anleitungen, die eher genereller Natur sind, zu einer zugeschnittenen und zielgerichteten Anleitung für das Unternehmen zu machen und dabei die besondere Ausgangssituation des Unternehmens zu berücksichtigen.

Die Zielgruppe umfasst dabei die Verantwortlichen während des gesamten Lebenszyklus der Governance-Lösung, von der Konzeption über die Ausführung bis hin zur Assurance. Prüfer können die in dieser Publikation entwickelte Logik und den Arbeitsablauf anwenden, um ein fundiertes Assurance-Programm für das Unternehmen zu erstellen.

Diese Seite wurde absichtlich freigelassen.



## Kapitel 3

### COBIT-Prinzipien

#### 3.1 Einleitung

COBIT® 2019 wurde auf der Grundlage zweier Arten von Prinzipien entwickelt:

- Prinzipien, die die wesentlichen Anforderungen an ein **Governance-System** für unternehmensweite Informationen und Technologie beschreiben.
- Prinzipien für ein **Governance-Rahmenwerk**, das zum Aufbau eines Governance-Systems für das Unternehmen dienen kann.

#### 3.2 Sechs Prinzipien für ein Governance-System

Die sechs Prinzipien für ein Governance-System sind (**Abbildung 3.1**):

1. Jedes Unternehmen benötigt ein Governance-System, um die Bedürfnisse der Anspruchsgruppen zu befriedigen und um durch den Einsatz von I&T Wert zu generieren. Der Wert spiegelt ein Gleichgewicht zwischen Nutzen, Risiko und Ressourcen wider, und Unternehmen benötigen eine umsetzbare Strategie und ein Governance-System, um diesen Wert zu realisieren.
2. Ein Governance-System für unternehmensweite Informationen und Technologie besteht aus einer Reihe von Komponenten, die unterschiedlicher Art sein können und ganzheitlich zusammenwirken.
3. Ein Governance-System sollte dynamisch sein. Das bedeutet, dass bei jeder Änderung eines oder mehrerer Designfaktoren (z. B. bei einer Änderung der Strategie oder Technologie), die Auswirkungen dieser Änderungen auf das EGIT-System berücksichtigt werden müssen. Eine dynamische Betrachtungsweise bezüglich EGIT wird zu einem praktikablen und zukunftssicheren EGIT-System führen.
4. Ein Governance-System sollte klar zwischen Governance- und Managementaktivitäten und -strukturen unterscheiden.



5. Ein Governance-System sollte auf die Erfordernisse des Unternehmens zugeschnitten sein und eine Reihe von Designfaktoren als Parameter zur Anpassung und Priorisierung der Komponenten des Governance-Systems verwenden.
6. Ein Governance-System sollte das Unternehmen ganzheitlich abdecken und sich nicht nur auf die IT-Funktionen, sondern auf die gesamte Technologie und Informationsverarbeitung konzentrieren, die das Unternehmen zur Erreichung seiner Ziele einsetzt, unabhängig davon, an welcher Stelle im Unternehmen die Verarbeitung stattfindet.<sup>6</sup>

## 3.3 Drei Prinzipien für ein Governance-Rahmenwerk

Die drei Prinzipien für ein Governance-Rahmenwerk sind (**Abbildung 3.2**):

1. Ein Governance-Rahmenwerk sollte auf einem konzeptionellen Modell basieren, das die wichtigsten Komponenten und Beziehungen zwischen den Komponenten identifiziert, um maximal konsistent zu sein und eine Automatisierung zu ermöglichen.
2. Ein Governance-Rahmenwerk sollte offen und flexibel sein. Sie sollte das Hinzufügen neuer Inhalte erlauben und die Möglichkeit bieten, neue Fragestellungen flexibel anzugehen, während Integrität und Konsistenz gewahrt bleiben.
3. Ein Governance-Rahmenwerk sollte sich an die einschlägigen wichtigen relevanten Standards, Rahmenwerke und Bestimmungen anpassen.

**Abbildung 3.2 – Prinzipien eines Governance-Rahmenwerks**



<sup>6</sup> Huygh, T.; De Haes, S.; „Using the Viable System Model to Study IT Governance Dynamics: Evidence from a Single Case Study“, Tagungsband der 51. Hawaii International Conference on System Sciences, 2018, <https://scholarspace.manoa.hawaii.edu/bitstream/10125/50501/1/paper0614.pdf>

### 3.4 COBIT® 2019

COBIT® 2019 enthält gegenüber früheren Versionen Verbesserungen in den folgenden Bereichen:

- **Flexibilität und Offenheit** – Definition und Verwendung von Designfaktoren ermöglichen es, COBIT besser an den spezifischen Kontext eines Anwenders anzupassen. Die offene Architektur von COBIT ermöglicht es, neue Schwerpunktbereiche hinzuzufügen (siehe Abschnitt 4.4) oder bestehende zu modifizieren, ohne dass dies direkte Auswirkungen auf die Struktur und den Inhalt des COBIT-Kernmodells hat.
- **Aktualität und Relevanz** – Das COBIT-Modell unterstützt die Referenzierung von und Anpassung an Konzepte, die aus anderen Quellen stammen (z. B. die neuesten IT-Standards und Compliance-Vorschriften).
- **Präskriptiver Charakter** – Modelle wie COBIT können entweder deskriptiv oder präskriptiv sein. Das konzeptionelle Modell hinter COBIT ist so aufgebaut und dargestellt, dass seine Implementierung (d. h. die Anwendung zugeschnittener COBIT-Governance-Komponenten) als verbindliche Vorgabe für ein zugeschnittenes IT-Governance-System wahrgenommen wird.
- **IT-Leistungssteuerung** – Die Struktur des COBIT-Leistungssteuerungsmodells ist in das konzeptionelle Modell integriert. Zum Zweck der besseren Anpassung an CMMI wurden Konzepte zu Reifegrad und Fähigkeitsstufen eingeführt.

In den COBIT-Anleitungen werden die Begriffe „Governance der unternehmensweiten Informationen und Technologie“, „Governance der IT“ und „IT-Governance“ synonym verwendet.

**Diese Seite wurde absichtlich freigelassen.**

### Kapitel 4

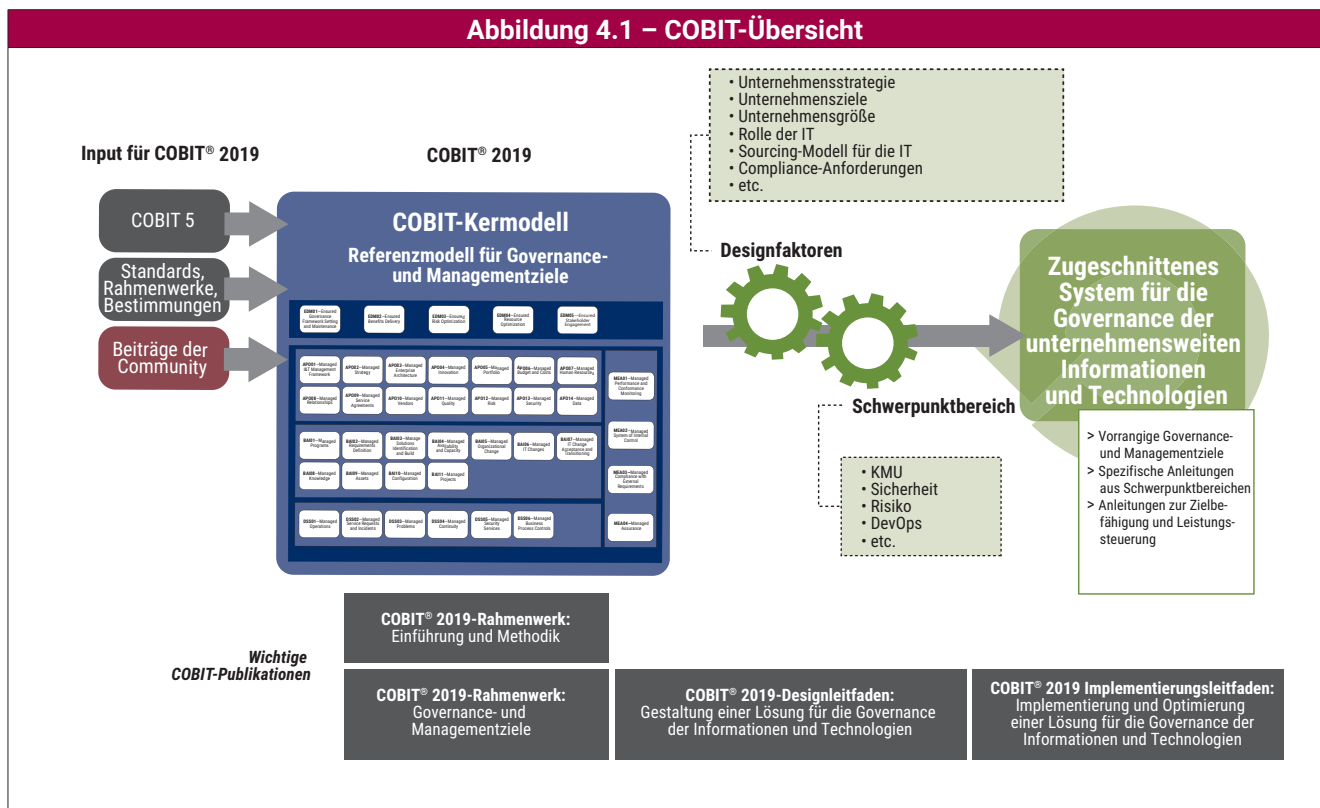
## Grundlegende Konzepte: Governance-System und -Komponenten

### 4.1 COBIT-Übersicht

Die COBIT® 2019-Reihe ist so ausgelegt, dass sie jederzeit erweitert und angepasst werden kann. Die folgenden Publikationen sind derzeit verfügbar:<sup>7</sup>

- **COBIT® 2019-Rahmenwerk: Einführung und Methodik** stellt die wesentlichen Konzepte von COBIT® 2019 vor.
- **COBIT® 2019-Rahmenwerk: Governance- und Managementziele** beschreibt umfassend die 40 wesentlichen Governance und Managementziele, die entsprechenden Prozesse und andere verwandte Komponenten. In dieser Publikation wird auch auf andere Standards und Rahmenwerke Bezug genommen.
- **COBIT® 2019-Designleitfaden: Gestaltung einer Lösung für die Governance der Informationen und Technologie** beschäftigt sich mit Designfaktoren, die die Governance beeinflussen können, und stellt einen Arbeitsablauf zur Planung eines zugeschnittenen Governance-Systems für das Unternehmen vor.
- **COBIT® 2019-Implementierungsleitfaden: Implementierung und Optimierung einer Lösung für die Governance der Informationen und Technologie** ist eine Weiterentwicklung des **COBIT® 5-Implementierungsleitfadens** und enthält eine Roadmap für die kontinuierliche Verbesserung der Governance. Die Publikation kann in Verbindung mit dem **COBIT® 2019-Designleitfaden** verwendet werden.

Abbildung 4.1 zeigt einen Überblick über COBIT® 2019 und veranschaulicht, welche Aspekte die verschiedenen Publikationen der Reihe abdecken.



<sup>7</sup> Zum Zeitpunkt der Veröffentlichung von COBIT® 2019-Rahmenwerk: Einführung und Methodik, sind weitere Titel der COBIT® 2019-Reihe bereits in Planung, aber noch nicht veröffentlicht.

Die in **Abbildung 4.1** als Schwerpunktbereiche ausgewiesenen Inhalte enthalten vertiefende Informationen zu einzelnen Themen.<sup>8</sup>

COBIT® 2019 basiert auf COBIT® 5 und weiteren wichtigen Quellen. COBIT ist an einer Reihe von verwandten Standards und Rahmenwerken ausgerichtet. Eine Auflistung dieser Standards ist in Kapitel 10 enthalten. Die Analyse verwandter Standards und die Ausrichtung von COBIT an diesen Standards untermauern die bewährte Position von COBIT als übergreifendes Rahmenwerk für die I&T-Governance.

Zukünftig wird COBIT seinen Anwendern anbieten, inhaltliche Aktualisierungen vorzuschlagen, die nach einer Prüfung kontinuierlich eingebunden werden sollen, um COBIT auf dem neuesten Stand der Erkenntnisse und Entwicklung zu halten.

Die folgenden Abschnitte erklären die COBIT® 2019 zugrundeliegenden wesentlichen Konzepte und Begriffe.

## 4.2 Governance- und Managementziele

Damit I&T zur Erreichung der Unternehmensziele beitragen können, müssen eine Reihe von Governance- und Managementzielen erreicht werden. Grundlegende Prinzipien in Bezug auf Governance- und Managementziele sind:

- Ein Governance- oder Managementziel bezieht sich immer auf einen Prozess (mit identischem oder ähnlichem Namen) und eine Reihe von Komponenten anderer Art, die zur Erreichung des Ziels beitragen.
- Ein Governance-Ziel bezieht sich auf einen Governance-Prozess (in **Abbildung 4.2** mit dunkelblauem Hintergrund dargestellt), während sich ein Managementziel auf einen Managementprozess bezieht (in **Abbildung 4.2** mit hellblauem Hintergrund dargestellt). Geschäftsleitung und oberste Führungskräfte sind in der Regel für Governance-Prozesse verantwortlich, während Managementprozesse in den Verantwortungsbereich des oberen und mittleren Managements fallen.

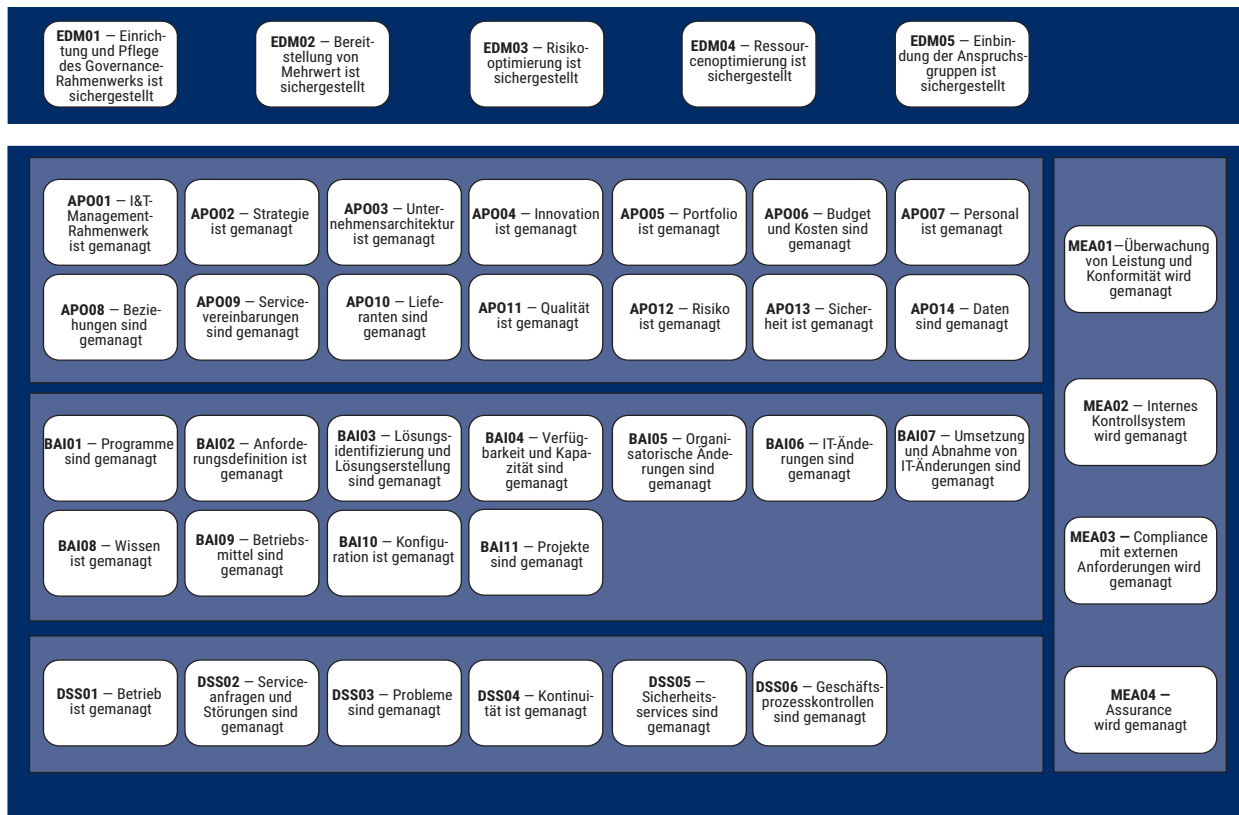
Innerhalb von COBIT sind die Governance- und Managementziele in fünf Domänen gruppiert. Die Domänen sind mit Verben bezeichnet, die den Hauptzweck und die Aktivitätsbereiche des Ziels ausdrücken:

- Governance-Ziele werden in die Domäne **Evaluieren, Vorgeben und Überwachen** eingeordnet. In dieser Domäne evaluiert das verantwortliche Governance-Organ strategische Optionen, steuert das obere Management hinsichtlich der gewählten strategischen Optionen und überwacht die Umsetzung der Strategie.
- Die Managementziele sind in vier Domänen zusammengefasst:
  - **Anpassen, Planen und Organisieren** befasst sich mit der Organisation im Ganzen, der Strategie und den unterstützenden Aktivitäten für I&T.
  - **Aufbauen, Beschaffen und Implementieren** befasst sich mit der Definition, dem Erwerb und der Implementierung von I&T-Lösungen und deren Integration in Geschäftsprozesse.
  - **Bereitstellen, Betreiben und Unterstützen** befasst sich mit der operativen Bereitstellung und Unterstützung von I&T-Dienstleistungen, einschließlich Sicherheit.
  - **Überwachen, Evaluieren und Beurteilen** befasst sich mit der Leistungsüberwachung und der Erfüllung interner Leistungsziele, interner Kontrollziele und externer Anforderungen durch I&T.

---

<sup>8</sup> Weitere dieser Publikationen zu Schwerpunktbereichen sind bereits in Vorbereitung, weitere in Planung. Die Reihe der Publikationen zu den Schwerpunktbereichen wird zunehmend erweitert. Informationen über aktuell verfügbare und geplante Publikationen sowie weitere Inhalte finden Sie unter [www.isaca.org/cobit](http://www.isaca.org/cobit).

**Abbildung 4.2 – COBIT-Kernmodell**



### 4.3 Komponenten des Governance-Systems

Um Governance- und Managementziele zu erreichen, muss jedes Unternehmen ein aus einer Reihe verschiedener Komponenten aufgebautes Governance-System einrichten, anpassen und aufrechterhalten.

- Komponenten sind Faktoren, die einzeln oder in ihrer Gesamtheit zum reibungslosen Funktionieren des Governance-Systems des Unternehmens im Bereich I&T beitragen.
- Die Komponenten interagieren miteinander, was zu einem ganzheitlichen I&T-Governance-System führt.
- Komponenten können unterschiedlicher Art sein. Am gängigsten sind dabei die Prozesse. Zu den Komponenten eines Governance-Systems gehören jedoch auch Organisationsstrukturen, Richtlinien und Verfahren, Informationen, Kultur und Verhalten, Fähigkeiten und Kompetenzen sowie Dienstleistungen, Infrastruktur und Anwendungen (**Abbildung 4.3**).
  - **Prozesse** beschreiben eine strukturierte Abfolge von Verfahren und Aktivitäten zur Erreichung bestimmter Ziele und erzeugen eine Reihe von Ergebnissen, die das Erreichen der übergeordneten IT-bezogenen Ziele unterstützen.
  - **Organisationsstrukturen** sind die wichtigsten entscheidungsrelevanten Einheiten in einem Unternehmen.
  - **Prinzipien, Richtlinien und Rahmenwerke** setzen gewünschtes Verhalten in konkrete Anleitungen für den unternehmerischen Alltag um.
  - **Informationen** sind in jeder Organisation allgegenwärtig und umfassen alle vom Unternehmen produzierten und genutzten Informationen. COBIT konzentriert sich auf Informationen, die für eine effektive Arbeitsweise des Governance-Systems des Unternehmens erforderlich sind.

- **Kultur, Ethik und Verhalten** des Einzelnen und des Unternehmens werden als Faktoren für den Erfolg von Governance- und Managementaktivitäten oft unterschätzt.
- **Mitarbeiter, Fähigkeiten und Kompetenzen** sind für eine gute Entscheidungsfindung, die Durchführung von korrektiven Maßnahmen und den erfolgreichen Abschluss aller Aktivitäten erforderlich.
- **Services, Infrastruktur und Anwendungen** umfassen die Infrastruktur, Technologie und Anwendungen, die dem Unternehmen das Governance-System zur Anwendung bereitstellen.

Abbildung 4.3 – COBIT-Komponenten eines Governance-Systems



Die verschiedenen Komponenten können generisch oder Varianten von generischen Komponenten sein:

- **Generische** Komponenten werden im COBIT-Kernmodell (siehe **Abbildung 4.2**) beschrieben und gelten im Prinzip in jeder Situation. Sie sind jedoch generischer Natur und müssen in der Regel angepasst werden, bevor sie praktisch umgesetzt werden können.
- **Varianten** basieren auf generischen Komponenten, sind aber auf einen bestimmten Zweck oder Kontext innerhalb eines Schwerpunktbereichs zugeschnitten (z. B. Informationssicherheit, DevOps, eine bestimmte Vorschrift).

## 4.4 Schwerpunktbereiche

Ein **Schwerpunktbereich** beschreibt einen bestimmten Sachverhalt, eine Domäne oder eine Fragestellung im Rahmen der Governance, die bzw. der durch eine Reihe von Governance- und Managementzielen und deren Komponenten adressiert werden kann. Beispiele für Schwerpunktbereiche sind: kleine und mittlere Unternehmen (KMU), Cybersicherheit, digitale Transformation, Cloud Computing, Datenschutz und DevOps.<sup>9</sup> Schwerpunktbereiche können eine Kombination aus generischen Komponenten und Varianten enthalten.

<sup>9</sup> Der DevOps-Ansatz repräsentiert sowohl eine Komponentenvariante als auch einen Schwerpunktbereich. Warum? DevOps ist ein aktuelles und relevantes Thema und bedarf zwingend einer spezifischen Anleitung, was es zu einem Schwerpunktbereich macht. DevOps umfasst eine Reihe von allgemeinen Governance- und Managementzielen des COBIT-Kernmodells sowie eine Reihe von Varianten von entwicklungs-, betriebs- und überwachungsbezogenen Prozessen und Organisationsstrukturen.



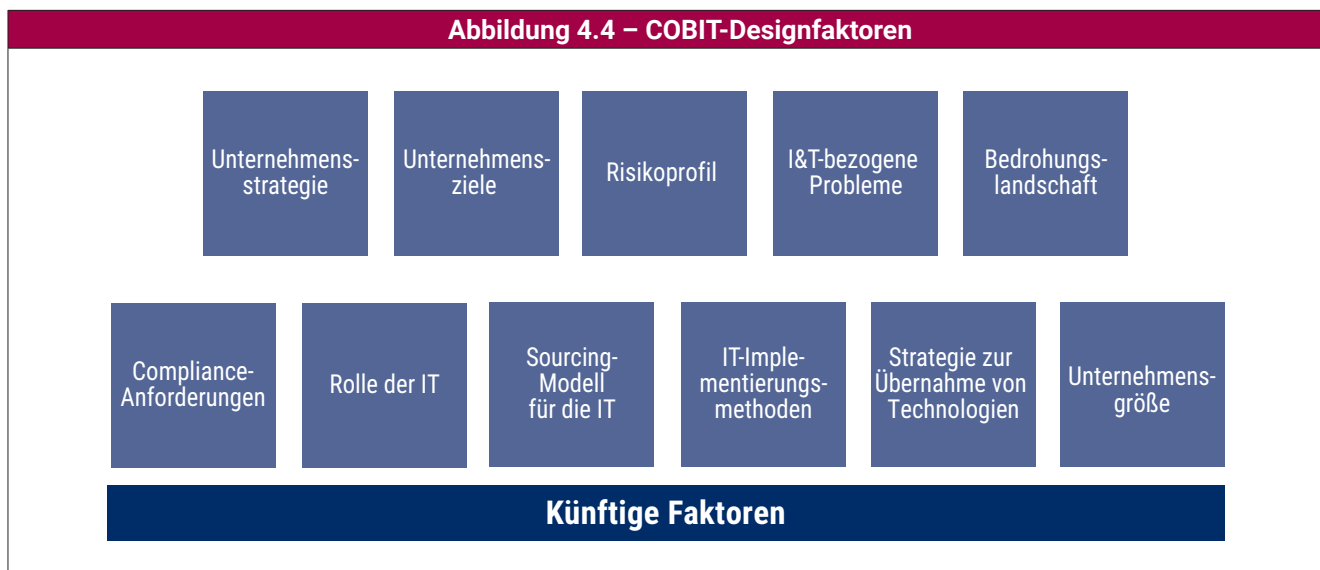
Die Anzahl der Schwerpunktbereiche ist praktisch unbegrenzt. Diese Eigenschaft macht COBIT erweiterbar. Neue Schwerpunktbereiche können entweder bei Bedarf hinzugefügt werden oder wenn Fachexperten und Anwender Beiträge zu COBIT liefern.

### 4.5 Designfaktoren

**Designfaktoren** sind Faktoren, die die Ausgestaltung des Governance-Systems eines Unternehmens beeinflussen und für den erfolgreichen Einsatz von I&T verantwortlich sein können.

Die möglichen Auswirkungen, die Designfaktoren auf das Governance-System haben können, sind in Abschnitt 7.1 dargestellt. Weitere Informationen und detaillierte Hinweise zur Verwendung der Designfaktoren zur Konzipierung eines Governance-Systems finden Sie im COBIT® 2019-Designleitfaden.

Designfaktoren umfassen alle Kombinationen der folgenden einzelnen Elemente (**Abbildung 4.4**):



**1. Unternehmensstrategie** – Unternehmen können verschiedene Strategien einsetzen, die sich in Form einer oder mehrerer der in **Abbildung 4.5** dargestellten Grundstrategien beschreiben lassen. Organisationen verfügen in der Regel über eine Primärstrategie und höchstens eine Sekundärstrategie.

| Abbildung 4.5 – Designfaktor Unternehmensstrategie |                                                                                                                                                  |
|----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Grundstrategie                                     | Erläuterung                                                                                                                                      |
| <b>Wachstum/Akquisition</b>                        | Das Unternehmen ist auf Wachstum (Umsatz) ausgerichtet. <sup>10</sup>                                                                            |
| <b>Innovation/Differenzierung</b>                  | Das Unternehmen konzentriert sich darauf, seinen Kunden andersartige und/oder innovative Produkte und Dienstleistungen anzubieten. <sup>11</sup> |
| <b>Kostenführerschaft</b>                          | Das Unternehmen ist auf kurzfristige Kostenminimierung ausgerichtet. <sup>12</sup>                                                               |
| <b>Kundenservice/Stabilität</b>                    | Das Unternehmen ist auf die Bereitstellung dauerhafter und kundenorientierter Dienstleistungen ausgerichtet. <sup>13</sup>                       |

<sup>10</sup> Entspricht dem Sucher (Prospector) in der Miles-Snow-Typologie. Siehe: Miles and Snow's Typology of Defender, Prospector, Analyzer, and Reactor, Elibrary, [https://ebrary.net/3737/management/miles\\_snows\\_typology\\_defender\\_prospector\\_analyzer\\_reactor](https://ebrary.net/3737/management/miles_snows_typology_defender_prospector_analyzer_reactor).

<sup>11</sup> Siehe: Reeves, M.; Love, C; Tillmanns, P.; Your Strategy Needs a Strategy; Harvard Business Review, September 2012, <https://hbr.org/2012/09/your-strategy-needs-a-strategy>, besonders im Hinblick auf Visionäres und Gestaltung.

<sup>12</sup> Entspricht der Kostenführerschaft. Siehe: University of Cambridge; Porter's Generic Competitive Strategies (ways of competitive); Institute for Manufacturing (IfM) Management Technology Policy, <https://www.ifm.eng.cam.ac.uk/research/dstools/porters-generic-competitive-strategies/>.

Entspricht ebenfalls der operativen Exzellenz. Siehe: Treacy, M.; Wiersema, F.; Customer Intimacy and Other Value Disciplines; Harvard Business Review, Januar/Februar 1993, <https://hbr.org/1993/01/customer-intimacy-and-other-value-disciplines>

<sup>13</sup> Entspricht dem Verteidiger (Defender) in der Miles-Snow-Typologie. Siehe: Miles and Snow's Typology of Defender, Prospector, Analyzer, and Reactor, a. a. O.

**2. Unternehmensziele**, die die Unternehmensstrategie unterstützen – Die Unternehmensstrategie wird durch das Erreichen von (einer Reihe von) Unternehmenszielen umgesetzt. Diese Ziele werden im COBIT-Rahmenwerk definiert, anhand der Dimensionen in einer Balanced Scorecard (BSC) strukturiert und umfassen die in **Abbildung 4.6** dargestellten Elemente.

| Abbildung 4.6 – Designfaktor Unternehmensziele |                                        |                                                            |
|------------------------------------------------|----------------------------------------|------------------------------------------------------------|
| Referenz                                       | Dimension der Balanced Scorecard (BSC) | Unternehmensziel                                           |
| EG01                                           | Finanzen                               | Portfolio wettbewerbsfähiger Produkte und Dienstleistungen |
| EG02                                           | Finanzen                               | Gesteuertes Geschäftsrisiko                                |
| EG03                                           | Finanzen                               | Compliance mit externen Gesetzen und Bestimmungen          |
| EG04                                           | Finanzen                               | Qualität von Finanzinformationen                           |
| EG05                                           | Kunde                                  | Kundenorientierte Servicekultur                            |
| EG06                                           | Kunde                                  | Kontinuität und Verfügbarkeit der geschäftlichen Services  |
| EG07                                           | Kunde                                  | Qualität der Managementinformationen                       |
| EG08                                           | Intern                                 | Optimierung der internen Geschäftsprozessfunktionalität    |
| EG09                                           | Intern                                 | Optimierung der Geschäftsprozesskosten                     |
| EG10                                           | Intern                                 | Fähigkeiten, Motivation und Produktivität des Personals    |
| EG11                                           | Intern                                 | Compliance mit internen Richtlinien                        |
| EG12                                           | Wachstum                               | Gesteuerte Programme zur digitalen Transformation          |
| EG13                                           | Wachstum                               | Produkt- und Geschäftsinnovation                           |

Abschnitt 4.6 enthält weitere Informationen zur COBIT-Zielkaskade, die eine detailliertere Ausarbeitung dieses Designfaktors repräsentiert.

**3. Risikoprofil** des Unternehmens und aktuelle Fragestellungen in Bezug auf I&T – Das Risikoprofil identifiziert die Art von I&T-bezogenen Risiken, denen das Unternehmen derzeit ausgesetzt ist, und gibt an, in welchen Risikobereichen die Risikobereitschaft überschritten wird. Die in **Abbildung 4.7** aufgeführten Risikokategorien<sup>14</sup> verdienen in diesem Zusammenhang eine genauere Betrachtung.

| Abbildung 4.7 – Designfaktor Risikoprofil (IT-Risikokategorien) |                                                                             |
|-----------------------------------------------------------------|-----------------------------------------------------------------------------|
| Referenz                                                        | Risikokategorie                                                             |
| 1                                                               | Entscheidungsfindung bei IT-Investitionen, Portfoliodefinition und -wartung |
| 2                                                               | Lebenszyklusmanagement von Programmen und Projekten                         |
| 3                                                               | IT-Kosten und Überwachung                                                   |
| 4                                                               | IT-Fachwissen, Fähigkeiten und Verhalten                                    |
| 5                                                               | Unternehmens-/IT-Architektur                                                |
| 6                                                               | Störungen der operativen IT-Infrastruktur                                   |
| 7                                                               | Unautorisierte Handlungen                                                   |
| 8                                                               | Probleme bei Softwareübernahme/-nutzung                                     |
| 9                                                               | Störungen der Hardware                                                      |
| 10                                                              | Softwarefehler                                                              |
| 11                                                              | Logische Angriffe (Hacking, Malware usw.)                                   |
| 12                                                              | Vorfälle seitens Dritter/Lieferanten                                        |
| 13                                                              | Nichteinhaltung von Regeln (Non-Compliance)                                 |
| 14                                                              | Geopolitische Problemstellungen                                             |
| 15                                                              | Arbeitskampf                                                                |
| 16                                                              | Höhere Gewalt                                                               |
| 17                                                              | Technologiebasierte Innovation                                              |
| 18                                                              | Umwelt                                                                      |
| 19                                                              | Daten- und Informationsmanagement                                           |

<sup>14</sup> Mit Änderungen übernommen aus: ISACA, The Risk IT Practitioner Guide, USA, 2009.

**4. I&T-bezogene Probleme** – Eine verwandte Methode zur I&T-Risikoeinschätzung für das Unternehmen besteht darin, zu betrachten, welchen I&T-bezogenen Problemen es sich derzeit gegenüberstellt, oder welches I&T-bezogene Risiko eingetreten ist. Die am häufigsten auftretenden Probleme<sup>15</sup> sind in **Abbildung 4.8** dargestellt.

| Abbildung 4.8 – Designfaktor I&T-bezogene Probleme |                                                                                                                                                                                                                      |
|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Referenz                                           | Beschreibung                                                                                                                                                                                                         |
| A                                                  | Frustration bei verschiedenen IT-Einheiten innerhalb der Organisation, da ihnen nur ein geringer Beitrag zum Geschäftswert zugestanden wird                                                                          |
| B                                                  | Frustration bei den Fachabteilungen (d. h. den Kunden der IT) und der IT-Abteilung aufgrund fehlgeschlagener Initiativen oder der Wahrnehmung eines geringen Beitrags zum Geschäftswert                              |
| C                                                  | Schwerwiegende IT-bezogene Vorfälle, wie Datenverlust, Sicherheitslücken, Scheitern von Projekten und Anwendungsfehler im Zusammenhang mit der IT                                                                    |
| D                                                  | Probleme bei der Erbringung von Dienstleistungen durch IT-Outsourcing-Dienstleister                                                                                                                                  |
| E                                                  | Versäumnisse bei der Erfüllung IT-bezogener gesetzlicher oder vertraglicher Anforderungen                                                                                                                            |
| F                                                  | Regelmäßige Prüfungsfeststellungen oder andere Bewertungsberichte über unzureichende IT-Leistung oder IT-Qualitäts- oder Serviceprobleme                                                                             |
| G                                                  | Erhebliche versteckte und übermäßige IT-Ausgaben, d. h. IT-Ausgaben durch die Abteilungen, die außerhalb der Kontrolle der üblichen Entscheidungsmechanismen für IT-Investitionen und der genehmigten Budgets liegen |
| H                                                  | Doppelarbeit oder Überschneidungen zwischen verschiedenen Initiativen oder andere Formen von Ressourcenverschwendung                                                                                                 |
| I                                                  | Unzureichende IT-Ressourcen, Personal mit unzureichenden Fähigkeiten oder Mitarbeiter-Burnout/Unzufriedenheit                                                                                                        |
| J                                                  | IT-gestützte Änderungen oder Projekte, die häufig die geschäftlichen Anforderungen nicht erfüllen, zu spät fertiggestellt werden oder über dem Budget liegen                                                         |
| K                                                  | Starke Zurückhaltung von Geschäftsleitungsmitgliedern, Führungskräften oder leitenden Angestellten, sich mit IT zu beschäftigen, oder ein Mangel an Unterstützung von IT-Themen                                      |
| L                                                  | Komplexes IT-Betriebsmodell und/oder unklare Entscheidungsmechanismen für IT-bezogene Entscheidungen                                                                                                                 |
| M                                                  | Übermäßig hohe IT-Kosten                                                                                                                                                                                             |
| N                                                  | Verhinderte oder gescheiterte Umsetzung von neuen Initiativen oder Innovationen, die durch die IT-Architektur und -Systeme verursacht wird                                                                           |
| O                                                  | Diskrepanz zwischen geschäftsbezogenem und technischem Wissen, die dazu führt, dass Fachbereichsmitarbeiter und Informations- und/oder Technologiespezialisten verschiedene Sprachen sprechen                        |
| P                                                  | Regelmäßig auftretende Probleme bezüglich der Datenqualität und Integration von Daten aus verschiedenen Quellen                                                                                                      |
| Q                                                  | Hoher Grad der Nutzung durch Endbenutzer, was (neben anderen Problemen) zu einem Mangel an Überwachung und Qualitätskontrolle der Anwendungen führt, die entwickelt und in Betrieb genommen werden                   |
| R                                                  | Abteilungen implementieren eigene Lösungen mit nur geringer oder keiner Einbindung der IT-Abteilung des Unternehmens <sup>16</sup>                                                                                   |
| S                                                  | Unkenntnis und/oder Nichteinhaltung von Datenschutzbestimmungen                                                                                                                                                      |
| T                                                  | Unfähigkeit, neue Technologien anzuwenden oder mit Hilfe von I&T Innovationen voranzutreiben                                                                                                                         |

**5. Bedrohungslandschaft** – Die Bedrohungslandschaft, in der das Unternehmen operiert, kann wie in **Abbildung 4.9** gezeigt genauer klassifiziert werden.

| Abbildung 4.9 – Designfaktor Bedrohungslandschaft |                                                                                                                                                                      |
|---------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bedrohungslandschaft                              | Erläuterung                                                                                                                                                          |
| Normal                                            | Das Unternehmen ist einem als normal geltenden Bedrohungsniveau ausgesetzt                                                                                           |
| Hoch                                              | Aufgrund der geopolitischen Lage, des Industriesektors oder eines besonderen Unternehmensprofils operiert das Unternehmen in einem Umfeld mit hohem Bedrohungsniveau |

<sup>15</sup> Siehe auch Abschnitt 3.3.1 Typical Pain Points, in ISACA, COBIT® 2019 Implementation Guide: Implementing and Optimizing an Information and Technology Governance Solution, USA, 2018.

<sup>16</sup> Dieses Problem steht im Zusammenhang mit der Nutzung durch den Endbenutzer und ist häufig auf Unzufriedenheit mit IT-Lösungen und -Services zurückzuführen.

**6. Compliance-Anforderungen** – Die Compliance-Anforderungen, denen das Unternehmen unterliegt, können nach den in **Abbildung 4.10** aufgeführten Kategorien klassifiziert werden.

| <b>Abbildung 4.10 – Designfaktor Compliance-Anforderungen</b> |                                                                                                                                                                   |
|---------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Regulatorisches Umfeld</b>                                 | <b>Erläuterung</b>                                                                                                                                                |
| <b>Niedrige Compliance-Anforderungen</b>                      | Das Unternehmen unterliegt wenigen normalen Compliance-Anforderungen, die unter dem Durchschnitt liegen.                                                          |
| <b>Normale Compliance-Anforderungen</b>                       | Das Unternehmen unterliegt einigen normalen Compliance-Anforderungen auf üblichem Niveau.                                                                         |
| <b>Hohe Compliance-Anforderungen</b>                          | Das Unternehmen unterliegt überdurchschnittlich hohen Compliance-Anforderungen, die meist mit dem Industriesektor oder geopolitischen Bedingungen zusammenhängen. |

**7. Rolle der IT** – Die Rolle der IT für das Unternehmen kann wie in **Abbildung 4.11** dargestellt klassifiziert werden.

| <b>Abbildung 4.11 – Designfaktor Rolle der IT</b> |                                                                                                                                                                                                                                                                                      |
|---------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Rolle der IT<sup>17</sup></b>                  | <b>Erläuterung</b>                                                                                                                                                                                                                                                                   |
| <b>Support</b>                                    | Die IT ist weder für den Ablauf und die Kontinuität der Geschäftsprozesse und Services, noch für deren innovative Weiterentwicklung entscheidend.                                                                                                                                    |
| <b>Fabrik</b>                                     | Wenn die IT ausfällt, hat dies unmittelbare Auswirkungen auf den Ablauf und die Kontinuität der Geschäftsprozesse und Services. Die IT wird jedoch nicht als treibende Kraft für die Innovation von Geschäftsprozessen und Services gesehen.                                         |
| <b>Trendwende</b>                                 | Die IT wird als treibende Kraft für die Innovation von Geschäftsprozessen und Services gesehen. Zum gegenwärtigen Zeitpunkt besteht jedoch keine kritische Abhängigkeit von der IT, um den laufenden Betrieb und die Kontinuität der Geschäftsprozesse und Services sicherzustellen. |
| <b>Strategisch</b>                                | Die IT ist sowohl für den Ablauf als auch für die innovative Weiterentwicklung der Geschäftsprozesse und Services der Organisation von entscheidender Bedeutung.                                                                                                                     |

**8. Sourcing-Modell für die IT** – Das vom Unternehmen eingesetzte Sourcing-Modell kann wie in **Abbildung 4.12** dargestellt klassifiziert werden.

| <b>Abbildung 4.12 – Designfaktor Sourcing-Modell für die IT</b> |                                                                                                              |
|-----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| <b>Sourcing-Modell</b>                                          | <b>Erläuterung</b>                                                                                           |
| <b>Outsourcing</b>                                              | Zur Erbringung von IT-Dienstleistungen nimmt das Unternehmen die Leistungen Dritter in Anspruch.             |
| <b>Cloud</b>                                                    | Das Unternehmen maximiert die Nutzung der Cloud zur Bereitstellung von IT-Services für seine Benutzer.       |
| <b>Insourced</b>                                                | Das Unternehmen nutzt eigenes IT-Personal und stellt eigene IT-Services bereit.                              |
| <b>Hybrid</b>                                                   | Es wird ein gemischtes Modell angewendet, das die übrigen drei Modelle in unterschiedlichem Maße kombiniert. |

<sup>17</sup> Die in dieser Tabelle enthaltenen Rollen stammen aus McFarlan, F. Warren, James L. McKenney, Philip Pyburn: "The Information Archipelago – Plotting a Course", Harvard Business Review, Januar 1993, <https://hbr.org/1983/01/the-information-archipelago-plotting-a-course>.

**9. IT-Implementierungsmethoden** – Die Methoden, die das Unternehmen anwendet, können wie in **Abbildung 4.13** dargestellt klassifiziert werden.

| Abbildung 4.13 – Designfaktor IT-Implementierungsmethoden |                                                                                                                                          |
|-----------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| IT-Implementierungsmethode                                | Erläuterung                                                                                                                              |
| Agil                                                      | Das Unternehmen setzt agile Softwareentwicklung ein.                                                                                     |
| DevOps                                                    | Das Unternehmen nutzt den DevOps-Ansatz für die Entwicklung, den Einsatz und den Betrieb von Software.                                   |
| Traditionell                                              | Das Unternehmen nutzt einen eher klassischen Ansatz zur Softwareentwicklung (Wasserfall) und trennt die Softwareentwicklung vom Betrieb. |
| Hybrid                                                    | Das Unternehmen nutzt eine Mischung aus traditioneller und moderner IT-Implementierung, oft als „bimodale IT“ bezeichnet                 |

**10. Strategie zur Übernahme von Technologien** – Die Strategie zur Übernahme von Technologien kann wie in **Abbildung 4.14** aufgeführt klassifiziert werden.

| Abbildung 4.14 – Designfaktor Strategie zur Übernahme von Technologien |                                                                                                                                             |
|------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| Strategie zur Übernahme von Technologien                               | Erläuterung                                                                                                                                 |
| Vorreiter                                                              | Das Unternehmen setzt neue Technologien in der Regel so früh wie möglich ein und versucht, sich einen Vorteil als Vorreiter zu verschaffen. |
| Nachahmer                                                              | Das Unternehmen wartet in der Regel, bis sich neue Technologien durchsetzen und bewähren, bevor es sie einsetzt.                            |
| Nachzügler                                                             | Das Unternehmen führt neue Technologien erst sehr spät ein.                                                                                 |

**11. Unternehmensgröße** – Hinsichtlich der Gestaltung des Governance-Systems eines Unternehmens können zwei Kategorien, wie in **Abbildung 4.15** dargestellt, unterschieden werden.<sup>18</sup>

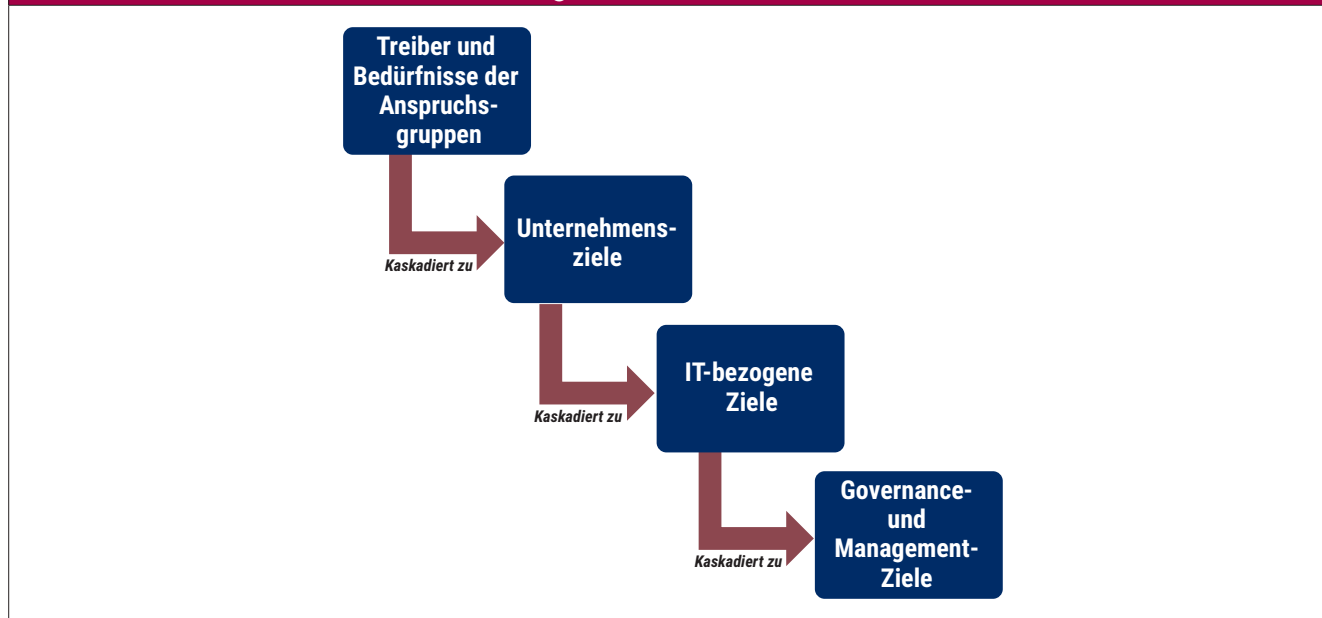
| Abbildung 4.15 – Designfaktor Unternehmensgröße |                                                    |
|-------------------------------------------------|----------------------------------------------------|
| Unternehmensgröße                               | Erläuterung                                        |
| Großes Unternehmen (Standard)                   | Unternehmen mit mehr als 250 Vollzeitbeschäftigten |
| Kleine und mittlere Unternehmen (KMU)           | Unternehmen mit 50 bis 250 Vollzeitbeschäftigten   |

<sup>18</sup> Kleinunternehmen, d. h. Unternehmen mit weniger als 50 Mitarbeitern, werden in dieser Publikation nicht berücksichtigt.

## 4.6 Zielkaskade

Die Bedürfnisse der Anspruchsgruppen müssen in eine praktikable Unternehmensstrategie umgesetzt werden. Die Zielkaskade (**Abbildung 4.16**) unterstützt Unternehmensziele, die einen der wichtigsten Designfaktoren eines Governance-Systems darstellen. Sie erlaubt die Priorisierung von Managementzielen auf der Grundlage der Priorisierung von Unternehmenszielen.

Abbildung 4.16 – COBIT-Zielkaskade



Die Zielkaskade unterstützt weiterhin die Umsetzung von Unternehmenszielen in Prioritäten für IT-bezogene Ziele. Die Zielkaskade wurde in COBIT® 2019 umfassend aktualisiert:

- Die Unternehmensziele wurden konsolidiert, reduziert, aktualisiert und präzisiert.
- IT-bezogene Ziele (im Original: Alignment Goals) stellen die Ausrichtung aller IT-Bemühungen auf die Geschäftsziele in den Vordergrund. Mit diesem aktualisierten Begriff soll auch das häufige Missverständnis vermieden werden, dass diese Ziele rein interne Ziele der IT-Abteilung eines Unternehmens darstellen. Wie die Unternehmensziele wurden auch die IT-bezogenen Ziele konsolidiert, reduziert, aktualisiert und, wo erforderlich, präzisiert.

### 4.6.1 Unternehmensziele

Die Bedürfnisse der Anspruchsgruppen kaskadieren zu Unternehmenszielen (im Original: Enterprise Goals).

Abbildung 4.17 zeigt die 13 Unternehmensziele zusammen mit einer Reihe von zugehörigen Beispielmetriken.

| Abbildung 4.17 – Zielkaskade: Unternehmensziele und Metriken |               |                                                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------------------------------------|---------------|------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Referenz                                                     | BSC-Dimension | Unternehmensziel                                           | Beispielmetrik                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| EG01                                                         | Finanzen      | Portfolio wettbewerbsfähiger Produkte und Dienstleistungen | <ul style="list-style-type: none"> <li>• Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben</li> <li>• Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben</li> <li>• Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten</li> <li>• Markteinführungszeit für neue Produkte und Dienstleistungen</li> </ul>                                                                              |
| EG02                                                         | Finanzen      | Gesteuertes Geschäftsrisiko                                | <ul style="list-style-type: none"> <li>• Anteil der kritischen Geschäftsziele und Dienstleistungen, die von der Risikobewertung abgedeckt werden</li> <li>• Anzahl der gravierenden Störungen, die in den Risikobewertungen nicht identifiziert wurden, gegenüber den gesamten Störungen</li> <li>• Häufigkeit der Aktualisierung des Risikoprofils</li> </ul>                                                                                                                                                                                   |
| EG03                                                         | Finanzen      | Compliance mit externen Gesetzen und Bestimmungen          | <ul style="list-style-type: none"> <li>• Kosten der Nichteinhaltung von Vorschriften, einschließlich Vergleichen und Bußgeldern</li> <li>• Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von Vorschriften, die öffentliche Kommentare oder negative Publicity verursacht haben</li> <li>• Anzahl der von den Aufsichtsbehörden festgestellten Fälle von Nichteinhaltung der Vorschriften</li> <li>• Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit Geschäftspartnern</li> </ul> |
| EG04                                                         | Finanzen      | Qualität von Finanzinformationen                           | <ul style="list-style-type: none"> <li>• Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, des Verständnisses und der Genauigkeit der Finanzinformationen des Unternehmens</li> <li>• Kosten der Nichteinhaltung finanzbezogener Vorschriften</li> </ul>                                                                                                                                                                                                                                                 |
| EG05                                                         | Kunde         | Kundenorientierte Servicekultur                            | <ul style="list-style-type: none"> <li>• Anzahl der Unterbrechungen bei Kundenservices</li> <li>• Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die Kundenservices den vereinbarten Standards entsprechen</li> <li>• Anzahl von Kundenbeschwerden</li> <li>• Trend der Umfrageergebnisse zur Kundenzufriedenheit</li> </ul>                                                                                                                                                                                         |
| EG06                                                         | Kunde         | Kontinuität und Verfügbarkeit der geschäftlichen Services  | <ul style="list-style-type: none"> <li>• Anzahl von Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursachen</li> <li>• Kosten von aufgetretenen Störungen</li> <li>• Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit</li> <li>• Anteil der Beschwerden in Abhängigkeit von den festgelegten Zielen zur Verfügbarkeit der Services</li> </ul>                                                                                                    |
| EG07                                                         | Kunde         | Qualität der Managementinformationen                       | <ul style="list-style-type: none"> <li>• Grad der Zufriedenheit der obersten Führungskräfte mit den Informationen zur Entscheidungsfindung</li> <li>• Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden</li> <li>• Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen</li> <li>• Aktualität der Managementinformationen</li> </ul>                                                                                |



**Abbildung 4.17 – Zielkaskade: Unternehmensziele und Metriken**

| Referenz | BSC-Dimension | Unternehmensziel                                         | Beispielmetrik                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------|---------------|----------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EG08     | Intern        | Optimierung der internen Geschäftsprozess-funktionalität | <ul style="list-style-type: none"> <li>• Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten</li> <li>• Zufriedenheitsgrad der Kunden mit der Servicebereitstellung</li> <li>• Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette</li> </ul>                                                                                         |
| EG09     | Intern        | Optimierung der Geschäftsprozesskosten                   | <ul style="list-style-type: none"> <li>• Verhältnis von Kosten zu erreichten Service Levels</li> <li>• Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Kosten der Geschäftstätigkeit</li> </ul>                                                                                                                                                                                         |
| EG10     | Intern        | Fähigkeiten, Motivation und Produktivität des Personals  | <ul style="list-style-type: none"> <li>• Mitarbeiterproduktivität im Vergleich zu Benchmarks</li> <li>• Grad der Zufriedenheit der Anspruchsgruppen mit den Fachkenntnissen und den Fähigkeiten der Mitarbeiter</li> <li>• Anteil der Mitarbeiter, deren Fähigkeiten nicht ausreichen, um die zugewiesene Rolle kompetent wahrzunehmen</li> <li>• Anteil zufriedener Mitarbeiter</li> </ul>                         |
| EG11     | Intern        | Compliance mit internen Richtlinien                      | <ul style="list-style-type: none"> <li>• Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von Richtlinien</li> <li>• Anteil der Anspruchsgruppen, die die Richtlinien verstehen</li> <li>• Anteil der Richtlinien, die durch effektive Standards und Arbeitspraktiken unterstützt werden</li> </ul>                                                                                                     |
| EG12     | Wachstum      | Gesteuerte Programme zur digitalen Transformation        | <ul style="list-style-type: none"> <li>• Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt werden</li> <li>• Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind</li> <li>• Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden</li> <li>• Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten</li> </ul> |
| EG13     | Wachstum      | Produkt- und Geschäftsinnovation                         | <ul style="list-style-type: none"> <li>• Grad des Bewusstseins und Verständnisses für geschäftliche Innovationsmöglichkeiten</li> <li>• Zufriedenheit der Anspruchsgruppen mit dem Grad der Produkt- und Innovationskompetenz und der Entwicklung von neuen Ideen</li> <li>• Anzahl der genehmigten Produkt- und Serviceinitiativen, die aus innovativen Ideen resultieren</li> </ul>                               |

## 4.6.2 IT-bezogene Ziele

Unternehmensziele kaskadieren zu IT-bezogenen Zielen (im Original: Alignment Goals). **Abbildung 4.18** zeigt die IT-bezogenen Ziele und Beispielmetriken

**Abbildung 4.18 – Zielkaskade: IT-bezogene Ziele und Metriken**

| Referenz | IT-BSC-Dimension | IT-bezogenes Ziel                                                                                       | Beispielmetrik                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------|------------------|---------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AG01     | Finanzen         | I&T-Compliance und Unterstützung für die Unternehmens-Compliance mit externen Gesetzen und Bestimmungen | <ul style="list-style-type: none"> <li>• Kosten der Nichteinhaltung von IT-Vorschriften, einschließlich Vergleichen und Bußgeldern, sowie die Auswirkungen von Reputationsverlusten</li> <li>• Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von IT-Vorschriften, die der Geschäftsleitung gemeldet wurden oder zu öffentlichen Kommentaren oder Unannehmlichkeiten führten</li> <li>• Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit IT-Dienstleistern</li> </ul> |



**Abbildung 4.18 – Zielkaskade: IT-bezogene Ziele und Metriken**

| Referenz | IT-BSC-Dimension | IT-bezogenes Ziel                                                                                       | Beispielmetrik                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|----------|------------------|---------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AG02     | Finanzen         | Gesteuertes I&T-Risiko                                                                                  | <ul style="list-style-type: none"> <li>Häufigkeit der Aktualisierung des Risikoprofils</li> <li>Anteil der unternehmensweiten Risikobewertungen einschließlich I&amp;T-bezogener Risiken</li> <li>Anzahl gravierender I&amp;T-bezogener Störungen, die nicht in einer Risikobewertung identifiziert wurden</li> </ul>                                                                                                                                                                                                                                                     |
| AG03     | Finanzen         | Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio            | <ul style="list-style-type: none"> <li>Anteil der durch die I&amp;T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden</li> <li>Anteil der I&amp;T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden</li> </ul>                                                                                                                                                                                                                                   |
| AG04     | Finanzen         | Qualität der durch IT erzeugten Finanzinformationen                                                     | <ul style="list-style-type: none"> <li>Zufriedenheit der wichtigsten Anspruchsgruppen hinsichtlich des Grades an Transparenz, Verständnis und Genauigkeit der IT-Finanzinformationen</li> <li>Anteil der I&amp;T-Services mit definierten und genehmigten Betriebskosten und erwartetem Nutzen</li> </ul>                                                                                                                                                                                                                                                                 |
| AG05     | Kunde            | Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen                            | <ul style="list-style-type: none"> <li>Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die IT-Services den vereinbarten Service Levels entsprechen</li> <li>Anzahl von Geschäftsunterbrechungen aufgrund von IT-Service-Störungen</li> <li>Anteil der Nutzer, die mit der Qualität der IT-Services zufrieden sind</li> </ul>                                                                                                                                                                                                                   |
| AG06     | Kunde            | Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen                                    | <ul style="list-style-type: none"> <li>Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der IT auf neue Anforderungen</li> <li>Durchschnittliche Markteinführungszeit für neue I&amp;T-bezogene Services und Anwendungen</li> <li>Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&amp;T-Zielvorgaben in abgestimmte und genehmigte Initiativen</li> <li>Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden</li> </ul>                                                     |
| AG07     | Intern           | Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz            | <ul style="list-style-type: none"> <li>Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben</li> <li>Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben</li> <li>Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben</li> </ul>                                         |
| AG08     | Intern           | Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie | <ul style="list-style-type: none"> <li>Dauer der Ausführung von Geschäftsservices oder -prozessen</li> <li>Anzahl von durch I&amp;T-gestützten Geschäftsprogrammen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder zusätzliche Kosten verursachen</li> <li>Anzahl der Geschäftsprozessänderungen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder überarbeitet werden müssen</li> <li>Anzahl von Anwendungen oder kritischen Infrastrukturen, die isoliert arbeiten und nicht integriert sind</li> </ul> |

**Abbildung 4.18 – Zielkaskade: IT-bezogene Ziele und Metriken (Forts.)**

| Referenz | IT-BSC-Dimension    | IT-bezogenes Ziel                                                                                | Metriken                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------|---------------------|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AG09     | Intern              | Termingetreue, budget-, bedarfs- und qualitätsgerechte Bereitstellung von Programmen             | <ul style="list-style-type: none"> <li>Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte</li> <li>Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern</li> <li>Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                          |
| AG10     | Intern              | Qualität der I&T-Managementinformationen                                                         | <ul style="list-style-type: none"> <li>Grad der Zufriedenheit der Nutzer mit Qualität, Pünktlichkeit und Verfügbarkeit von I&amp;T-bezogenen Managementinformationen unter Berücksichtigung der verfügbaren Ressourcen</li> <li>Verhältnis und Ausmaß von falschen Geschäftsentscheidungen, bei denen fehlerhafte oder nicht verfügbare I&amp;T-bezogene Informationen ein wesentlicher Faktor waren</li> <li>Anteil der Informationen, die die Qualitätskriterien erfüllt haben</li> </ul>                                                                                                                                                                                                                       |
| AG11     | Intern              | I&T-Compliance mit internen Richtlinien                                                          | <ul style="list-style-type: none"> <li>Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von IT-bezogenen Richtlinien</li> <li>Anzahl der Ausnahmen hinsichtlich interner Richtlinien</li> <li>Häufigkeit der Überprüfung und Aktualisierung der Leitlinien</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| AG12     | Lernen und Wachstum | Kompetente und motivierte Mitarbeiter mit gegenseitigem Verständnis für Technologie und Geschäft | <ul style="list-style-type: none"> <li>Anteil von I&amp;T-erfahrenen Fachbereichsmitarbeitern (d. h. Personen, die über das erforderliche I&amp;T-Wissen und -Verständnis verfügen, um I&amp;T-Themen zu lenken, vorzugeben, zu innovieren und I&amp;T-Möglichkeiten in ihrem Fachgebiet zu erkennen)</li> <li>Anteil der fachlich erfahrenen I&amp;T-Mitarbeiter (d. h. Personen, die über das erforderliche Wissen und Verständnis der relevanten Geschäftsbereiche verfügen, um I&amp;T-Themen, zu lenken, vorzugeben, zu innovieren und I&amp;T-Möglichkeiten für den Geschäftsbereich zu erkennen)</li> <li>Anzahl oder Anteil der Fachbereichsmitarbeiter mit Erfahrung im Technologiemanagement</li> </ul> |
| AG13     | Lernen und Wachstum | Wissen, Know-how und Initiativen für geschäftliche Innovationen                                  | <ul style="list-style-type: none"> <li>Grad des Bewusstseins von Führungskräften und des Verständnisses der Innovationsmöglichkeiten im Bereich I&amp;T</li> <li>Anzahl der genehmigten Initiativen, die aus innovativen I&amp;T-Ideen resultieren</li> <li>Anzahl der anerkannten/ausgezeichneten Innovations-Champions</li> </ul>                                                                                                                                                                                                                                                                                                                                                                               |

### Kapitel 5

## COBIT Governance- und Managementziele

### 5.1 Zweck

In Abschnitt 4.2, **Abbildung 4.2**, wurde das COBIT-Kernmodell und die 40 Governance- und Managementziele vorgestellt. **Abbildung 5.1** führt alle Governance- und Managementziele zusammen mit jeweiligen Zweck auf. Der Zweck ist eine weiterführende Ausarbeitung, quasi die nächste Detailstufe jedes Governance- und Managementziels.

| Abbildung 5.1 – COBIT-Kernmodell: Governance- und Managementziele und jeweiliger Zweck |                                                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------------------------------------------------------------------------------------|----------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Referenz                                                                               | Beschreibung                                                         | Zweck                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| EDM01                                                                                  | Einrichtung und Pflege des Governance-Rahmenwerks ist sichergestellt | Bereitstellung eines konsistenten Ansatzes, der in den Governance-Ansatz des Unternehmens integriert und an diesem ausgerichtet ist. I&T-bezogene Entscheidungen müssen im Einklang mit den Strategien und Zielvorgaben des Unternehmens getroffen und der gewünschte Wert realisiert werden. Zu diesem Zweck muss sichergestellt werden, dass I&T-bezogene Prozesse effektiv und transparent überwacht werden, die Compliance mit gesetzlichen, vertraglichen und behördlichen Anforderungen gegeben ist und die Governance-Anforderungen für Mitglieder der Geschäftsleitung erfüllt sind. |
| EDM02                                                                                  | Bereitstellung von Mehrwert ist sichergestellt                       | Sicherstellung eines optimalen Wertbeitrages aus Services, Betriebsmitteln und Initiativen, die durch I&T ermöglicht wurden, kosteneffiziente Bereitstellung von Lösungen und Services sowie ein zuverlässiger und genauer Überblick über die Kosten und den möglichen Mehrwert, damit die Geschäftsanforderungen effektiv und effizient unterstützt werden können.                                                                                                                                                                                                                          |
| EDM03                                                                                  | Risiko-Optimierung ist sichergestellt                                | Sicherstellung, dass das I&T-bezogene Unternehmensrisiko die Risikobereitschaft und Risikotoleranz des Unternehmens nicht übersteigt, dass die Auswirkungen des I&T-Risikos auf den Unternehmenswert identifiziert und gemanagt werden und dass die Gefahr für Compliance-Verfehlungen minimiert wird.                                                                                                                                                                                                                                                                                       |
| EDM04                                                                                  | Ressourcenoptimierung ist sichergestellt                             | Sicherstellung, dass der Ressourcenbedarf des Unternehmens optimal gedeckt und dass die I&T-Kosten optimiert werden sowie die Wahrscheinlichkeit der Nutzenrealisierung und die Bereitschaft für künftige Veränderungen erhöht wird.                                                                                                                                                                                                                                                                                                                                                         |
| EDM05                                                                                  | Einbindung der Anspruchsgruppen ist sichergestellt                   | Sicherstellung, dass die Anspruchsgruppen die I&T-Strategie und die Roadmap unterstützen und dass die Kommunikation mit den Anspruchsgruppen effektiv und rechtzeitig erfolgt und dass die Grundlage für die Berichterstattung mit dem Ziel geschaffen wird, die Leistung zu steigern. Identifizierung von Bereichen, in denen Verbesserungen möglich sind und Sicherstellung, dass die I&T-bezogenen Zielvorgaben und Strategien mit der Unternehmensstrategie vereinbar sind.                                                                                                              |
| APO01                                                                                  | I&T-Management-Rahmenwerk ist gemanagt                               | Bereitstellung eines konsistenten Managementansatzes, mit dessen Hilfe die Governance-Anforderungen des Unternehmens erfüllt werden können, der die folgenden Komponenten umfasst: Managementprozesse, Organisationsstrukturen, Rollen und Zuständigkeiten, zuverlässige und wiederholbare Aktivitäten, Informationselemente, Richtlinien und Verfahren, Fähigkeiten und Kompetenzen, Kultur und Verhalten sowie Services, Infrastruktur und Anwendungen.                                                                                                                                    |

**Abbildung 5.1 – COBIT-Kernmodell: Governance- und Managementziele und jeweiliger Zweck (Forts.)**

| Referenz | Beschreibung                         | Zweck                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AP002    | Strategie ist gemanagt               | Unterstützung der digitalen Transformationsstrategie der Organisation und Bereitstellung des gewünschten Wertes anhand einer Roadmap mit stufenweisen Änderungen. Verwendung eines ganzheitlichen I&T-Ansatzes, der sicherstellt, dass jede Initiative eindeutig mit einer übergreifenden Strategie verbunden ist. Ermöglichung von Veränderungen verschiedener Aspekte der Organisation – von Kanälen und Prozessen bis hin zu Daten, Kultur, Fähigkeiten, Betriebsmodell und Anreizsystemen. |
| AP003    | Unternehmensarchitektur ist gemanagt | Darstellung der unterschiedlichen Bausteine, aus denen das Unternehmen besteht, der Beziehungen der Bausteine untereinander, sowie der Prinzipien, auf denen ihr Design und ihre Weiterentwicklung im Laufe der Zeit basiert und die eine standardisierte, flexible und effiziente Erfüllung operativer und strategischer Zielvorgaben ermöglicht.                                                                                                                                             |
| AP004    | Innovation ist gemanagt              | Realisierung von Wettbewerbsvorteilen, Geschäftsinnovation, verbessertem Kundenerlebnis und verbesserter operativer Effektivität und Effizienz durch die Nutzung von I&T-Entwicklungen und aufkommenden Technologien.                                                                                                                                                                                                                                                                          |
| AP005    | Portfolio ist gemanagt               | Optimierung der Leistung des gesamten Programmportfolios, um der Leistung der individuellen Programme, Produkte und Dienstleistungen sowie veränderten Unternehmensprioritäten und -anforderungen Rechnung zu tragen.                                                                                                                                                                                                                                                                          |
| AP006    | Budget und Kosten sind gemanagt      | Förderung einer Partnerschaft zwischen IT und Anspruchsgruppen im Unternehmen, um eine effektive und effiziente Nutzung I&T-bezogener Ressourcen zu ermöglichen und die Kosten und den Geschäftswert von Lösungen und Services transparent und nachvollziehbar zu gestalten. Befähigung des Unternehmens, fundierte Entscheidungen zur Nutzung von I&T-Lösungen und -Services zu treffen.                                                                                                      |
| AP007    | Personal ist gemanagt                | Optimierung der Befähigungen von Mitarbeitern, um die Unternehmenszielvorgaben zu erreichen.                                                                                                                                                                                                                                                                                                                                                                                                   |
| AP008    | Beziehungen sind gemanagt            | Bereitstellung der geeigneten Kenntnisse, Fähigkeiten und Verhaltensweisen, um bessere Ergebnisse, größeres (gegenseitiges) Vertrauen und eine effektive Nutzung der Ressourcen zu erreichen, um eine produktive Beziehung zu den Anspruchsgruppen des Unternehmens aufzubauen.                                                                                                                                                                                                                |
| AP009    | Servicevereinbarungen sind gemanagt  | Sicherstellung, dass I&T-Produkte, Services und Service Levels den aktuellen und zukünftigen Bedürfnissen des Unternehmens entsprechen.                                                                                                                                                                                                                                                                                                                                                        |
| AP010    | Lieferanten sind gemanagt            | Optimierung der verfügbaren I&T-Befähigungen zur Unterstützung der I&T-Strategie und Roadmap, Minimierung des Risikos einer unzureichenden oder nichtkonformen Lieferantenleistung und Sicherstellung einer wettbewerbsfähigen Preisgestaltung.                                                                                                                                                                                                                                                |
| AP011    | Qualität ist gemanagt                | Sicherstellung einer konsistenten Bereitstellung von Technologie-lösungen und Services, um die Qualitätsanforderungen des Unternehmens und die Bedürfnisse der Anspruchsgruppen zu erfüllen.                                                                                                                                                                                                                                                                                                   |
| AP012    | Risiko ist gemanagt                  | Integration des Managements von I&T-bezogenen Unternehmensrisiken in das allgemeine unternehmensweite Risikomanagement (ERM) und Abwägung von Kosten und Nutzen, die mit dem Management der I&T-bezogenen Unternehmensrisiken einhergehen.                                                                                                                                                                                                                                                     |
| AP013    | Sicherheit ist gemanagt              | Begrenzung der Auswirkungen und des Auftretens von Informationssicherheitsstörungen auf die jeweilige Risikobereitschaft des Unternehmens.                                                                                                                                                                                                                                                                                                                                                     |
| AP014    | Daten sind gemanagt                  | Sicherstellung einer effektiven Nutzung der entscheidenden Datenbestände zur Erreichung der Unternehmensziele und -vorgaben.                                                                                                                                                                                                                                                                                                                                                                   |

**Abbildung 5.1 – COBIT-Kernmodell: Governance- und Managementziele und jeweiliger Zweck (Forts.)**

| Referenz | Beschreibung                                               | Zweck                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----------|------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BAI01    | Programme sind gemanagt                                    | Realisierung des gewünschten Geschäftswerts und Minderung des Risikos von unerwarteten Verzögerungen, Kosten und Wertverlusten, indem die Kommunikation zu und die Einbindung von Geschäfts- und Endbenutzern verbessert wird. Sicherstellen des Wertes und der Qualität von Programmergebnissen und der Nachverfolgung von Projekten innerhalb der Programme sowie die Maximierung ihres Beitrags zum Investitionsportfolio. |
| BAI02    | Anforderungsdefinition ist gemanagt                        | Entwicklung optimaler Lösungen, die den Bedürfnissen des Unternehmens Rechnung tragen und gleichzeitig das Risiko minimieren.                                                                                                                                                                                                                                                                                                 |
| BAI03    | Lösungsidentifizierung und Lösungserstellung sind gemanagt | Sicherstellung einer agilen und skalierbaren Bereitstellung von digitalen Produkten und Services. Zeitgerechte und kostenoptimierte Entwicklung von Lösungen (Technologie, Geschäftsprozesse und Arbeitsabläufe), die geeignet sind, die strategischen und operativen Zielvorgaben des Unternehmens zu unterstützen.                                                                                                          |
| BAI04    | Verfügbarkeit und Kapazität sind gemanagt                  | Aufrechterhaltung der Serviceverfügbarkeit, effizientes Ressourcenmanagement und Optimierung der Systemleistung durch die Vorhersage zukünftiger Leistungs- und Kapazitätsanforderungen.                                                                                                                                                                                                                                      |
| BAI05    | Organisatorische Änderungen sind gemanagt                  | Vorbereitung und Verpflichtung der Anspruchsgruppen auf geschäftsbezogene Änderungen und Reduzierung des Ausfallrisikos.                                                                                                                                                                                                                                                                                                      |
| BAI06    | IT-Änderungen sind gemanagt                                | Ermöglichung einer schnellen und zuverlässigen Bereitstellung von Änderungen für den Geschäftsbetrieb. Minderung des Risikos einer negativen Auswirkung auf die Stabilität oder Integrität des veränderten Umfelds.                                                                                                                                                                                                           |
| BAI07    | Umsetzung und Abnahme von IT-Änderungen sind gemanagt      | Sichere Implementierung von Lösungen im Einklang mit vereinbarten Erwartungen und Ergebnissen.                                                                                                                                                                                                                                                                                                                                |
| BAI08    | Wissen ist gemanagt                                        | Bereitstellung von Wissen und Informationen, die zur Unterstützung aller Mitarbeiter bei Governance und Management der unternehmensweiten I&T erforderlich sind und Ermöglichung einer fundierten Entscheidungsfindung.                                                                                                                                                                                                       |
| BAI09    | Betriebsmittel sind gemanagt                               | Inventarisierung aller I&T-Betriebsmittel und Optimierung des Wertbeitrages, der durch die Nutzung entsteht.                                                                                                                                                                                                                                                                                                                  |
| BAI10    | Konfiguration ist gemanagt                                 | Bereitstellung ausreichender Hintergrundinformationen zu Services, um ein effektives Managen des jeweiligen Services zu ermöglichen. Beurteilung der Auswirkungen von Änderungen und Abwicklung von Servicestörungen.                                                                                                                                                                                                         |
| BAI11    | Projekte sind gemanagt                                     | Realisierung definierter Projektergebnisse und Minderung des Risikos von unerwarteten Verzögerungen, Kosten und Wertverlusten, indem die Kommunikation zu und die Einbindung von Geschäfts- und Endbenutzern verbessert wird. Sicherstellen des Wertes und der Qualität der Projektergebnisse und Maximierung ihres Beitrages zu den definierten Programmen und zum Investitionsportfolio.                                    |
| DSS01    | Betrieb ist gemanagt                                       | Bereitstellung von vereinbarten betrieblichen I&T-Produkten und Service-Ergebnissen.                                                                                                                                                                                                                                                                                                                                          |
| DSS02    | Serviceanfragen und Störungen sind gemanagt                | Maximierung der Produktivität und Minimierung von Unterbrechungen durch schnelle Bearbeitung von Benutzeranfragen und Störungen. Beurteilung der Auswirkungen von Änderungen und Abwicklung von Servicestörungen. Bearbeitung von Benutzeranfragen und Wiederherstellen des Services bei Störungen.                                                                                                                           |
| DSS03    | Probleme sind gemanagt                                     | Steigerung der Verfügbarkeit, Verbesserung der Service Levels, Reduzierung von Kosten und Verbesserung der Benutzerfreundlichkeit und Benutzerzufriedenheit durch Reduzierung der Anzahl operativer Probleme und Identifikation der Ursachen im Rahmen der Problemlösung.                                                                                                                                                     |

**Abbildung 5.1 – COBIT-Kernmodell: Governance- und Managementziele und jeweiliger Zweck (Forts.)**

| Referenz     | Beschreibung                                           | Zweck                                                                                                                                                                                                                                                                                                                                      |
|--------------|--------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>DSS04</b> | Kontinuität ist gemanagt                               | Schnelle Anpassung, Fortsetzung des Geschäftsbetriebs und Aufrechterhaltung der Verfügbarkeit von Ressourcen und Informationen auf einem für das Unternehmen akzeptablen Niveau im Falle einer erheblichen Unterbrechung (z. B. Bedrohungen, Chancen, Anforderungen).                                                                      |
| <b>DSS05</b> | Sicherheitsservices sind gemanagt                      | Minimierung der geschäftlichen Auswirkungen von betrieblichen Informationssicherheits-Schwachstellen und -Vorfällen.                                                                                                                                                                                                                       |
| <b>DSS06</b> | Geschäftsprozesskontrollen sind gemanagt               | Aufrechterhaltung der Informationsintegrität und der Sicherheit von Informationsbeständen, die im Rahmen von unternehmensinternen oder ausgelagerten Geschäftsprozessen verarbeitet werden.                                                                                                                                                |
| <b>MEA01</b> | Überwachung von Leistung und Konformität wird gemanagt | Gewährleistung von Transparenz in Bezug auf Leistung und Konformität sowie Förderung der Zielerreichung.                                                                                                                                                                                                                                   |
| <b>MEA02</b> | Internes Kontrollsystem wird gemanagt                  | Sicherstellung von Transparenz für wichtige Anspruchsgruppen in Bezug auf die Angemessenheit des internen Kontrollsystems und somit die Schaffung von Vertrauen in Abläufe, von Zuversicht hinsichtlich der Erreichung der Unternehmenszielvorgaben sowie Förderung eines adäquaten Verständnisses des Restrisikos.                        |
| <b>MEA03</b> | Compliance mit externen Anforderungen wird gemanagt    | Sicherstellung, dass die Organisation alle relevanten externen Anforderungen erfüllt.                                                                                                                                                                                                                                                      |
| <b>MEA04</b> | Assurance wird gemanagt                                | Befähigung des Unternehmens, effiziente und effektive Assurance-Initiativen zu konzipieren, indem Anleitungen zur Planung, zur Festlegung des Umfangs, zur Durchführung und zur Weiterverfolgung von Assurance-Prüfungen bereitgestellt werden. Dies erfolgt unter Verwendung einer Roadmap, die auf bewährten Assurance-Ansätzen basiert. |

## Kapitel 6

### Leistungssteuerung in COBIT

#### 6.1 Definition

Leistungssteuerung ist ein wesentlicher Bestandteil eines Governance- und Managementsystems. „Leistungssteuerung“ ist ein genereller Begriff, der alle Aktivitäten und Methoden umfasst. Er drückt aus, wie gut das Governance- und Managementsystem und alle Komponenten eines Unternehmens funktionieren und wie sie verbessert werden können, um das erforderliche Niveau zu erreichen. Die Leistungssteuerung umfasst Konzepte und Methoden, wie z. B. Fähigkeits- und Reifegradstufen. COBIT verwendet für diese Aktivitäten den Begriff COBIT Performance Management (CPM), das entsprechende Konzept ist ein integraler Bestandteil des COBIT-Rahmenwerks.

#### 6.2 Prinzipien der COBIT-Leistungssteuerung

COBIT® 2019 basiert auf den folgenden Prinzipien:

1. Das CPM sollte einfach zu verstehen und anzuwenden sein.
2. Das CPM sollte mit dem konzeptionellen Modell von COBIT im Einklang stehen und dieses unterstützen. Das CPM sollte es ermöglichen, die Leistung aller Arten von Komponenten des Governance-Systems zu managen und es muss möglich sein, sowohl die Leistung von Prozessen als auch die Leistung anderer Komponenten (z. B. Organisationsstrukturen oder Informationen) zu managen, wenn die Benutzer dies wünschen.
3. Das CPM sollte zuverlässige, reproduzierbare und relevante Ergebnisse liefern.
4. Das CPM muss flexibel sein, damit es den Anforderungen verschiedener Organisationen mit unterschiedlichen Prioritäten und Bedürfnissen gerecht werden kann.
5. Das CPM sollte verschiedene Arten der Bewertung unterstützen, von Selbsteinschätzungen bis hin zu formellen Beurteilungen oder Audits.

#### 6.3 Übersicht der COBIT-Leistungssteuerung

Das CPM-Modell (**Abbildung 6.1**) orientiert sich weitgehend an den CMMI® Development V2.0<sup>20</sup>-Konzepten und erweitert sie:

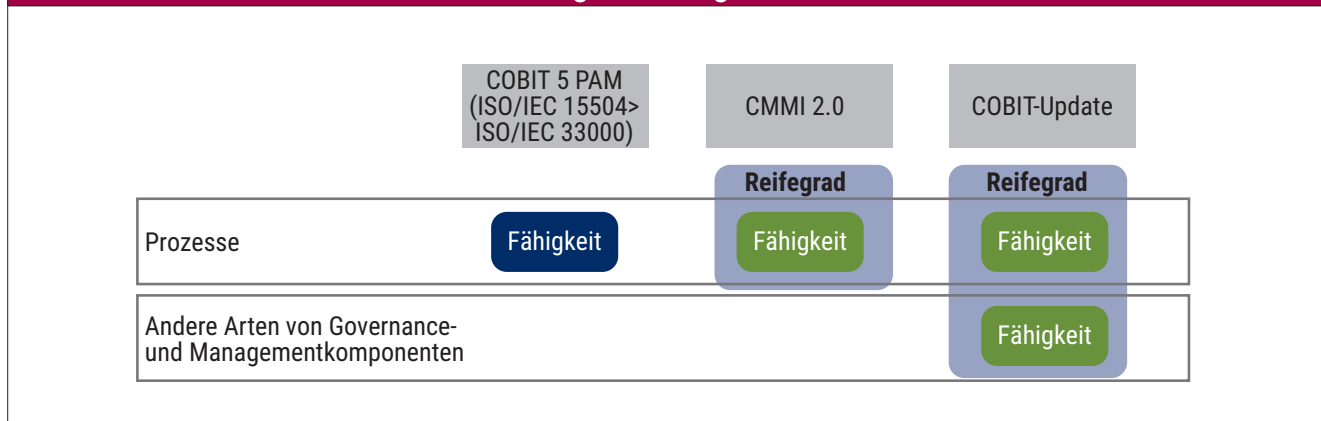
- Prozessaktivitäten sind Fähigkeitsstufen zugeordnet. Dies ist im *COBIT® 2019-Rahmenwerk: Governance- und Managementziele* enthalten.
- Für andere Arten von Governance- und Managementkomponenten (z. B. Organisationsstrukturen, Informationen) können in künftigen Anleitungen ebenfalls Fähigkeitsstufen definiert werden.
- Die Reifegradstufen sind mit Schwerpunktbereichen verknüpft (d. h. mit einer Gruppe von Governance- und Managementzielen und den zugrunde liegenden Komponenten) und werden erreicht, wenn alle erforderlichen Fähigkeitsstufen erreicht sind.

---

<sup>20</sup> CMMI® Development V2.0, CMMI Institute, USA, 2018, <https://cmmiinstitute.com/model-viewer/dashboard>



Abbildung 6.1 – Fähigkeitsstufen



Wenn Unternehmen weiterhin das COBIT 5-Prozessfähigkeitsmodell auf der Grundlage der International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 15504 (jetzt ISO/IEC 33000, in der die Fähigkeitsstufen stark abweichende Bedeutungen haben) verwenden möchten, finden sie alle dazu erforderlichen Informationen in *COBIT® 2019-Rahmenwerk: Governance- und Managementziele*. Es sind keine separaten Publikationen zum Prozessbewertungsmodell (PAM) erforderlich, und sie sind auch nicht Bestandteil von COBIT® 2019.

In COBIT® 2019 werden die Prozessergebnisse oder Prozessziele durch Prozesspraktiken ersetzt. Daraus ergibt sich die folgende Situation für eine ISO/IEC33000-Bewertung:

1. Die Prozessergebnisse sind nun eins zu eins mit den Prozesspraktiken verknüpft (d. h. die Prozessergebnisse entsprechen dem erfolgreichen Abschluss der Prozesspraktiken). Hinweis: Die Prozesspraktiken werden als Praktiken formuliert, und die Ergebnisse können daraus abgeleitet werden. Beispiel: APO01.01 *Design des Managementsystems für die Unternehmens-I&T* hat als Prozessergebnis APO01.01: *Ein Managementsystem für die Unternehmens-I&T ist designt*.
2. Die grundlegenden Praktiken entsprechen den COBIT® 2019-Prozesspraktiken für jedes Governance- und Managementziel.
3. Die Arbeitsprodukte entsprechen den Informationsflüssen und Elementen unter Komponente C bei jedem Governance-/Managementziel.

Daher erfolgt die Zuordnung der Ergebnisse zu den grundlegenden Praktiken und Arbeitsprodukten in COBIT® 2019 anhand der Definition.

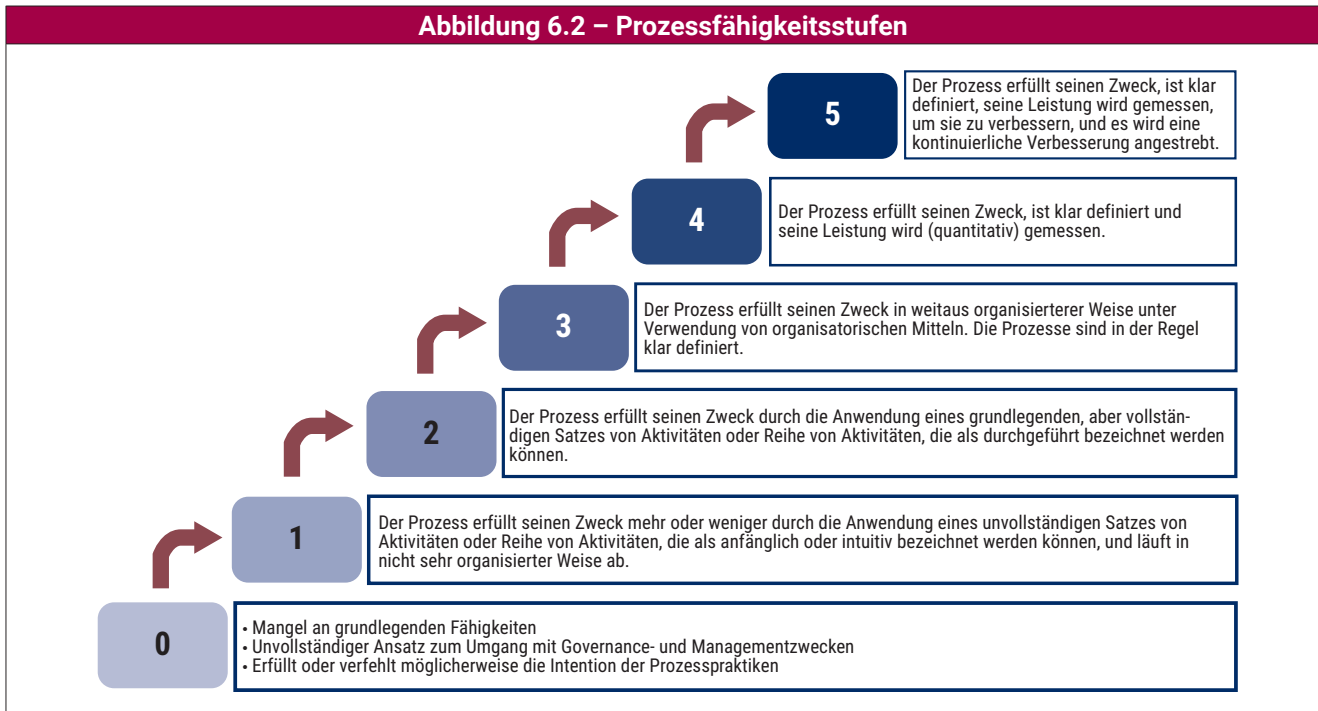
## 6.4 Managen der Prozessleistung

### 6.4.1 Prozessfähigkeitsstufen

COBIT® 2019 unterstützt ein auf CMMI basierendes Prozessfähigkeitsschema. Der Prozess im Rahmen der einzelnen Governance- und Managementziele kann auf verschiedenen Fähigkeitsstufen von 0 bis 5 ablaufen. Die Fähigkeitsstufe ist ein Maß dafür, wie gut ein Prozess umgesetzt wurde und wie leistungsfähig er ist. **Abbildung 6.2** zeigt das Modell, die verschiedenen Fähigkeitsstufen und deren allgemeine Merkmale.



Abbildung 6.2 – Prozessfähigkeitsstufen



Das COBIT-Kernmodell ordnet allen Prozessaktivitäten Fähigkeitsstufen zu und ermöglicht so eine klare Definition der Prozesse und der erforderlichen Aktivitäten zur Erreichung der verschiedenen Fähigkeitsstufen. Für weitere Informationen siehe: *COBIT® 2019-Rahmenwerk: Governance- und Managementziele*.

### 6.4.2 Rating der Prozessaktivitäten

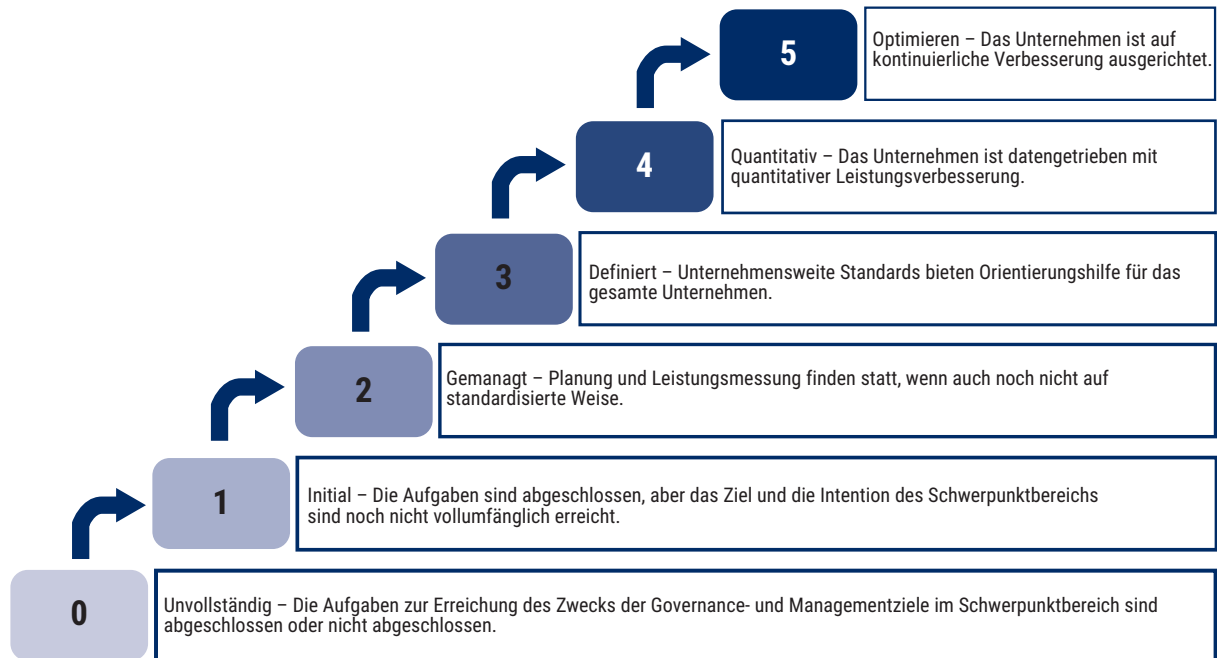
Welche Fähigkeitsstufe erreicht wurde, kann durch eine Reihe von Ratings ausgedrückt werden. Die Bandbreite der verfügbaren Ratings hängt vom Kontext ab, in dem die Leistungsbewertung vorgenommen wird:

- Einige formelle Methoden, die zu einer unabhängigen Zertifizierung führen, legen eine binäre Bewertung in Form von bestanden/nicht bestanden zu Grunde.
- Weniger formelle Methoden (die oft im Zusammenhang mit einer Leistungsverbesserung eingesetzt werden) liefern durch eine größere Bandbreite bessere Ergebnisse, wie z. B. die folgende Skala:
  - **Vollständig** – Die Fähigkeitsstufe wird zu mehr als 85 Prozent erreicht. (Dies bleibt eine Ermessensentscheidung, aber sie kann durch die Untersuchung oder Bewertung der Komponenten des Enablers, wie z. B. Prozessaktivitäten, Prozessziele oder bewährte Praktiken im Bereich der Organisationsstruktur, untermauert werden).
  - **Größtenteils** – Die Fähigkeitsstufe wird zu 50 bis 85 Prozent erreicht.
  - **Teilweise** – Die Fähigkeitsstufe wird zu 15 bis 50 Prozent erreicht.
  - **Nicht** – Die Fähigkeitsstufe wird zu weniger als 15 Prozent erreicht.

### 6.4.3 Reifegradstufen für Schwerpunktbereiche

Manchmal ist eine höhere Abstraktionsebene ohne die Notwendigkeit des Detailgrades erforderlich, der bei der Bewertung der einzelnen Prozessfähigkeitsstufen Anwendung findet, um die Leistung auszudrücken. Zu diesem Zweck können Reifegradstufen verwendet werden. COBIT® 2019 definiert Reifegradstufen als ein Leistungsmaß auf der Ebene der Schwerpunktbereiche, wie in **Abbildung 6.3** dargestellt.

Abbildung 6.3 – Reifegradstufen für Schwerpunktbereiche



Reifegradstufen sind mit Schwerpunktbereichen verknüpft (d. h. mit einer Gruppe von Governance- und Managementzielen und den zugrunde liegenden Komponenten) und eine bestimmte Reifegradstufe ist erreicht, wenn alle im Schwerpunktbereich enthaltenen Prozesse diese bestimmte Fähigkeitsstufe erreichen.

## 6.5 Leistungssteuerung anderer Komponenten des Governance-Systems

### 6.5.1 Leistungssteuerung von Organisationsstrukturen

Obwohl es keine allgemein akzeptierte oder formelle Methode zur Bewertung von Organisationsstrukturen gibt, können sie anhand der folgenden Kriterien bewertet werden. Für jedes Kriterium kann eine Reihe von Unterkriterien definiert werden, die mit den verschiedenen Fähigkeitsstufen verknüpft sind. Die Kriterien sind:

- Erfolgreiche Ausführung jener Prozesspraktiken, für die die Organisationsstruktur (oder Rolle) die Verantwortung oder Zuständigkeit hat (A bzw. R im RACI-Diagramm).
- Erfolgreiche Anwendung einer Reihe von bewährten Praktiken für Organisationsstrukturen, wie z. B.:
  - Grundlegende Funktionsprinzipien
    - Die Organisationsstruktur ist formal festgelegt.
    - Die Organisationsstruktur hat einen klaren, dokumentierten und hinlänglich verstandenen Zweck.
    - Die Funktionsprinzipien sind dokumentiert.
    - Es finden regelmäßige Besprechungen statt, wie in den Funktionsprinzipien festgelegt.
    - Besprechungsprotokolle sind verfügbar und aussagekräftig.
  - Zusammensetzung
    - Die Organisationsstruktur ist formal festgelegt.

- Steuerungsmöglichkeiten
  - Die Organisationsstruktur hat einen klaren, dokumentierten und hinlänglich verstandenen Zweck.
  - Die Funktionsprinzipien sind dokumentiert.
  - Es finden regelmäßige Besprechungen statt, wie in den Funktionsprinzipien festgelegt.
  - Besprechungsprotokolle sind verfügbar und aussagekräftig.
- Autoritätsebene und Umfang der Entscheidungsbefugnisse
  - Entscheidungsbefugnisse in der Organisationsstruktur sind definiert und dokumentiert.
  - Entscheidungsbefugnisse in der Organisationsstruktur werden anerkannt und eingehalten (auch eine Frage der Kultur/des Verhaltens).
- Delegieren von Befugnissen
  - Befugnissen werden auf sinnvolle Weise delegiert.
- Eskalationsverfahren
  - Eskalationsverfahren sind definiert und werden angewendet.
- Erfolgreiche Anwendung einer Reihe von Praktiken zum Management der Organisationsstruktur (nicht-funktionale Praktiken, die sich aus Sicht der Organisationsstruktur ergeben):
  - Ziele für die Leistung der Organisationsstrukturen werden festgelegt.
  - Die Leistung der Organisationsstruktur wird geplant und überwacht.
  - Die Leistung der Organisationsstruktur wird zwecks Planerreichung angepasst.
  - Die seitens der Organisationsstruktur erforderlichen Ressourcen und Informationen werden identifiziert, zur Verfügung gestellt, zugewiesen und genutzt.
  - Die Schnittstellen zwischen der Organisationsstruktur und anderen Anspruchsgruppen werden so verwaltet, dass sowohl eine effektive Kommunikation als auch eine klare Zuweisung von Verantwortung gewährleistet ist.
  - Regelmäßige Evaluierungen führen zu der erforderlichen kontinuierlichen Verbesserung der Organisationsstruktur – in ihrem Aufbau, ihrem Zweck oder jedem anderen Parameter.

Was die Prozesse anbelangt, so erfordern niedrige Fähigkeitsstufen nur die Erfüllung einer Teilmenge der Kriterien, während höhere Fähigkeitsstufen die Erfüllung aller Kriterien erfordern. Aber, wie bereits angedeutet, gibt es kein allgemein akzeptiertes Schema zur Bewertung von Organisationsstrukturen. Dies muss ein Unternehmen jedoch nicht daran hindern, ein eigenes Fähigkeitsstufenschema für die Organisationsstrukturen zu definieren.

### 6.5.2 Leistungssteuerung von Informationselementen

Die Komponente Informationselement eines I&T-Governance-Systems ist mehr oder weniger äquivalent zu den Arbeitsprodukten des Prozesses, wie in *COBIT 2019®-Rahmenwerk: Governance- und Managementziele* beschrieben.

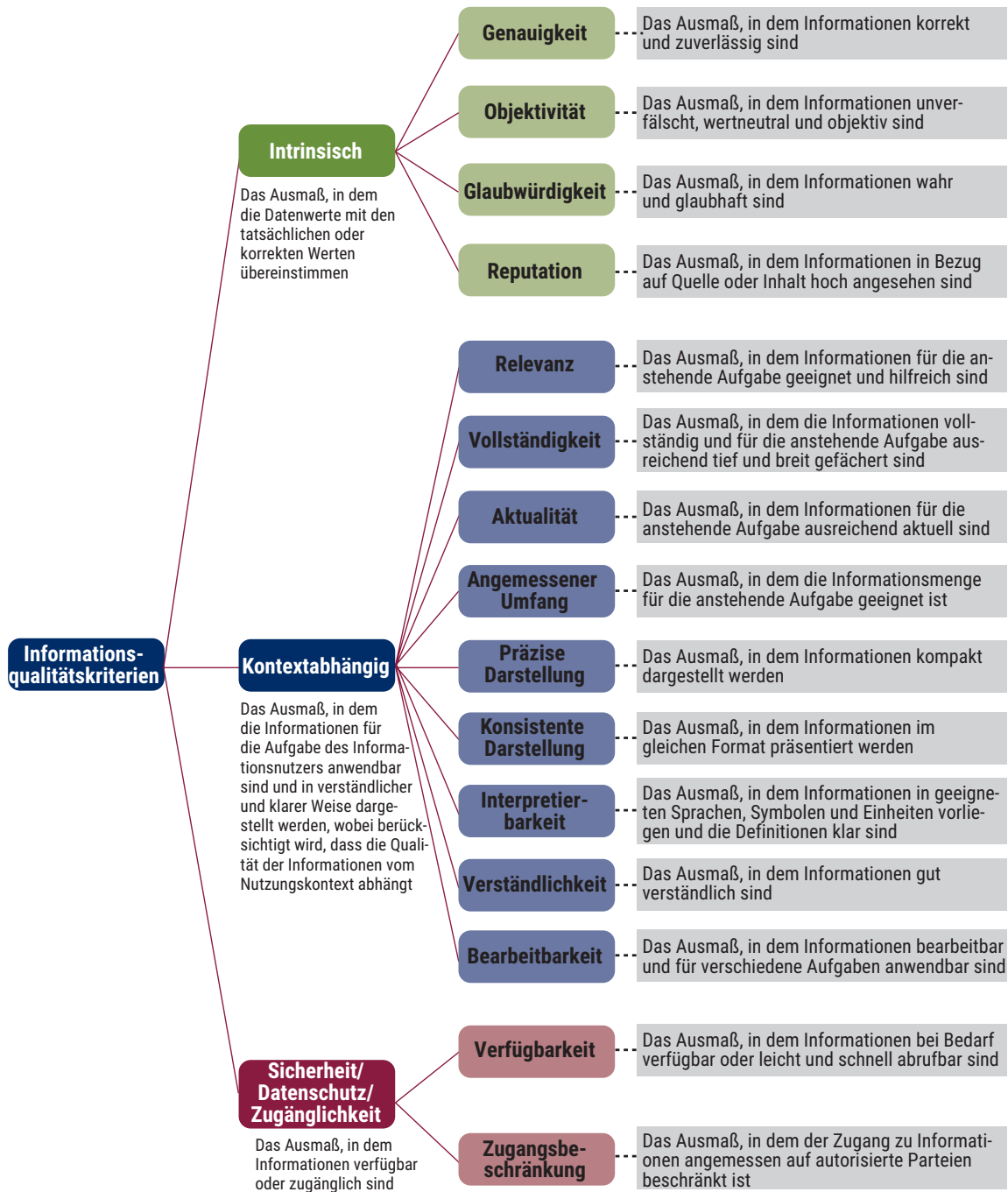
Obwohl es keine allgemein akzeptierte oder formelle Methode zur Bewertung von Informationselementen gibt, können sie weniger formell nach dem Informationsreferenzmodell bewertet werden, das erstmals in *COBIT® 5: Enabling Information* vorgestellt wurde.<sup>21</sup>

Dieses Modell definiert drei Hauptqualitätskriterien und 15 Unterkriterien für Informationen, wie in **Abbildung 6.4** dargestellt.

---

<sup>21</sup> Siehe: ISACA, COBIT® 5: Enabling Information, Kapitel 3.1.2 Goals, USA, 2013, <http://www.isaca.org/COBIT/Pages/COBIT-5-Enabling-Information-product-page.aspx>

Abbildung 6.4 – COBIT-Informationsreferenzmodell: Qualitätskriterien für Informationen



Ein Informationselement kann bewertet werden, indem geprüft wird, inwieweit die relevanten Qualitätskriterien, wie in **Abbildung 6.4** definiert, erreicht werden.

### 6.5.3 Leistungssteuerung von Kultur und Verhalten

Für die Governance-Komponente „Kultur und Verhalten“ sollten erwünschte (und/oder unerwünschte) Verhaltensweisen für Governance und Management der IT definiert und diesen jeweils verschiedene Fähigkeitsstufen zugeordnet werden.

Das *COBIT® 2019-Rahmenwerk: Governance- und Managementziele* definiert Aspekte der Komponente „Kultur- und Verhalten“ für die meisten Ziele. Auf dieser Grundlage ist es möglich, zu beurteilen, inwieweit diese Bedingungen oder Verhaltensweisen umgesetzt sind.

Informationen zu Schwerpunktbereichen, die detailliertere erwünschte Verhaltensweisen enthalten werden, sind noch in der Entwicklung. Dem Leser wird empfohlen, sich unter [isaca.org/cobit](https://isaca.org/cobit) über den neuesten Stand und die verfügbaren Informationen zu den Schwerpunktbereichen zu informieren.

**Diese Seite wurde absichtlich freigelassen.**

### Kapitel 7

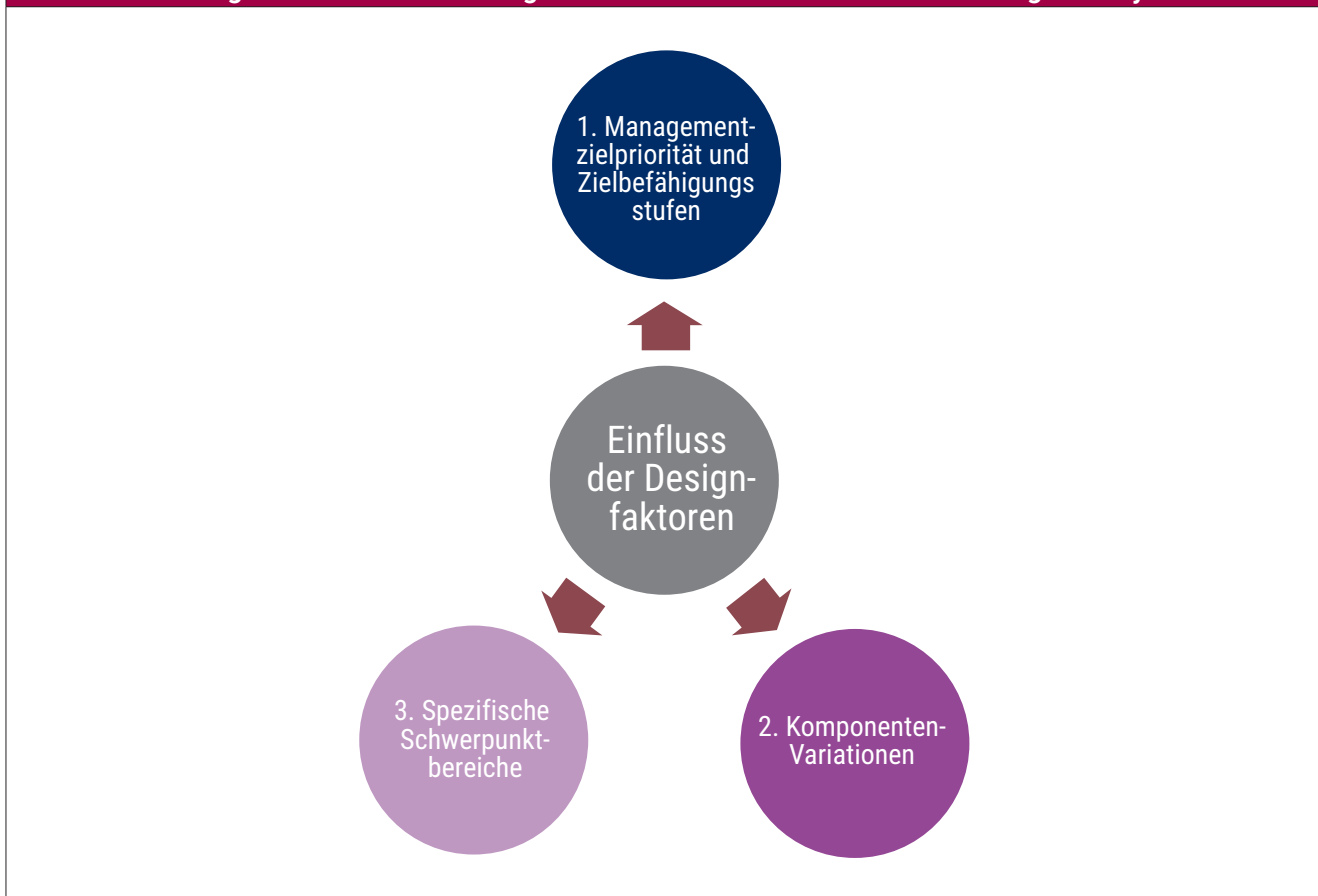
## Konzeption eines zugeschnittenen Governance-Systems

### 7.1 Auswirkungen von Designfaktoren

Dieses Kapitel bietet einen allgemeinen Überblick über die potenziellen Auswirkungen von Designfaktoren auf ein Governance-System für die unternehmensweite I&T. Außerdem wird der Arbeitsablauf zur Konzeption eines auf die Bedürfnisse des Unternehmens zugeschnittenen Governance-Systems in allgemeiner Form beschrieben. Weitere Informationen zu diesen Themen finden Sie im *COBIT® 2019-Designleitfaden*.

Designfaktoren beeinflussen auf unterschiedliche Weise die Gestaltung des Governance-Systems eines Unternehmens. In dieser Publikation werden drei verschiedene Arten von Auswirkungen unterschieden, die in **Abbildung 7.1** dargestellt sind.

**Abbildung 7.1 – Einfluss von Designfaktoren auf ein Governance- und Managementsystem**



**1. Priorisierung/Auswahl von Managementzielen** – Das COBIT-Kernmodell umfasst 40 Governance- und Managementziele, die jeweils aus dem Prozess und einer Reihe von zugehörigen Komponenten bestehen. Sie sind im Prinzip gleichwertig, d. h. es gibt keine Rangfolge oder Priorisierung. Designfaktoren können diese Gleichwertigkeit jedoch beeinflussen und dazu führen, dass einige Governance- und Managementziele wichtiger werden als andere, manchmal sogar in dem Maß, dass andere Governance- und Managementziele vernachlässigbar werden können. In der Praxis führt diese höhere Wichtigkeit dazu, dass für wesentliche Governance- und Managementziele höhere Fähigkeitsstufen festgelegt werden.

**Beispiel:** Wenn ein Unternehmen das/die wichtigste(n) Unternehmensziel(e) aus der Gesamtheit der Unternehmensziele identifiziert und die Zielkaskade anwendet, führt dies zu einer Auswahl von vorrangigen Managementzielen mit höherer Priorität. Wenn z. B. EG01 *Portfolio wettbewerbsfähiger Produkte und Dienstleistungen* von einem Unternehmen als sehr hoch eingestuft wird, macht dies das Managementziel APO05 *Portfolio ist gemanagt* zu einem wichtigen Bestandteil des Governance-Systems dieses Unternehmens.

**Beispiel:** Ein Unternehmen, das sehr risikoavers ist, wird den Managementzielen, die darauf hinwirken, Risiko und Sicherheit zu steuern und zu managen, mehr Priorität einräumen. Die Governance- und Managementziele EDM03 *Risiko-Optimierung ist sichergestellt*, APO12 *Risiko ist gemanagt*, APO13 *Sicherheit ist gemanagt* und DSS05 *Sicherheitsservices sind gemanagt* werden zu wichtigen Bestandteilen des Governance-Systems dieses Unternehmens und es werden für sie höhere Fähigkeitsstufen definiert.

**Beispiel:** Ein Unternehmen, das in einer Umgebung mit hohem Bedrohungspotenzial operiert, wird leistungsfähige sicherheitsbezogene Prozesse benötigen: APO13 *Sicherheit ist gemanagt* und DSS05 *Sicherheitsservices sind gemanagt*.

**Beispiel:** Ein Unternehmen, in dem die Rolle der IT strategisch und entscheidend für den Geschäftserfolg ist, erfordert eine starke Einbindung IT-bezogener Rollen in die Organisationsstruktur, ein tiefgehendes Verständnis des Geschäfts durch IT-Fachleute (und umgekehrt) und eine Fokussierung auf strategische Prozesse wie APO02 *Strategie ist gemanagt* und APO08 *Beziehungen sind gemanagt*.

**2. Komponenten-Variationen** – Komponenten sind erforderlich, um die Governance- und Managementziele zu erreichen. Einige Designfaktoren können die Bedeutung einer oder mehrerer Komponenten beeinflussen oder spezifische Varianten erforderlich machen

**Beispiel:** Kleine und mittlere Unternehmen benötigen möglicherweise nicht den vollen Umfang an Rollen und Organisationsstrukturen, wie im COBIT-Kernmodell dargelegt, sondern können stattdessen eine reduzierte Anzahl verwenden. Die reduzierte Anzahl von Governance- und Managementzielen und die darin enthaltenen Komponenten sind im Schwerpunktbereich „Kleine und mittlere Unternehmen“ definiert.<sup>22</sup>

**Beispiel:** Ein Unternehmen, das in einem stark regulierten Umfeld tätig ist, wird dokumentierten Arbeitsprodukten, Richtlinien und Verfahren sowie einigen Rollen, z. B. der Funktion des Compliance-Beauftragten, mehr Bedeutung beimessen.

**Beispiel:** Ein Unternehmen, das den DevOps-Ansatz zur Lösungsentwicklung und im Betrieb einsetzt, wird spezifische Aktivitäten, Organisationsstrukturen, Kultur usw. benötigen und sich auf BAI03 *Lösungsidentifizierung und Lösungserstellung sind gemanagt* und DSS01 *Betrieb ist gemanagt* konzentrieren.

**3. Bedarf an spezifischen Schwerpunktbereichen** – Einige Designfaktoren, wie z. B. die Bedrohungslandschaft, das spezifische Risiko, die Methoden der Zielentwicklung und der Aufbau der Infrastruktur, werden den Bedarf an Variation des Inhalts des COBIT-Kernmodells für einen spezifischen Kontext vorantreiben.

**Beispiel:** Unternehmen, die einen DevOps-Ansatz verfolgen, benötigen ein Governance-System mit Varianten mehrerer generischer COBIT-Prozesse, die im Leitfaden zum Schwerpunktbereich DevOps<sup>23</sup> in COBIT beschrieben sind.

<sup>22</sup> Zum Zeitpunkt der Veröffentlichung von COBIT® 2019-Rahmenwerk: Einführung und Methodik, befand sich der Inhalt des Schwerpunktbereichs „Kleine und mittlere Unternehmen“ noch in der Entwicklung und war noch nicht veröffentlicht.

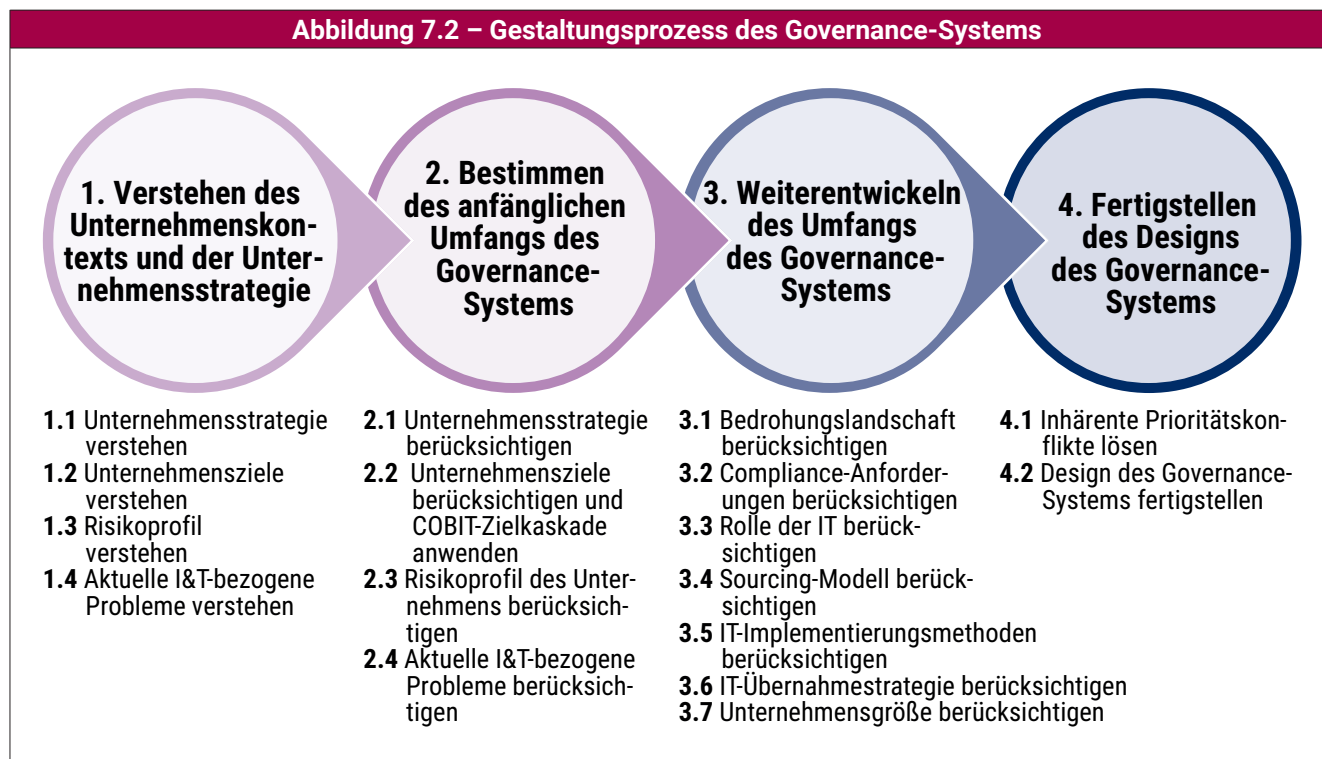
<sup>23</sup> Zum Zeitpunkt der Veröffentlichung von COBIT® 2019-Rahmenwerk: Einführung und Methodik, befand sich der Inhalt des Schwerpunktbereichs „DevOps“ noch in der Entwicklung und war noch nicht veröffentlicht.



**Beispiel:** Kleine und mittlere Unternehmen verfügen über weniger Personal, weniger IT-Ressourcen und kürzere und direktere Berichtslinien und unterscheiden sich in vielen Aspekten von großen Unternehmen. Aus diesem Grund wird ihr I&T-Governance-System im Vergleich zu großen Unternehmen weniger aufwändig sein müssen. Dies wird im Leitfaden zum Schwerpunktbereich Kleine und mittlere Unternehmen (KMU) von COBIT beschrieben.<sup>24</sup>

### 7.2 Phasen und Schritte im Gestaltungsprozess

Abbildung 7.2 illustriert den vorgeschlagenen Ablauf zur Gestaltung eines zugeschnittenen Governance-Systems.



Aus den verschiedenen Phasen und Schritten des Prozesses, wie in **Abbildung 7.2** dargestellt, ergeben sich Empfehlungen für die Priorisierung von Governance- und Managementzielen oder damit zusammenhängenden Governance-System-Komponenten, für angestrebte Fähigkeitsstufen oder für die Verwendung spezifischer Varianten einer Governance-System-Komponente.

Einige dieser Schritte oder Teilschritte können zu widersprüchlichen Hinweisen führen, was unvermeidlich ist, wenn man eine größere Anzahl von Designfaktoren, den allgemeinen Charakter der Anleitungen zu den Designfaktoren und die verwendeten Zuordnungstabellen berücksichtigt.

Es wird empfohlen, die während der verschiedenen Schritte entstandenen Hinweise zunächst im Überblick zu betrachten und in der letzten Phase des Prozesses die Konflikte zwischen den Elementen (im Rahmen des Möglichen) zu lösen und den Prozess abzuschließen. Es gibt allerdings kein Patentrezept. Die endgültige Ausarbeitung wird von Fall zu Fall auf der Grundlage des Gesamtüberblicks aller Elemente entschieden. Durch die Befolgung dieser Schritte werden Unternehmen ein Governance-System erhalten, das auf ihre Bedürfnisse zugeschnitten ist.

<sup>24</sup> Zum Zeitpunkt der Veröffentlichung von COBIT® 2019-Rahmenwerk: Einführung und Methodik, befand sich der Inhalt des Schwerpunktbereichs „Kleine und mittlere Unternehmen“ noch in der Entwicklung und war noch nicht veröffentlicht.

**Diese Seite wurde absichtlich freigelassen.**

## Kapitel 8

### Implementierung der Governance der unternehmensweiten I&T

#### 8.1 Zweck des COBIT-Implementierungsleitfadens

Der *COBIT® 2019-Implementierungsleitfaden* stellt eine unternehmensweite Sicht der Governance der I&T in den Vordergrund. Dieser Leitfaden geht davon aus, dass I&T in Unternehmen allgegenwärtig sind und dass es weder möglich noch bewährte Praxis ist, geschäftliche und IT-bezogene Aktivitäten zu trennen. Governance und Management der unternehmensweiten I&T sollte daher als integraler Bestandteil der Governance des Unternehmens implementiert werden, der die gesamten funktionalen Verantwortungsbereiche von Geschäft und IT vollumfänglich abdeckt.

Einer der häufigen Gründe, warum die Implementierung von Governance-Systemen scheitert, ist, dass sie nach der Einführung nicht sachgemäß als Programme gemanagt werden, um sicherzustellen, dass die Vorteile auch realisiert werden. Governance-Programme müssen von den obersten Führungskräften nachhaltig unterstützt werden, ihr Umfang muss sorgfältig geplant und Ziele definiert werden, die auch erreichbar sind. Dies ermöglicht es dem Unternehmen, das geplante Tempo des Wandels auch zu verkraften. Das Programm-Management wird daher als integraler Bestandteil der Phase der Implementierung behandelt.

Weiter wird davon ausgegangen, dass zwar ein Programm- und Projektansatz empfohlen wird, um Verbesserungsinitiativen effektiv voranzutreiben, das Ziel aber auch darin besteht, eine übliche Geschäftspraxis und einen nachhaltigen Ansatz für Governance und Management der unternehmensweiten I&T zu etablieren, ebenso wie für jeden anderen Aspekt der Governance. Aus diesem Grund basiert der Implementierungsansatz auf der Befähigung von Geschäfts- und IT-Anspruchsgruppen und Akteuren, die Verantwortung für IT-bezogene Governance- und Managemententscheidungen und -aktivitäten zu übernehmen, indem Veränderungen gefördert und ermöglicht werden. Das Implementierungsprogramm wird abgeschlossen, wenn der Prozess der Fokussierung auf IT-bezogene Prioritäten und die Verbesserung der Governance einen messbaren Nutzen liefert und das Programm in die laufende Geschäftstätigkeit eingebunden ist.

Weitere Informationen zu diesem Thema finden Sie im *COBIT® 2019 Implementierungsleitfaden*.

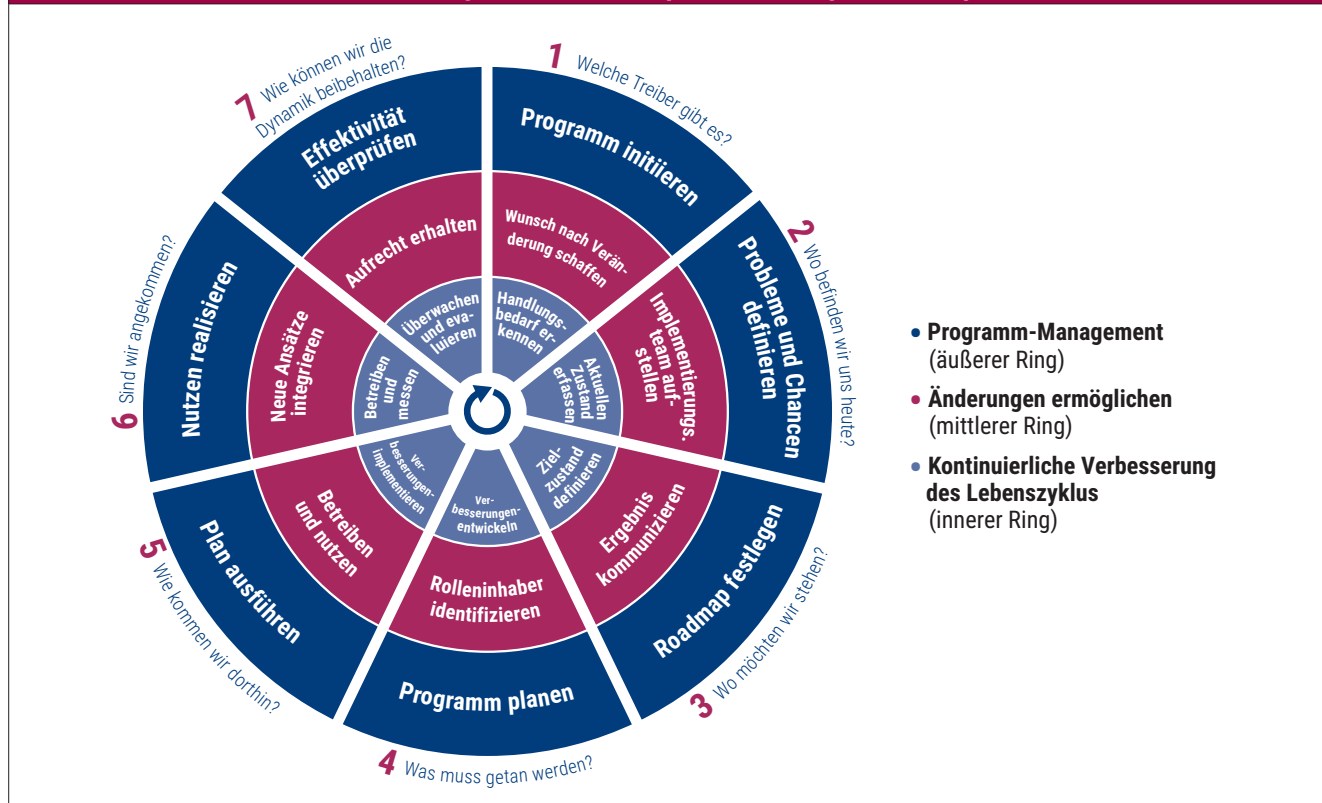
#### 8.2 COBIT-Implementierungsansatz

Der COBIT-Implementierungsansatz umfasst sieben Phasen:

- Welche Treiber gibt es?
- Wo befinden wir uns heute?
- Wo möchten wir stehen?
- Was muss getan werden?
- Wie kommen wir dorthin?
- Sind wir angekommen?
- Wie können wir die Dynamik beibehalten?

Der COBIT-Implementierungsansatz ist in **Abbildung 8.1** zusammengefasst.

Abbildung 8.1 – COBIT-Implementierungs-Roadmap



## 8.2.1 Phase 1 – Welche Treiber gibt es?

In Phase 1 des Implementierungsansatzes werden die aktuellen Treiber von Veränderungen identifiziert und auf der obersten Führungsebene der Wunsch nach Veränderung geweckt, der dann im Entwurf eines Business Case zum Ausdruck kommt. Ein Treiber von Veränderungen ist ein internes oder externes Ereignis, eine Bedingung oder ein Schlüsselthema, das als Auslöser von Veränderungen fungiert. Ereignisse, Trends (in der Branche, auf dem Markt oder im technischen Bereich), Leistungsdefizite, Software-Implementierungen und sogar die Unternehmensziele können als Treiber des Wandels wirken.

Das mit der Implementierung des Programms selbst verbundene Risiko wird im Business Case beschrieben und über den gesamten Lebenszyklus gemanagt. Die Vorbereitung, Aktualisierung und Überwachung eines Business Case sind grundlegende und wichtige Aufgaben zur Rechtfertigung, Unterstützung und anschließenden Sicherstellung erfolgreicher Ergebnisse für jede Initiative, einschließlich der Verbesserung des Governance-Systems. Dadurch wird ein fortwährender Fokus auf den Nutzen des Programms und dessen Realisierung sichergestellt.

## 8.2.2 Phase 2 – Wo befinden wir uns heute?

In Phase 2 werden die I&T-bezogenen Ziele mit den Unternehmensstrategien und -risiken in Einklang gebracht und die wichtigsten Unternehmensziele, IT-bezogenen Ziele und Prozesse priorisiert. Der *COBIT® 2019-Designleitfaden* zeigt verschiedene Designfaktoren auf, die bei der Auswahl helfen können.

Auf der Grundlage der ausgewählten unternehmens- und IT-bezogenen Ziele und anderer Designfaktoren muss das Unternehmen kritische Governance- und Managementziele und die zugrunde liegenden Prozesse identifizieren, die ausreichend leistungsfähig sind, um erfolgreiche Ergebnisse zu gewährleisten. Das Management muss wissen, welche Fähigkeiten vorhanden sind und wo möglicherweise Defizite bestehen. Dies kann durch eine Bewertung der Prozessfähigkeit des aktuellen Status der ausgewählten Prozesse erreicht werden.

### 8.2.3 Phase 3 – Wo möchten wir stehen?

In Phase 3 wird ein Ziel für Verbesserungen festgelegt, gefolgt von einer GAP-Analyse, um mögliche Lösungen zu ermitteln.

Einige Lösungen werden kurzfristig realisierbar sein und andere anspruchsvollere, langfristige Aufgaben darstellen. Projekte, die leichter umzusetzen sind und den größten Nutzen bringen, sollten Vorrang erhalten. Längerfristige Aufgaben sollten in überschaubare Schritte aufgeteilt werden.

### 8.2.4 Phase 4 – Was muss getan werden?

In Phase 4 wird beschrieben, wie durchführbare und geeignete Lösungen geplant werden können, indem Projekte definiert werden, die durch überzeugende Business Cases und einen Umsetzungsplan unterstützt werden. Ein gut ausgearbeiteter Business Case trägt dazu bei, dass der Nutzen des Projekts identifiziert und kontinuierlich überwacht werden kann.

### 8.2.5 Phase 5 – Wie kommen wir dorthin?

Phase 5 sieht vor, die vorgeschlagenen Lösungen in die tägliche Praxis umzusetzen und Maßnahmen und Überwachungssysteme einzurichten, um sicherzustellen, dass die Ausrichtung an geschäftlichen Belangen sichergestellt ist und die Leistung gemessen werden kann.

Eine erfolgreiche Umsetzung erfordert Einsatz, Aufmerksamkeit, Kommunikation, Verständnis und Engagement der obersten Führungsebene und die Übernahme der Verantwortung durch die betroffenen Geschäfts- und IT-Prozessverantwortlichen.

### 8.2.6 Phase 6 – Sind wir angekommen?

Phase 6 konzentriert sich auf eine nachhaltige Übernahme der verbesserten Governance- und Managementpraktiken in den normalen Geschäftsbetrieb. Ein weiterer Schwerpunkt ist die Überwachung der erzielten Verbesserungen anhand der Leistungsmetriken und des erwarteten Nutzens.

### 8.2.7 Phase 7 – Wie können wir die Dynamik beibehalten?

In Phase 7 wird der Gesamterfolg der Initiative überprüft, weitere Governance- oder Managementanforderungen ermittelt und die Notwendigkeit einer kontinuierlichen Verbesserung untermauert. In diesem Zusammenhang werden auch weitere Möglichkeiten zur Verbesserung des Governance-Systems priorisiert.

Das Programm- und Projektmanagement basiert auf bewährten Praktiken und sieht für jede der sieben Phasen Kontrollpunkte vor, um sicherzustellen, dass die Leistung des Programms den Vorgaben entspricht, der Business Case und das Risiko aktualisiert werden und die Planung für die nächste Phase gegebenenfalls angepasst wird. Es wird davon ausgegangen, dass der Standardansatz des Unternehmens angewendet wird.

Weitere Informationen zum Programm- und Projektmanagement finden Sie auch unter den COBIT-Managementzielen BAI01 *Programme sind gemanagt* und BAI11 *Projekte sind gemanagt*. Obwohl die Berichterstattung in keiner der Phasen explizit erwähnt wird, zieht sie sich wie ein roter Faden durch alle Phasen und Iterationen.

## 8.3 Beziehung zwischen dem COBIT® 2019-Designleitfaden und dem COBIT® 2019-Implementierungsleitfaden

Der im COBIT® 2019-Designleitfaden erläuterte Arbeitsablauf weist die folgenden Verbindungspunkte mit dem COBIT® 2019-Implementierungsleitfaden auf. Der COBIT® 2019 Designleitfaden arbeitet eine Reihe von Aufgaben detaillierter aus, die im COBIT® 2019-Implementierungsleitfaden definiert sind. **Abbildung 8.2** gibt einen allgemeinen Überblick über diese Verbindungspunkte. Weitere Informationen finden Sie im COBIT® 2019-Designleitfaden.

| Abbildung 8.2 – Verbindungspunkte zwischen dem COBIT-Designleitfaden und dem COBIT-Implementierungsleitfaden |   |                                                                                                                                                                                                                                             |
|--------------------------------------------------------------------------------------------------------------|---|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| COBIT-Implementierungsleitfaden                                                                              |   | COBIT-Designleitfaden                                                                                                                                                                                                                       |
| <b>Phase 1</b> – Welche Treiber gibt es? (Kontinuierliche Verbesserung)                                      | ➔ | <b>Schritt 1</b> – Verstehen des Unternehmenskontexts und der Unternehmensstrategie                                                                                                                                                         |
| <b>Phase 2</b> – Wo befinden wir uns heute? (Kontinuierliche Verbesserung)                                   | ➔ | <b>Schritt 2</b> – Bestimmen des anfänglichen Umfangs des Governance-Systems<br><b>Schritt 3</b> – Weiterentwickeln des anfänglichen Umfangs des Governance-Systems<br><b>Schritt 4</b> – Fertigstellen des Konzepts des Governance-Systems |
| <b>Phase 3</b> – Wo möchten wir stehen? (Kontinuierliche Verbesserung)                                       | ➔ | <b>Schritt 4</b> – Fertigstellen des Designs des Governance-Systems                                                                                                                                                                         |

### Kapitel 9

## Erste Schritte mit COBIT: Erstellung des Business Case

### 9.1 Business Case

In der geschäftlichen Praxis ist die Erstellung eines Business Case zur Analyse und Rechtfertigung der Initiierung eines Großprojekts und/oder einer Finanzinvestition erforderlich. Dieses Beispiel ist als unverbindliche, allgemeine Hilfestellung zu sehen, um die Erstellung eines Business Case zur Rechtfertigung der Investition in ein EGIT-Implementierungsprogramm anzuregen. Jedes Unternehmen hat individuelle Gründe zur Verbesserung der EGIT und einen eigenen Ansatz zur Erstellung eines Business Case. Die Bandbreite reicht dabei von einem detaillierten Ansatz mit Schwerpunkt auf quantifizierten Nutzenvorteilen bis hin zu einem abstrakteren, eher qualitativen Ansatz. Unternehmen sollten sich dabei an im Unternehmen bestehenden Business Cases und Ansätzen zur Begründung von Investitionen orientieren. Dieses Beispiel und die Hinweise in dieser Publikation sollen helfen, sich auf die Fragestellungen zu konzentrieren, die in einem Business Case behandelt werden sollten.

*Im Beispielszenario geht es um die Muster AG, ein großes multinationales Unternehmen mit einer Mischung aus traditionellen, etablierten Geschäftseinheiten sowie neuen internetbasierten Geschäftsbereichen, die die neuesten Technologien einsetzen. Viele der Geschäftseinheiten wurden akquiriert und liegen in verschiedenen Ländern mit unterschiedlichen politischen, kulturellen und wirtschaftlichen Rahmenbedingungen. Das zentrale Team der obersten Führungskräfte arbeitet auf Basis der neuesten Leitfäden zur unternehmensweiten Governance, darunter auch COBIT, die das Unternehmen seit einiger Zeit zentral verwendet. Damit soll sichergestellt werden, dass die rasche Expansion und die Einführung moderner IT den erwarteten Nutzen bringen. Man rechnet auch mit erheblichen neuen Risiken, die es zu managen gilt. Daher wurde die unternehmensweite Einführung eines einheitlichen EGIT-Ansatzes in Auftrag gegeben. Dieser Ansatz umfasst die Einbeziehung der Audit- und Risikofunktionen und die interne jährliche Berichterstattung durch das Management der Geschäftseinheiten hinsichtlich der Angemessenheit der Kontrollen.*

Obwohl das Beispiel von einer realen Situation abgeleitet ist, spiegelt es nicht ein spezifisches, bestehendes Unternehmen wider.

### 9.2 Kurzfassung

Dieser Business Case stellt kurz den Umfang des vorgeschlagenen EGIT-Programms für die Muster AG auf der Grundlage von COBIT vor.

Um sicherzustellen, dass der Vorstand der Muster AG und die Geschäftseinheiten die Initiative unterstützen und die möglichen Vorteile erkennen, ist ein geeigneter Business Case erforderlich. Die Muster AG wird den Business Case überwachen, um sicherzustellen, dass die erwarteten Vorteile realisiert werden.

Alle Geschäftseinheiten der Muster AG sollen einbezogen werden. Es wird zur Kenntnis genommen, dass aufgrund der begrenzten Programmressourcen eine Priorisierung der Einheiten hinsichtlich der anfänglichen Umsetzung des EGIT-Programms erfolgen muss.

Verschiedene Anspruchsgruppen haben ein Interesse an den Ergebnissen des EGIT-Programms, vom Vorstand der Muster AG bis hin zum lokalen Management jeder Einheit, aber auch externe Anspruchsgruppen wie Aktionäre und Behörden.

Bei der erforderlichen Umsetzung des EGIT-Programms auf globaler Ebene müssen einige bedeutende Herausforderungen und Risiken, berücksichtigt werden. Einer der kritischen Aspekte ist der unternehmerische Charakter vie-



ler der internetbasierten Geschäftseinheiten sowie das dezentralisierte Geschäftsmodell, das innerhalb der Muster AG besteht.

Das EGIT-Programm wird umgesetzt, indem man sich auf die Leistungsfähigkeit der Prozesse der Muster AG und anderer Komponenten des Governance-Systems mit Bezug auf die in COBIT definierten Prozesse fokussiert, die für jede Geschäftseinheit relevant sind. Die relevanten und priorisierten Governance- und Managementziele, die in den jeweiligen Geschäftseinheiten im Fokus stehen, werden durch einen moderierten Workshop der Mitglieder des EGIT-Programms ermittelt. Am Anfang steht die Planung der Strategie- und Unternehmensziele jeder Einheit sowie der IT-bezogenen Geschäftsrisikoszenarien, die für die jeweilige Geschäftseinheit gelten.

Ziel des EGIT-Programms ist es, sicherzustellen, dass ein adäquates Governance-System, einschließlich der Governance-Strukturen, vorhanden ist, und die Fähigkeitsstufe und Angemessenheit der relevanten IT-Prozesse zu erhöhen. Die Erwartung ist, dass mit zunehmender Fähigkeitsstufe eines IT-Prozesses auch dessen Effizienz und Qualität steigt. Gleichzeitig wird das damit verbundene Risiko proportional abnehmen. Auf diese Weise können von jeder Geschäftseinheit tatsächliche Geschäftsvorteile realisiert werden.

Sobald der Prozess der Bewertung der Fähigkeitsstufen in jeder Geschäftseinheit etabliert ist, wird erwartet, dass die Selbstbewertungen innerhalb jeder Geschäftseinheit als normale Geschäftspraxis fortgeführt werden.

Das EGIT-Programm wird in zwei Phasen durchgeführt. Die erste Phase ist die Entwicklungsphase, in der das Team den Ansatz und die Werkzeuge, die in der gesamten Muster AG verwendet werden sollen, entwickelt und testet. Am Ende von Phase 1 werden die Ergebnisse der Konzernleitung zur endgültigen Genehmigung vorgelegt. Sobald die endgültige Genehmigung in Form eines genehmigten Business Case vorliegt, wird das EGIT-Programm in der Organisation in der vereinbarten Weise eingeführt (Implementierung, Phase 2).

Zum Umfang des EGIT-Programms gehört es nicht, die für die einzelnen Geschäftsbereiche festgelegten Änderungsmaßnahmen umzusetzen. Das EGIT-Programm wird lediglich die Fortschritte in den einzelnen Einheiten konsolidieren und darüber berichten.

Die finale Herausforderung für das EGIT-Programm ist die Berichterstattung darüber, ob die Ergebnisse sich auf nachhaltige Weise entwickeln. Dieser Aspekt wird Zeit und ein erhebliches Maß an Diskussionen und Entwicklung erfordern, sollte aber zu einer Verbesserung der bestehenden Berichterstattungsmechanismen und Scorecards des Unternehmen führen.

Für die Entwicklungsphase des EGIT-Programms wird ein erstes Budget erstellt. Das Budget wird in einem separaten Plan detailliert ausgearbeitet. Auch für Phase 2 des Projekts wird ein detailliertes Budget erstellt und der Konzernleitung zur Genehmigung vorgelegt.

## 9.3 Hintergrund

EGIT ist ein integraler Bestandteil der Unternehmens-Governance und konzentriert sich auf die IT-Leistung und das Management von Risiken, die auf die Abhängigkeiten des Unternehmens von der IT zurückzuführen sind.

Die IT ist ein fester Bestandteil des Geschäftsbetriebs der Muster AG. Für viele Einheiten ist das Internet das Herzstück ihrer Tätigkeit. EGIT folgt daher der Managementstruktur der Gruppe und arbeitet daher ebenfalls mit einer dezentralisierten Struktur. Das Management jedes Tochterunternehmens bzw. jeder Geschäftseinheit ist dafür verantwortlich, dass angemessene EGIT-Prozesse implementiert werden.

Jährlich muss die Geschäftsführung jeder größeren Tochtergesellschaft einen schriftlichen Bericht an den zuständigen Risikoausschuss, der aus Mitgliedern der Geschäftsleitung besteht, senden. In diesem Bericht wird im Einzelnen dargestellt, in welchem Umfang EGIT im Laufe des Geschäftsjahres umgesetzt wurde. Über bedeutsame Abweichungen muss auf jeder geplanten Sitzung des zuständigen Risikoausschusses berichtet werden.



Die Geschäftsleitung stellt mit Unterstützung der Risiko- und Prüfungsausschüsse sicher, dass die EGIT-Leistung der Gruppe bewertet, überwacht, berichtet und in einer Erklärung zur EGIT als Teil des Jahresberichts der Gruppe offengelegt wird. Die Erklärung wird sich auf Berichte stützen, die von den Risiko-, Compliance- und Audit-Teams und der Geschäftsführung jeder größeren Tochtergesellschaft eingeholt werden. Sie liefert sowohl internen als auch externen Anspruchsgruppen relevante und zuverlässige Informationen über die Qualität der EGIT-Aktivitäten der Gruppe.

Durch interne Audits wird dem Management und dem Revisionsausschuss die Angemessenheit und Wirksamkeit der EGIT bestätigt.

Über IT-bezogene Geschäftsrisiken in den Risikoregistern, die dem zuständigen Risikoausschuss vorgelegt werden, wird im Rahmen des Risikomanagementprozesses berichtet und diskutiert.

### 9.4 Geschäftliche Herausforderungen

Aufgrund der Allgegenwart der IT und der Geschwindigkeit des technologischen Wandels ist ein zuverlässiges Rahmenwerk erforderlich, um eine adäquate Kontrolle der gesamten IT-Umgebung zu gewährleisten und Kontrolllücken zu vermeiden, die das Unternehmen inakzeptablen Risiken aussetzen könnten.

Dabei ist es nicht die Intention, den IT-Betrieb der verschiedenen Betriebseinheiten zu behindern. Stattdessen soll das Risikoprofil der Einheiten in einer Weise verbessert werden, die geschäftlich sinnvoll ist und eine höhere Servicequalität und Effizienz bietet, wobei ausdrücklich nicht nur die Einhaltung der EGIT-Charta der Muster AG, sondern auch anderer gesetzlicher, behördlicher und/oder vertraglicher Anforderungen gewährleistet werden soll.

Einige Beispiele für mögliche Schwachstellen sind:<sup>25</sup>

- Schwierige Rahmenbedingungen für IT-Prüfungen aufgrund des unternehmerischen Charakters vieler Geschäftseinheiten
- Komplexe IT-Betriebsmodelle aufgrund der internetbasierten Geschäftsmodelle
- Geografisch verstreute Einheiten, die verschiedene Kulturen und Sprachen aufweisen
- Das in der Gruppe vorherrschende dezentrale und weitgehend autonome Unternehmenssteuerungsmodell
- Implementierung eines angemessenen IT-Managements angesichts einer hochspezialisierten und zeitweise fluktuierenden IT-Belegschaft
- Die auf die IT bezogene Abwägung zwischen dem Streben des Unternehmens nach Innovationsfähigkeit und geschäftlicher Agilität und der Notwendigkeit, Risiken zu managen und ausreichende Kontrolle auszuüben
- Die Festlegung von Risiko- und Toleranzniveaus für jede Geschäftseinheit
- Zunehmende Notwendigkeit, sich auf die Erfüllung gesetzlicher (Datenschutz) und vertraglicher (Payment Card Industry [PCI]) Compliance-Anforderungen zu konzentrieren
- Prüfungsfeststellungen zu ungenügenden IT-Kontrollen und gemeldete Probleme im Zusammenhang mit der IT-Servicequalität
- Erfolgreiche und pünktliche Bereitstellung neuer und innovativer Dienstleistungen in einem hart umkämpften Markt

---

<sup>25</sup> Diese Aufzählung ist eine Teilmenge der Aufzählung in Abschnitt 4.5 (Designfaktoren) und wird ebenfalls im COBIT® 2019-Implementierungsleitfaden behandelt. <sup>26</sup> Empirische Untersuchungen unterstützen diese Aussage. Siehe z. B.: De Haes, J. und van Grembergen, a. a. O.

## 9.4.1 GAP-Analyse und Ziel

Gegenwärtig gibt es weder einen gruppenweiten Ansatz, ein Rahmenwerk, noch werden bewährte IT-Praktiken und Standards umgesetzt. Bei den lokalen Geschäftseinheiten gibt es einen unterschiedlichen Grad der Übernahme bewährter Praktiken in Bezug auf EGIT. Infolgedessen wurde den IT-Prozessfähigkeitsstufen traditionell sehr wenig Aufmerksamkeit geschenkt. Erfahrungsgemäß sind die Stufen im Allgemeinen niedrig.

Das Ziel des EGIT-Programms ist es daher, die Fähigkeitsstufen und Angemessenheit der IT-bezogenen Prozesse und Kontrollen für jede Geschäftseinheit zu priorisieren und adäquat zu erhöhen.

Das Ergebnis sollte sein, dass signifikante Risiken identifiziert und artikuliert werden und das Management das Risiko angehen und den diesbezüglichen Status berichten kann. Mit steigender Fähigkeitsstufe der einzelnen Geschäftseinheiten sollten auch Qualität und Effizienz proportional zunehmen und das IT-bezogene Geschäftsrisikoprofil jeder Einheit abnehmen.

Letztendlich sollte sich auch der Geschäftswert durch eine effektive EGIT erhöhen.<sup>26</sup>

## 9.4.2 Betrachtete Alternativen

Es gibt viele IT-Rahmenwerke, die darauf ausgelegt sind, einzelne Aspekte der IT zu steuern. Das COBIT-Rahmenwerk wird von vielen als das weltweit führende EGIT- und Kontrollrahmenwerk angesehen. Es wurde bereits von einigen Tochtergesellschaften der Muster AG umgesetzt.

COBIT wurde von der Muster AG als das bevorzugte Rahmenwerk für die EGIT-Implementierung ausgewählt und soll daher auch von allen Tochtergesellschaften übernommen werden.

COBIT muss dabei nicht vollumfänglich implementiert werden, sondern nur die Bereiche, die für die jeweilige Tochtergesellschaft oder Geschäftseinheit relevant sind, wobei Folgendes zu berücksichtigen ist:

1. Die Entwicklungsstufe der jeweiligen Geschäftseinheit im Geschäftslebenszyklus
2. Die Geschäftsziele der Geschäftseinheit
3. Die Bedeutung der IT für die Geschäftseinheit
4. Das IT-bezogene Geschäftsrisiko, mit dem die Geschäftseinheit konfrontiert ist
5. Gesetzliche und vertragliche Anforderungen
6. Sonstige relevante Gründe

Wenn eine Tochtergesellschaft oder Geschäftseinheit bereits ein anderes Rahmenwerk implementiert hat oder für die Zukunft plant, sollte die Implementierung zu Zwecken der Berichterstattung, der Prüfung und der Klarheit der internen Kontrolle in COBIT abgebildet werden.

## 9.5 Lösungsvorschlag

Das EGIT-Programm wird in zwei Phasen geplant.

### 9.5.1 Phase 1: Vorplanung

Phase 1 des EGIT-Programms ist die Entwicklungsphase, in der die folgenden Schritte durchgeführt werden:

1. Die Struktur des Kernteams wird unter den Anspruchsgruppen und Projektteilnehmern festgelegt.
2. Das Kernteam schließt das COBIT Foundation Training ab.<sup>27</sup>

---

<sup>27</sup> ISACA Germany Chapter bietet zu COBIT ebenfalls verschiedene Schulungen in deutsch an (u.a. ITGCB, ITGCP). Weitere Informationen erhalten Sie unter [www.isaca.de](http://www.isaca.de).

3. Das Kernteam führt Workshops durch, um die Vorgehensweise festzulegen.
4. Innerhalb der Muster AG wird eine Online-Community eingerichtet, die als Plattform für den Wissensaustausch dienen soll.
5. Alle Anspruchsgruppen und ihre Anforderungen werden ermittelt.
6. Derzeitige Komitees, Rollen und Verantwortlichkeiten, Entscheidungsfindungs- und Berichterstattungsregelungen werden geklärt und bei Bedarf angepasst.
7. Als Grundlage für die erfolgreiche Umsetzung des Programms wird ein Business Case für das EGIT-Programm entwickelt und fortlaufend aktualisiert.
8. Es wird ein Kommunikationsplan für die Leitprinzipien, Richtlinien und den erwarteten Nutzen für das gesamte Programm erstellt.
9. Die Bewertungs- und Berichterstattungsinstrumente, die während der Laufzeit des Programms und darüber hinaus zum Einsatz kommen, werden entwickelt.
10. Der Ansatz wird in einer der lokalen Einheiten getestet. Der Grund dafür ist eine vereinfachte Logistik und die Möglichkeit der besseren Optimierbarkeit des Ansatzes und der Instrumente.
11. Der überarbeitete Ansatz wird in einer der ausländischen Geschäftseinheiten als Pilotprojekt umgesetzt. Damit sollen Hindernisse bei der Durchführung der Bewertungsphase des EGIT-Programms unter schwierigeren Geschäftsbedingungen festgestellt und quantifiziert werden.
12. Der endgültige Business Case und die Vorgehensweise werden vorgestellt, einschließlich eines Rollout-Plans, und der Führungsebene der Muster AG zur Genehmigung vorgelegt.

### 9.5.2 Phase 2: Programm-Implementierung

Durch das EGIT-Programm soll ein fortlaufendes Programm zur kontinuierlichen Verbesserung auf der Grundlage eines unterstützenden, iterativen Lebenszyklus eingeleitet werden, bei dem die folgenden Schritte durchlaufen werden:

1. Bestimmen der treibenden Faktoren zur Verbesserung der EGIT, sowohl aus der Perspektive der Muster AG-Gruppe als auch auf der Ebene der Geschäftseinheiten.
2. Ermitteln des aktuellen EGIT-Status.
3. Festlegen des gewünschten EGIT-Zielstatus (sowohl kurz- als auch langfristig).
4. Ermitteln, was auf der Ebene der Geschäftseinheiten umgesetzt werden muss, um lokale Geschäftsziele zu ermöglichen und den Erwartungen der Gruppe zu entsprechen.
5. Implementieren der identifizierten und vereinbarten Verbesserungsprojekte auf der Ebene der lokalen Geschäftseinheiten.
6. Realisieren und überwachen der Nutzensvorteile.
7. Fortsetzen der neuen Arbeitsweise, durch Beibehalten der bestehenden Dynamik.

### 9.5.3 Programmumfang

Das EGIT-Programm deckt die folgenden Bereiche ab:

1. Alle Geschäftseinheiten der Gruppe. Die Geschäftseinheiten müssen jedoch aufgrund der begrenzten Programmressourcen priorisiert werden.
2. Die Methode der Priorisierung muss mit dem Management der Muster AG vereinbart werden, könnte aber auf folgender Grundlage erfolgen:
  - a. Umfang der Investition
  - b. Gewinn/Beitrag zur Gruppe
  - c. Risikoprofil aus Gruppensicht

- d. Eine Kombination dieser Kriterien
- 3. Die Liste der Geschäftseinheiten, die während des laufenden Geschäftsjahres abgedeckt werden sollen. Diese sollte finalisiert und vom Management der Muster AG verabschiedet werden.

## 9.5.4 Programm-Methodik und Ausrichtung

Das EGIT-Programm wird in Form eines moderierten, interaktiven Workshop-Ansatzes mit allen Geschäftseinheiten umgesetzt.

Der Ansatz beginnt mit der Festlegung der Geschäftsziele und des Zielverantwortlichen, in der Regel der CEO und der Chief Financial Officer (CFO). Der Ansatz sollte sicherstellen, dass die Programmergebnisse eng an den erwarteten Geschäftsergebnissen und Prioritäten ausgerichtet sind.

Sobald die Geschäftsziele erreicht sind, verlagert sich der Schwerpunkt auf den IT-Betrieb, in der Regel unter der Verantwortung des Chief Technology Officer (CTO) oder Chief Information Officer (CIO). Auf der Ebene des IT-Betriebs werden weitere Einzelheiten zu den IT-bezogenen Geschäftsrisiken und -zielen betrachtet.

Die Geschäfts- und IT-Ziele sowie das IT-bezogene Geschäftsrisiko werden dann in einem Tool (basierend auf den COBIT-Leitlinien) kombiniert, das eine Reihe von Schwerpunktbereichen innerhalb der COBIT-Prozesse zur Berücksichtigung durch die Geschäftseinheit bereitstellt. Auf diese Weise kann die Geschäftseinheit ihre Anstrengungen zur Nachbesserung priorisieren, um Bereiche mit IT-Risiken anzugehen.

## 9.5.5 Programmergebnisse

Wie bereits erwähnt, besteht ein übergeordnetes Ziel des EGIT-Programms darin, bewährte EGIT-Verfahren in den laufenden Betrieb der verschiedenen Geschäftseinheiten der Gruppe einzubetten.

Das EGIT-Programm wird spezifische Ergebnisse liefern, die der Muster AG erlauben zu beurteilen, inwieweit die beabsichtigten Ergebnisse erreicht wurden. Das umfasst Folgendes:

1. Das EGIT-Programm wird den internen Wissensaustausch über die Intranet-Plattform erleichtern und bestehende Beziehungen zu Anbietern zum Vorteil der einzelnen Geschäftseinheiten nutzen.
2. Detaillierte Berichte über jede erreichte Verbesserung in den Geschäftsbereichen werden mit Hilfe des Bewertungs-Tools des EGIT-Programms erstellt. Die Berichte enthalten:
  - a. Die aktuellen priorisierten Geschäftsziele und die sich daraus ergebenden IT-Ziele, basierend auf COBIT.
  - b. Das von der Geschäftseinheit identifizierte IT-bezogene Risiko, angegeben in einem standardisierten Format und die vereinbarten Schwerpunktbereiche, auf die sich die Geschäftseinheit auf der Grundlage der COBIT-Prozesse und -Praktiken und anderer empfohlener Komponenten konzentrieren soll.
3. Weiterhin werden Berichte über den Gesamtfortschritt hinsichtlich der geplanten Abdeckung der Geschäftsbereiche der Muster AG durch das EGIT-Programm erstellt.
4. Die konsolidierte Gruppenberichterstattung umfasst:
  - a. Fortschritte der Geschäftseinheiten, die die vereinbarten Implementierungsprojekte umsetzen, auf der Grundlage der Überwachung vereinbarter Leistungsmetriken.
  - b. Das konsolidierte IT-Risiko der Geschäftseinheiten der Muster AG.
  - c. Besondere Anforderungen des/der Risikoausschusses/-ausschüsse.
5. Ein Finanzbericht zum Programmbudget im Vergleich zu dem tatsächlich ausgegebenen Betrag wird erstellt.

6. Die Nutzenüberwachung und Berichterstattung hinsichtlich der von den Geschäftseinheiten definierten Wertziele und Metriken wird durchgeführt.

### 9.5.6 Programmrisiko

Im Folgenden werden potenzielle Risiken im Zusammenhang mit der Einführung und Sicherstellung der erfolgreichen Umsetzung des EGIT-Programms der Muster AG betrachtet. Das Risiko wird durch die Konzentration auf die Ermöglichung von Veränderung gemildert und durch Programmüberprüfungen und ein Risikoregister kontinuierlich überwacht und angegangen. Die Arten von Risiken sind:

1. Engagement und Unterstützung für das Programm seitens des Managements, sowohl auf Konzernebene als auch auf der Ebene der lokalen Geschäftseinheiten.
2. Nachweis der tatsächlichen Wertschöpfung und des Nutzens für jede lokale Einheit bei Anwendung des Programms. Die lokalen Geschäftseinheiten sollten den Prozess aufgrund des Nutzens, den er bringen wird, anwenden wollen, anstatt ihn aufgrund der bestehenden Vorgaben durchzuführen.
3. Aktive Beteiligung des Managements vor Ort an der Implementierung des Programms.
4. Identifizieren der für die Teilnahme am Programm wichtigen Anspruchsgruppen in jeder Einheit.
5. Geschäftseinblicke auf der Ebene des IT-Managements.
6. Erfolgreiche Integration in die innerhalb der Gruppe bestehenden Governance- oder Compliance-Initiativen.
7. Die geeigneten Ausschussstrukturen zur Überwachung des Programms. Zum Beispiel könnte der Fortschritt des EGIT-Programms zu einem Tagesordnungspunkt des IT-Exekutivkomitees werden. Es sollten auch entsprechende lokale Äquivalente gebildet werden. Dies könnte sowohl geographisch als auch gegebenenfalls auf der Ebene der lokalen Holdinggesellschaften wiederholt werden.

### 9.5.7 Anspruchsgruppen

Bezüglich des Ergebnisses des EGIT-Programms bestehen folgende Anspruchsgruppen:

1. Risikoausschuss
2. IT-Exekutivkomitee
3. Governance-Team
4. Compliance-Personal
5. Regionales Management
6. Oberste Führungskräfte vor Ort (einschließlich IT-Management)
7. Interne Revision

Eine endgültige Struktur, die die Namen der Anspruchsgruppenmitglieder enthält, wird nach Rücksprache mit der Konzernleitung erstellt und veröffentlicht.

Das EGIT-Programm benötigt von den benannten Anspruchsgruppenmitgliedern folgende Beiträge:

1. Orientierungshilfe zur Gesamtausrichtung des EGIT-Programms. Entscheidungen zu wichtigen Governance-bezogenen Themen, die in einem RACI-Chart gemäß den COBIT-Leitlinien definiert sind. Festlegung von Prioritäten, eine Einigung hinsichtlich der Finanzierung und die Genehmigung von wertmäßigen Zielen.
2. Abnahme der Ergebnisse und Überwachung des erwarteten Nutzens des EGIT-Programms.

### 9.5.8 Kosten-Nutzen-Analyse

Das Programm sollte den erwarteten Nutzen ermitteln und überwachen, um sicherzustellen, dass aus der Investition echter Geschäftswert geschaffen wird. Das Management vor Ort sollte für Motivation und Aufrechterhaltung des

Programms sorgen. Eine sachgerechte EGIT sollte zu Nutzensvorteilen führen, die in Form von spezifischen Zielen für jede Geschäftseinheit festgelegt und während der Implementierung überwacht und gemessen werden, um sicherzustellen, dass sie umgesetzt werden. Zu den Nutzensvorteilen gehören:

1. Maximierung der Umsetzung von Geschäftschancen durch die IT bei gleichzeitiger Minderung der IT-bezogenen Geschäftsrisiken auf ein akzeptables Maß, wodurch sichergestellt wird, dass bei allen Geschäftsinitiativen Risiko und Chancen verantwortungsbewusst gegeneinander abgewogen werden.
2. Unterstützung der Geschäftsziele durch Schlüsselinvestitionen und Sicherstellung maximaler Erträge aus diesen Investitionen, wobei IT-Initiativen und -Ziele unmittelbar auf die Geschäftsstrategie abgestimmt werden sollten.
3. Einhaltung von Gesetzen, Vorschriften und Verträgen sowie von internen Richtlinien und Verfahren.
4. Ein einheitlicher Ansatz zur Messung und Überwachung von Fortschritt, Effizienz und Effektivität.
5. Verbesserte Qualität der bereitgestellten Services.
6. Geringere Kosten des IT-Betriebs und/oder höhere IT-Produktivität durch konsistentere Erbringung eines höheren Arbeitsvolumens in kürzerer Zeit und mit weniger Ressourceneinsatz.

Die zentralen Kosten umfassen den Zeitaufwand für das Programm-Management der Gruppe, externe Beratungsleistungen und Einführungsschulungen. Diese zentralen Kosten wurden für Phase 1 geschätzt. Die Kosten der Workshops für die einzelnen Geschäftsbereichsleiter und Prozessverantwortlichen (Teilnahme, Veranstaltungsort, Moderatoren und andere damit verbundene Kosten) werden vor Ort getragen und ein Kostenvoranschlag wird vorgelegt. Spezifische Projektverbesserungsinitiativen für jede Geschäftseinheit werden in Phase 2 kalkuliert und sowohl fallweise als auch insgesamt betrachtet. Dies wird für maximale Effizienz und Standardisierung im Konzern sorgen.

## 9.5.9 Herausforderungen und Erfolgsfaktoren

**Abbildung 9.1** fasst die Herausforderungen zusammen, mit denen das EGIT-Programm während der Implementierungsphase konfrontiert sein könnte, sowie die kritischen Erfolgsfaktoren, die angegangen werden sollten, um ein erfolgreiches Ergebnis zu gewährleisten.

| <b>Abbildung 9.1 – Herausforderungen und geplante Maßnahmen für die Muster AG</b>    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|--------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Herausforderung</b>                                                               | <b>Kritischer Erfolgsfaktor – Geplante Maßnahmen</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Unfähigkeit, Unterstützung für Verbesserungsziele zu gewinnen und aufrechtzuerhalten | <ul style="list-style-type: none"><li>• Behebung durch Ausschussstrukturen in der Gruppe (zu vereinbaren und umzusetzen).</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Kommunikationsbarrieren zwischen IT und Geschäftseinheiten                           | <ul style="list-style-type: none"><li>• Einbeziehung aller Anspruchsgruppen.</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Kosten der Verbesserungen überlagern den wahrgenommenen Nutzen                       | <ul style="list-style-type: none"><li>• Schwerpunkt auf die Nutzensvorteile legen.</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Mangel an Vertrauen und guten Beziehungen zwischen der IT und dem Unternehmen        | <ul style="list-style-type: none"><li>• Förderung einer offenen und transparenten Kommunikation über Leistung, mit Anbindung an die unternehmensinterne Leistungssteuerung.</li><li>• Schwerpunkt auf betrieblichen Schnittstellen und Servicementalität.</li><li>• Veröffentlichung positiver Ergebnisse und der daraus gewonnenen Erkenntnisse, um Glaubwürdigkeit zu schaffen und zu erhalten.</li><li>• Sicherstellen, dass der CIO beim Aufbau von Vertrauen und Beziehungen glaubwürdig bleibt und seine Führungsrolle wahrnimmt.</li><li>• Formalisierung der Rollen und Verantwortlichkeiten für Governance im Unternehmen, damit die Verantwortlichkeit für Entscheidungen klar ist.</li><li>• Identifizieren und kommunizieren von Belegen für tatsächliche Probleme, zu vermeidende Risiken und (in geschäftlicher Hinsicht) zu erzielende Vorteile im Zusammenhang mit den vorgeschlagenen Verbesserungen.</li><li>• Schwerpunkt auf Überlegungen zur Ermöglichung von Veränderungen.</li></ul> |



**Abbildung 9.1 – Herausforderungen und geplante Maßnahmen für die Muster AG**

| Herausforderung                                                                                                            | Kritischer Erfolgsfaktor – Geplante Maßnahmen                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|----------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Mangelndes Verständnis des Umfelds der Muster AG seitens der für das EGIT-Programm Verantwortlichen                        | <ul style="list-style-type: none"> <li>Anwendung einer einheitlichen Beurteilungsmethodik.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Verschiedene Komplexitätsebenen (technisch, organisatorisch, Betriebsmodell)                                               | <ul style="list-style-type: none"> <li>Fallweise Behandlung der Einheiten. Profit aus den gewonnenen Erkenntnissen ziehen und Wissensaustausch.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                  |
| Verstehen des EGIT-Rahmenwerks, der Verfahren und Praktiken                                                                | <ul style="list-style-type: none"> <li>Schulungen und Mentoren bereitstellen.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Widerstand gegen Veränderungen                                                                                             | <ul style="list-style-type: none"> <li>Sicherstellen, dass die Implementierung des Lebenszyklus auch Aktivitäten zur Ermöglichung von Veränderungen umfasst.</li> </ul>                                                                                                                                                                                                                                                                                                                                                     |
| Annahme von Verbesserungen                                                                                                 | <ul style="list-style-type: none"> <li>Ermöglichung einer Befähigung vor Ort, auf der Ebene der Geschäftseinheiten.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                              |
| Schwierigkeiten bei der Integration von EGIT in die Governance-Modelle von Outsourcing-Partnern                            | <ul style="list-style-type: none"> <li>Einbeziehung von Lieferanten/Drittparteien in die EGIT-Aktivitäten.</li> <li>Aufnahme von Bedingungen und dem Recht auf Prüfung in Verträge.</li> </ul>                                                                                                                                                                                                                                                                                                                              |
| Nichteinhaltung der Verpflichtung zur EGIT-Implementierung                                                                 | <ul style="list-style-type: none"> <li>Erwartungen managen.</li> <li>Es einfach, realistisch und pragmatisch halten.</li> <li>Unterteilung des Gesamtprojekts in kleine, realisierbare Projekte, um Erfahrungen zu sammeln und Nutzen zu generieren.</li> </ul>                                                                                                                                                                                                                                                             |
| Zu viel auf einmal tun: IT geht übermäßig komplexe und/oder schwierige Probleme an                                         | <ul style="list-style-type: none"> <li>Vorgabe von Programm- und Projektmanagement-Grundsätzen.</li> <li>Festlegen von Meilensteinen.</li> <li>Anwenden der 80/20-Regel (Aufgaben mit 80 Prozent Nutzen bei 20 Prozent Aufwand) unter Beachtung der richtigen Abfolge. Umsetzen von kurzfristig realisierbaren Erfolgen.</li> <li>Vertrauen aufbauen. Über die Fähigkeiten und Erfahrungen verfügen, die Schritte einfach und pragmatisch umzusetzen.</li> <li>Nutzen des bereits Vorhandenen als Ausgangsbasis.</li> </ul> |
| IT durch Aktionismus gekennzeichnet und/oder nicht gut priorisierend und nicht in der Lage, sich auf EGIT zu konzentrieren | <ul style="list-style-type: none"> <li>Führungsstärke zeigen.</li> <li>Einbindung und Unterstützung seitens des oberen Managements, damit sich die Mitarbeiter auf EGIT konzentrieren können.</li> <li>Auseinandersetzung mit den Ursachen im operativen Bereich (externe Intervention, Priorisierung der IT durch das Management).</li> <li>Strengere Disziplin bei der Bearbeitung/Handhabung von geschäftlichen Anforderungen.</li> <li>Externe Unterstützung einbinden.</li> </ul>                                      |
| Fehlen der erforderlichen IT-Kenntnisse und Kompetenzen, wie z. B. Verständnis des Geschäfts, der Prozesse, Soft Skills    | <ul style="list-style-type: none"> <li>Schwerpunkt auf der Planung der Begünstigung von Veränderungen:               <ul style="list-style-type: none"> <li>Entwicklung</li> <li>Schulungen</li> <li>Coaching</li> <li>Mentoring</li> <li>Feedback in den Rekrutierungsprozess einfließen lassen</li> <li>Übergreifende Ausbildung</li> </ul> </li> </ul>                                                                                                                                                                   |
| Nicht übernommene oder angewandte Verbesserungen                                                                           | <ul style="list-style-type: none"> <li>Verwenden eines fallweisen Ansatzes mit abgestimmten Prinzipien für die lokale Einheit. Die praktische Umsetzbarkeit muss gewährleistet sein.</li> </ul>                                                                                                                                                                                                                                                                                                                             |
| Vorteile, die schwer zu demonstrieren oder nachzuweisen sind                                                               | <ul style="list-style-type: none"> <li>Ausweisen von Leistungsmetriken.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Nachlassen von Interesse und Schwung.                                                                                      | <ul style="list-style-type: none"> <li>Engagement auf Gruppenebene aufbauen, einschließlich Kommunikation.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                       |

Diese Seite wurde absichtlich freigelassen.



## Kapitel 10

### COBIT und andere Standards

#### 10.1 Leitprinzipien

Eines der Leitprinzipien während der gesamten Entwicklung von COBIT® 2019 war es, die Positionierung von COBIT als übergreifendes Rahmenwerk beizubehalten. Dies bedeutet, dass sich COBIT weiterhin an einer Reihe von wichtigen Standards, Rahmenwerken und/oder Vorschriften ausrichtet.

In diesem Zusammenhang bedeutet Ausrichtung, dass COBIT nicht im Widerspruch zu Leitlinien in den jeweiligen Standards steht. Gleichzeitig ist es wichtig, darauf hinzuweisen, dass COBIT den Inhalt dieser verwandten Standards nicht schlicht kopiert. Stattdessen enthält COBIT in der Regel vergleichbare Aussagen oder Verweise auf relevante Leitlinien.

#### 10.2 Liste der Standards auf die Bezug genommen wird

Standards und Leitlinien, die im Zuge der Aktualisierung von COBIT®2019 verwendet wurden:

- CIS® Center for Internet Security®, The CIS Critical Security Controls for Effective Cyber Defense, Version 6.1, August 2016
- Cloud-Standards und bewährte Praktiken:
  - Amazon Web Services (AWS®)
  - *Security Considerations for Cloud Computing*, ISACA
  - *Controls and Assurance in the Cloud: Using COBIT® 5*, ISACA
- CMMI® Cybermaturity Platform, 2018
- CMMI® Data Management Maturity (DMM)<sup>SM</sup> model, 2014
- CMMI® Development V2.0, CMMI Institute, USA, 2018
- Committee of Sponsoring Organizations (COSO) Enterprise Risk Management (ERM) Framework, Juni 2017
- European Committee for Standardization (CEN), *e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework*, EN 16234-1:2016
- Common Security Framework, Version 9, September 2017
- Information Security Forum (ISF), *The Standard of Good Practice for Information Security 2016*
- Standards der International Organization for Standardization / International Electrotechnical Commission (ISO/IEC):
  - ISO/IEC 20000-1:2011(E)
  - ISO/IEC 27001:2013/Cor.2:2015(E)
  - ISO/IEC 27002:2013/Cor.2:2015(E)
  - ISO/IEC 27004:2016(E)
  - ISO/IEC 27005:2011(E)
  - ISO/IEC 38500:2015(E)
  - ISO/IEC 38502:2017(E)
- Information Technology Infrastructure Library (ITIL®) v3, 2011
- Institute of Internal Auditors® (IIA®), “Core Principles for the Professional Practice of Internal Auditing”
- *King IV Report on Corporate Governance™*, 2016

- Standards des US National Institute of Standards and Technology (NIST):
  - *Framework for Improving Critical Infrastructure Cybersecurity* V1.1, April 2018
  - Special Publication 800–37, Revision 2 (Entwurf), Mai 2018
  - Special Publication 800–53, Revision 5 (Entwurf), August 2017
  - „Options for Transforming the IT Function Using Bimodal IT“, *MIS Quarterly Executive* (White Paper)
  - *A Guide to the Project Management Body of Knowledge: PMBOK® Guide*, 6. Auflage, 2017
  - PROSCI® 3-Phase Change Management Process
  - Scaled Agile Framework for Lean Enterprises (SAFe®)
  - Skills Framework for the Information Age (SFIA®) V6, 2015
- The Open Group IT4IT™ Reference Architecture, Version 2.0
- The Open Group Standard TOGAF® Version 9.2, 2018
- The TBM Taxonomy, The TBM Council